

TRƯỜNG ĐẠI HỌC XÂY DỰNG
KHOA CÔNG NGHỆ THÔNG TIN

—o0o—



BÀI TẬP LỚN

MÔN HỌC: AN TOÀN BẢO MẬT THÔNG TIN

NGHIÊN CỨU CÁC NGUY CƠ AN TOÀN THÔNG TIN
TRÊN MÔI TRƯỜNG CLOUD VÀ XÂY DỰNG MÔ
HÌNH BẢO VỆ DỮ LIỆU

Lương Ngọc Minh	0370369	69CS1
Hoàng Khánh Nguyên	0707769	69CS1
Tạ Việt Thành	0372969	69CS1
Dương Hữu Hình	0367869	69CS1

TRƯỜNG ĐẠI HỌC XÂY DỰNG
KHOA CÔNG NGHỆ THÔNG TIN

—o0o—



BÀI TẬP LỚN

MÔN HỌC: AN TOÀN BẢO MẬT THÔNG TIN

NGHIÊN CỨU CÁC NGUY CƠ AN TOÀN THÔNG TIN
TRÊN MÔI TRƯỜNG CLOUD VÀ XÂY DỰNG MÔ
HÌNH BẢO VỆ DỮ LIỆU

Lương Ngọc Minh	0370369	69CS1
Hoàng Khánh Nguyên	0707769	69CS1
Tạ Việt Thành	0372969	69CS1
Dương Hữu Hình	0367869	69CS1

GIẢNG VIÊN HƯỚNG DẪN: ThS. Nguyễn Việt Nhật

HÀ NỘI – 2026

LỜI CẢM ƠN

Chúng em xin trân trọng cảm ơn ThS. Nguyễn Việt Nhật, giảng viên hướng dẫn đề tài, cùng các thầy cô Khoa Công nghệ Thông tin, Trường Đại học Xây dựng Hà Nội.

Quá trình thực hiện đề tài là cơ hội để nhóm vận dụng kiến thức về an toàn thông tin, điện toán đám mây và phát triển ứng dụng vào việc xây dựng hệ thống CloudBox. Nhóm mong nhận được những góp ý của thầy cô để hoàn thiện báo cáo và nâng cao kiến thức chuyên môn.

MỤC LỤC

DANH MỤC TỪ VIẾT TẮT, THUẬT NGỮ	ii
DANH MỤC BẢNG BIỂU	iv
DANH MỤC HÌNH VẼ, ĐỒ THỊ	v
MỞ ĐẦU	1
1. Lý do chọn đề tài	1
2. Mục tiêu nghiên cứu	2
2.1. Mục tiêu tổng quát	2
2.2. Mục tiêu cụ thể	2
3. Đối tượng nghiên cứu	2
4. Phạm vi nghiên cứu	2
5. Phương pháp nghiên cứu	3
6. Kết quả đạt được và giới hạn bằng chứng	3
7. Cấu trúc báo cáo	3
1 CƠ SỞ LÝ THUYẾT VỀ ĐIỆN TOÁN Đám Mây VÀ AN TOÀN THÔNG TIN	4
1.1 Tổng quan về điện toán đám mây	4
1.1.1 Khái niệm điện toán đám mây	4
1.1.2 Đặc điểm của điện toán đám mây	5
1.1.3 Ưu điểm của điện toán đám mây	6
1.1.4 Hạn chế của điện toán đám mây	6
1.2 Các mô hình dịch vụ Cloud	7
1.2.1 Infrastructure as a Service	7
1.2.2 Platform as a Service	8
1.2.3 Software as a Service	8
1.2.4 So sánh các mô hình dịch vụ	9
1.3 Các mô hình triển khai Cloud	9
1.3.1 Public Cloud	9
1.3.2 Private Cloud	10
1.3.3 Hybrid Cloud	10
1.3.4 So sánh các mô hình triển khai	10
1.4 Mô hình trách nhiệm chia sẻ	11

1.4.1	Trách nhiệm của nhà cung cấp Cloud	11
1.4.2	Trách nhiệm của khách hàng	11
1.4.3	Áp dụng mô hình trách nhiệm chia sẻ vào đề tài	11
1.5	Tổng quan về an toàn thông tin	12
1.5.1	Tài sản thông tin	12
1.5.2	Mối đe dọa, lỗ hổng và rủi ro	13
1.5.3	Bộ ba CIA	13
1.5.4	Các nguyên tắc bảo mật	14
1.6	Các cơ chế bảo vệ dữ liệu	15
1.6.1	Xác thực người dùng	15
1.6.2	Kiểm soát truy cập	15
1.6.3	Mã hóa và hàm băm	16
1.6.4	Ghi log và giám sát	16
1.6.5	Sao lưu và phục hồi	17
1.7	Một số tiêu chuẩn và khung tham chiếu	18
1.8	Kết luận chương	19

2 CÁC NGUY CƠ AN TOÀN THÔNG TIN TRÊN MÔI TRƯỜNG CLOUD 20

2.1	Tổng quan về nguy cơ an toàn thông tin trên Cloud	20
2.2	Phân loại dữ liệu và tài sản cần bảo vệ	20
2.2.1	Dữ liệu định danh	20
2.2.2	Dữ liệu xác thực	21
2.2.3	Dữ liệu nghiệp vụ	21
2.2.4	Dữ liệu vận hành	21
2.3	Nguy cơ đối với danh tính và quyền truy cập	21
2.3.1	Mật khẩu yếu	21
2.3.2	Tấn công brute force	22
2.3.3	Chiếm đoạt tài khoản	22
2.3.4	Phân quyền không phù hợp	22
2.3.5	Leo thang đặc quyền	22
2.4	Nguy cơ đối với ứng dụng Cloud	23
2.4.1	Broken Access Control	23
2.4.2	SQL Injection	23
2.4.3	Cross-Site Scripting	23
2.4.4	Cross-Site Request Forgery	24
2.4.5	Quản lý phiên không an toàn	24
2.4.6	API không an toàn	24

2.5	Nguy cơ từ tệp tải lên	24
2.5.1	Giả mạo định dạng tệp	24
2.5.2	Path traversal	25
2.5.3	Tệp nén nguy hiểm	25
2.5.4	Tệp chứa mã độc	25
2.5.5	Tấn công làm cạn kiệt tài nguyên	25
2.6	Nguy cơ đối với dữ liệu lưu trữ	26
2.6.1	Rò rỉ dữ liệu	26
2.6.2	Dữ liệu bị sửa đổi	26
2.6.3	Mất dữ liệu	26
2.6.4	Dữ liệu không được mã hóa	26
2.7	Nguy cơ cấu hình sai hạ tầng Cloud	27
2.7.1	Cấu hình sai Amazon S3	27
2.7.2	Cấu hình sai Amazon RDS	27
2.7.3	Cấu hình sai Amazon EC2	27
2.7.4	Cấu hình sai IAM	27
2.7.5	Quản lý secret không an toàn	28
2.8	Nguy cơ từ chuỗi cung ứng phần mềm	28
2.9	Nguy cơ từ con người và quy trình	28
2.10	Mô hình hóa mối đe dọa	28
2.10.1	Xác định tác nhân	28
2.10.2	Xây dựng biểu đồ luồng dữ liệu	29
2.10.3	Xác định ranh giới tin cậy	29
2.10.4	Phân tích theo STRIDE	29
2.11	Đánh giá rủi ro	29
2.12	Ma trận rủi ro	30
2.13	Kết luận chương	31
3	ĐỀ XUẤT MÔ HÌNH BẢO VỆ DỮ LIỆU TRÊN MÔI TRƯỜNG CLOUD	32
3.1	Mục tiêu và phạm vi của mô hình	32
3.1.1	Mục tiêu bảo vệ	32
3.1.2	Phạm vi hiện thực	32
3.2	Yêu cầu của mô hình	33
3.2.1	Yêu cầu chức năng	33
3.2.2	Yêu cầu bảo mật	33
3.2.3	Yêu cầu vận hành	34
3.3	Kiến trúc tổng thể của mô hình	34

3.4	Lớp bảo vệ danh tính	34
3.4.1	Bảo vệ mật khẩu	34
3.4.2	Chống tấn công đăng nhập	35
3.4.3	Khôi phục mật khẩu bằng OTP	35
3.4.4	Bảo vệ phiên	36
3.5	Lớp kiểm soát truy cập	36
3.5.1	Mô hình RBAC	36
3.5.2	Kiểm soát quyền ở cấp tài liệu	36
3.5.3	Nguyên tắc đặc quyền tối thiểu	36
3.6	Lớp bảo vệ ứng dụng	37
3.6.1	Bảo vệ chống CSRF	37
3.6.2	Bảo vệ chống XSS	37
3.6.3	Bảo vệ chống SQL Injection	37
3.6.4	Các header bảo mật HTTP	38
3.7	Lớp bảo vệ tệp tải lên	38
3.8	Lớp bảo vệ dữ liệu lưu trữ	38
3.8.1	Bảo vệ siêu dữ liệu	38
3.8.2	Bảo vệ nội dung tệp	39
3.8.3	Bảo vệ tính toàn vẹn	39
3.9	Lớp bảo vệ hạ tầng AWS	39
3.9.1	Bảo vệ mạng	39
3.9.2	Bảo vệ Amazon S3	39
3.9.3	Bảo vệ Amazon RDS	40
3.9.4	Bảo vệ Amazon EC2	40
3.9.5	Quản lý secret	40
3.10	Lớp ghi log và giám sát	40
3.11	Lớp sao lưu và phục hồi	41
3.12	Bảo mật quá trình phát triển và triển khai	41
3.13	Luồng hoạt động của mô hình	41
3.13.1	Luồng đăng nhập an toàn	41
3.13.2	Luồng tải lên an toàn	41
3.13.3	Luồng tải xuống an toàn	42
3.13.4	Luồng khôi phục mật khẩu	42
3.14	Ma trận nguy cơ và biện pháp bảo vệ	42
3.15	Kết luận chương	43

4	XÂY DỰNG HỆ THỐNG CLOUDBOX	44
4.1	Giới thiệu hệ thống CloudBox	44
4.2	Công nghệ sử dụng	44
4.3	Kiến trúc hệ thống	44
4.3.1	Kiến trúc ứng dụng	44
4.3.2	Kiến trúc local	45
4.3.3	Kiến trúc Docker	46
4.3.4	Kiến trúc AWS	46
4.4	Phân tích chức năng hệ thống	47
4.4.1	Chức năng xác thực	47
4.4.2	Chức năng quản lý tài liệu	47
4.4.3	Chức năng chia sẻ	47
4.4.4	Chức năng quản trị	47
4.5	Thiết kế cơ sở dữ liệu	48
4.6	Hiện thực xác thực và quản lý phiên	49
4.7	Hiện thực khôi phục mật khẩu bằng OTP	49
4.8	Hiện thực RBAC	49
4.9	Hiện thực kiểm soát tài liệu	50
4.10	Hiện thực kiểm tra tệp tải lên	50
4.11	Hiện thực các biện pháp bảo mật web	51
4.12	Hiện thực lưu trữ dữ liệu	51
4.12.1	Môi trường local	51
4.12.2	Môi trường AWS	52
4.13	Docker hóa hệ thống	52
4.14	Xây dựng hạ tầng AWS bằng Terraform	53
4.14.1	Cấu trúc hạ tầng và các kiểm soát chính	53
4.14.2	Kết quả triển khai thực tế trên AWS	54
4.15	Xây dựng quy trình CI/CD	57
4.16	Kết quả xây dựng hệ thống	57
4.17	Kết luận chương	58
5	KIỂM THỬ VÀ ĐÁNH GIÁ MÔ HÌNH	59
5.1	Mục tiêu kiểm thử	59
5.2	Môi trường kiểm thử	59
5.2.1	Kiểm tra endpoint ứng dụng trên Ubuntu	59
5.3	Phương pháp kiểm thử	60
5.4	Kiểm thử chức năng	61
5.4.1	Kiểm thử xác thực	61

5.4.2	Kiểm thử quản lý tài liệu	61
5.4.3	Kiểm thử chia sẻ	61
5.4.4	Kiểm thử quản trị	61
5.5	Kiểm thử bảo vệ danh tính	62
5.6	Kiểm thử phân quyền và quyền tài liệu	62
5.6.1	Truy cập chức năng quản trị theo vai trò	62
5.6.2	Chia sẻ tài liệu và truy cập của người nhận	64
5.6.3	Từ chối truy cập khi không có quyền hoặc đã thu hồi quyền	64
5.7	Kiểm thử bảo mật ứng dụng web	67
5.8	Kiểm thử tệp tải lên	67
5.9	Kiểm thử cơ sở dữ liệu và lưu trữ	67
5.10	Kiểm thử triển khai AWS	68
5.10.1	Diễn tập cảnh báo và phục hồi trên AWS	69
5.11	Kiểm thử CI/CD	71
5.11.1	Kiểm tra thư viện phụ thuộc và mã nguồn Python	71
5.11.2	Phân tích các cảnh báo Bandit	74
5.11.3	Kiểm tra cấu hình hạ tầng và Docker image	76
5.12	Kiểm tra nội dung tài liệu sau khi khởi động lại container	76
5.13	Mô phỏng các kịch bản tấn công	78
5.13.1	Phạm vi và quy trình thực hiện	78
5.13.2	Tấn công đăng nhập và OTP	78
5.13.3	Vượt quyền và IDOR/BOLA	78
5.13.4	Tấn công vào ứng dụng web và tệp tải lên	79
5.13.5	Tấn công vào phiên và tài nguyên AWS	79
5.14	Tổng hợp kết quả	81
5.15	Đánh giá mô hình bảo vệ dữ liệu	81
5.15.1	Mức độ bảo vệ tính bí mật	81
5.15.2	Mức độ bảo vệ tính toàn vẹn	83
5.15.3	Mức độ bảo vệ tính sẵn sàng	83
5.15.4	Khả năng phát hiện và truy vết	84
5.16	Ưu điểm của mô hình	84
5.17	Hạn chế của mô hình	84
5.18	Rủi ro còn lại và thứ tự cải tiến	85
5.19	Kết luận chương	85
KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN		86
1.	Kết luận	86
2.	Hạn chế	86

3. Hướng phát triển	87
TÀI LIỆU THAM KHẢO	88
A Hướng dẫn cài đặt và kiểm chứng hệ thống	90
A.1 Cài đặt và chạy kiểm thử cục bộ	90
A.2 Kiểm chứng Docker và Terraform	90
A.2.1 Docker	90
A.2.2 Terraform	91
B Tổng hợp kiểm thử đã thực hiện	92
C Ma trận hiện thực và bằng chứng	93
D Quy trình phục hồi dữ liệu	95
D.1 Phục hồi SQLite vào tệp mới	95

DANH MỤC TỪ VIẾT TẮT, THUẬT NGỮ

STT	Từ viết tắt, thuật ngữ	Giải nghĩa
1	ABAC	Attribute-Based Access Control – Kiểm soát truy cập dựa trên thuộc tính
2	ALB	Application Load Balancer – Bộ cân bằng tải ứng dụng
3	API	Application Programming Interface – Giao diện lập trình ứng dụng
4	AWS	Amazon Web Services
5	CIA	Confidentiality, Integrity, Availability – Bí mật, toàn vẹn và sẵn sàng
6	CI/CD	Continuous Integration/Continuous Delivery – Tích hợp và triển khai liên tục
7	CSDL	Cơ sở dữ liệu
8	CSP	Content Security Policy – Chính sách bảo mật nội dung
9	CSRF	Cross-Site Request Forgery – Giả mạo yêu cầu liên trang
10	DAC	Discretionary Access Control – Kiểm soát truy cập tùy quyền
11	EC2	Amazon Elastic Compute Cloud
12	HTTP	Hypertext Transfer Protocol
13	HTTPS	Hypertext Transfer Protocol Secure
14	IAM	Identity and Access Management – Quản lý danh tính và truy cập
15	IaaS	Infrastructure as a Service – Hạ tầng dưới dạng dịch vụ
16	MFA	Multi-Factor Authentication – Xác thực đa yếu tố
17	MIME	Multipurpose Internet Mail Extensions
18	ORM	Object-Relational Mapping – Ánh xạ đối tượng quan hệ

STT	Từ viết tắt, thuật ngữ	Giải nghĩa
19	OTP	One-Time Password – Mật khẩu sử dụng một lần
20	PaaS	Platform as a Service – Nền tảng dưới dạng dịch vụ
21	RBAC	Role-Based Access Control – Kiểm soát truy cập dựa trên vai trò
22	RDS	Amazon Relational Database Service
23	RPO	Recovery Point Objective – Mục tiêu điểm phục hồi
24	RTO	Recovery Time Objective – Mục tiêu thời gian phục hồi
25	S3	Amazon Simple Storage Service
26	SaaS	Software as a Service – Phần mềm dưới dạng dịch vụ
27	SES	Amazon Simple Email Service
28	SHA-256	Secure Hash Algorithm 256-bit – Thuật toán băm an toàn 256 bit
29	SIEM	Security Information and Event Management
30	SQL	Structured Query Language
31	TLS	Transport Layer Security
32	VPC	Virtual Private Cloud
33	WAF	Web Application Firewall – Tường lửa ứng dụng web
34	XSS	Cross-Site Scripting – Chèn mã kịch bản liên trang

DANH MỤC BẢNG BIỂU

1.1	Đối chiếu hạ tầng truyền thống và Cloud trong phạm vi đề tài	7
1.2	So sánh IaaS, PaaS và SaaS	9
1.3	So sánh các mô hình triển khai được xem xét	11
1.4	Phân định trách nhiệm trong phương án CloudBox	12
2.1	Áp dụng STRIDE cho CloudBox	30
2.2	Ma trận ưu tiên rủi ro trước kiểm soát	30
3.1	Phạm vi và trạng thái hiện thực của mô hình	33
3.2	Chính sách quyền tài liệu của mô hình	37
3.3	Truy vết từ nguy cơ đến phương pháp xác minh	42
4.1	Một số phiên bản khóa trong mã nguồn	45
4.2	Phân chia trách nhiệm các thư mục	45
4.3	Các trường phục vụ bảo vệ dữ liệu	48
4.4	Tài nguyên AWS và bằng chứng nghiệm thu sau triển khai	56
5.1	Phạm vi môi trường thực nghiệm	60
5.2	Tổng hợp kịch bản mô phỏng tấn công	80
5.3	Kết quả bộ kiểm thử ứng dụng chạy lại trong tháng 09-2026	81
5.4	Tổng hợp kiểm chứng và giới hạn kết luận	83
5.5	Ưu tiên xử lý sau đánh giá	85
B.1	Tổng hợp các nhóm kiểm thử đã thực hiện	92
C.1	Trạng thái kiểm soát theo bằng chứng hiện có	93

DANH MỤC HÌNH VẼ, ĐỒ THỊ

2.1	Luồng dữ liệu logic của CloudBox	29
3.1	Các lớp của mô hình bảo vệ đề xuất	35
4.1	Kiến trúc CloudBox được khai báo và triển khai bằng Terraform trên AWS	46
4.2	Quan hệ dữ liệu chính của CloudBox (sơ đồ rút gọn)	48
4.3	Phiên bản Docker, Compose và trạng thái dịch vụ trên máy ảo Ubuntu	52
4.4	Giao diện đăng nhập CloudBox trong máy ảo Ubuntu VirtualBox . .	53
4.5	EC2 sau khắc phục: container ứng dụng healthy và endpoint cục bộ trả HTTP 200	54
4.6	Terraform validate thành công và danh sách tài nguyên đang được quản lý trong state	55
4.7	Kết quả refresh-only apply đồng bộ state mà không tạo, sửa hoặc xóa tài nguyên AWS	55
4.8	Chín kiểm tra tích hợp AWS đạt sau khi triển khai	56
4.9	CloudBox hoạt động qua địa chỉ Application Load Balancer	57
5.1	Kết quả smoke test endpoint HTTP local trên Ubuntu	60
5.2	Tài khoản admin truy cập thành công trang quản trị người dùng . . .	63
5.3	Tài khoản thường bị từ chối khi truy cập cùng đường dẫn quản trị . .	63
5.4	Chủ sở hữu kiểm tra tài khoản đang được cấp quyền nhận tài liệu . .	64
5.5	Người nhận tải xuống thành công tài liệu đã được chia sẻ	65
5.6	Tài khoản không được chia sẻ bị từ chối tại đường dẫn tải tài liệu . .	65
5.7	Người nhận bị từ chối khi truy cập lại đường dẫn tải trong kịch bản thu hồi quyền	66
5.8	Mười unit test của mô-đun kiểm tra tích hợp AWS đều đạt trên mã nguồn hiện tại	68
5.9	Lịch sử CloudWatch ghi nhận alarm EC2 chuyển từ OK sang ALARM trong phép thử	69
5.10	Email SNS nhận được khi kích hoạt thủ công alarm EC2 trên Cloud-Watch	69
5.11	Phục hồi object S3 bằng cách loại bỏ delete marker và đọc lại phiên bản trước	70

5.12 Snapshot RDS mã hóa và instance phục hồi độc lập đạt trạng thái available	71
5.13 Tổng quan lần chạy CI số 5 thành công trên GitHub Actions	72
5.14 Kết quả pip-audit trên GitHub Actions: không phát hiện lỗ hổng đã biết	72
5.15 Kết quả Bandit: không có High, còn ba Low và hai Medium	73
5.16 Bảng kết quả Trivy đối với Dockerfile và cấu hình Terraform	76
5.17 Kết quả Trivy quét lỗ hổng Docker image theo ngưỡng của CI	77
5.18 Hai dịch vụ healthy sau khởi động lại và SHA-256 hai bản tài liệu trùng nhau	78
5.19 Kiểm thử tự động các tình huống bảo mật ứng dụng và lưu trữ trên Ubuntu	80
5.20 Chi tiết các kiểm thử quản trị, RBAC và API trong bộ ứng dụng trên Ubuntu	82
5.21 Kết quả 78 bài kiểm thử ứng dụng và 10 bài kiểm thử mô-đun bảo mật đều đạt trên Ubuntu	82

MỞ ĐẦU

Tóm tắt đề tài

Đề tài nghiên cứu các nguy cơ an toàn thông tin đối với hệ thống lưu trữ và chia sẻ tài liệu trên môi trường điện toán đám mây, sau đó xây dựng mô hình bảo vệ dữ liệu nhiều lớp và hiện thực bằng ứng dụng CloudBox. Phương pháp nghiên cứu kết hợp tổng hợp tài liệu, mô hình hóa mối đe dọa theo STRIDE, đánh giá rủi ro, rà soát mã nguồn và kiểm thử thực nghiệm. Mô hình phối hợp bảo vệ danh tính, RBAC, quyền sở hữu và chia sẻ ở cấp tài liệu, kiểm tra tệp tải lên, bảo vệ phiên, ghi log, lưu trữ S3/RDS và kiểm soát hạ tầng bằng Terraform.

CloudBox được xây dựng bằng Flask và SQLAlchemy, đóng gói bằng Docker, kiểm thử trên máy ảo Ubuntu và triển khai hạ tầng thử nghiệm trên AWS bằng Terraform. Hạ tầng gồm ALB, EC2, RDS MySQL, S3, IAM, Secrets Manager, CloudWatch và VPC Flow Logs. Bộ kiểm thử tự động gồm 78 kiểm thử ứng dụng và 10 kiểm thử mô-đun bảo mật. Báo cáo đồng thời mô phỏng các yêu cầu tấn công có kiểm soát như vét cạn mật khẩu, vượt quyền, IDOR, CSRF, tệp tải lên giả mạo và truy cập trái phép tài nguyên AWS. Kết quả cho thấy các kiểm soát cốt lõi hoạt động trong phạm vi thử nghiệm, nhưng hệ thống vẫn còn hạn chế về quét mã độc, bộ đếm yêu cầu dùng chung, tài khoản cơ sở dữ liệu chỉ có quyền cần thiết và phục hồi đồng bộ RDS-S3.

Từ khóa: điện toán đám mây, an toàn thông tin, bảo vệ dữ liệu, Flask, Docker, Terraform, AWS, kiểm soát truy cập.

1. Lý do chọn đề tài

Điện toán đám mây cho phép tổ chức sử dụng tài nguyên tính toán, lưu trữ và phần mềm theo nhu cầu. Đối với các ứng dụng quản lý tài liệu, môi trường này hỗ trợ người dùng làm việc từ nhiều vị trí, chia sẻ nội dung thuận tiện và giảm nhu cầu đầu tư hạ tầng ban đầu. Tuy nhiên, giá trị của tài liệu cũng làm cho hệ thống lưu trữ trở thành đối tượng cần được bảo vệ ở cả tầng ứng dụng và hạ tầng.

Dữ liệu có thể bị lộ khi tài khoản bị chiếm đoạt, chức năng tải xuống thiếu kiểm tra quyền hoặc kho lưu trữ bị mở công khai. Mã hóa không khắc phục được lỗi phân quyền nếu chính ứng dụng trả tệp cho người không được phép. Việc sao lưu cũng cần bảo đảm thông tin trong cơ sở dữ liệu khớp với tệp đã lưu thì mới có thể khôi phục đầy đủ. Vì vậy, các biện pháp bảo vệ phải được áp dụng từ lúc tài liệu được tải lên cho đến khi chia sẻ, xóa hoặc khôi phục.

Nhóm lựa chọn xây dựng CloudBox, một ứng dụng lưu trữ và chia sẻ tài liệu, để

tìm hiểu các vấn đề trên qua một hệ thống cụ thể. Các chức năng của ứng dụng cho phép nhóm phân tích cách xác thực người dùng, kiểm tra quyền sở hữu, chia sẻ tài liệu và kiểm tra tệp tải lên. Qua việc triển khai trên AWS, nhóm cũng xem xét trách nhiệm bảo mật của khách hàng khi sử dụng dịch vụ đám mây. Mỗi nguy cơ được đối chiếu với biện pháp xử lý trong mã nguồn và kết quả kiểm thử tương ứng.

2. Mục tiêu nghiên cứu

2.1. Mục tiêu tổng quát

Nghiên cứu các nguy cơ an toàn thông tin trên môi trường Cloud và xây dựng mô hình bảo vệ dữ liệu nhiều lớp phù hợp với hệ thống lưu trữ tài liệu. Mô hình được hiện thực bằng ứng dụng CloudBox để đánh giá khả năng kiểm soát truy cập và bảo vệ dữ liệu trong phạm vi thử nghiệm.

2.2. Mục tiêu cụ thể

Đề tài hệ thống hóa nền tảng điện toán đám mây; nhận diện tài sản, ranh giới tin cậy và các nhóm nguy cơ; xây dựng ma trận ưu tiên xử lý rủi ro; thiết kế lớp bảo vệ danh tính, ứng dụng, lưu trữ và hạ tầng. Phần hiện thực tập trung vào Flask, SQLAlchemy, xác thực bằng mật khẩu, OTP khôi phục, RBAC và quyền cấp tài liệu. Docker được sử dụng để triển khai ứng dụng cùng MySQL trên máy ảo Ubuntu; Terraform được sử dụng để khởi tạo hạ tầng thử nghiệm trên AWS. Kiểm thử tự động và các kịch bản mô phỏng tấn công được dùng để đối chiếu hành vi thực tế với mục tiêu bảo vệ.

3. Đối tượng nghiên cứu

Đối tượng nghiên cứu gồm dữ liệu và các cơ chế bảo vệ trong hệ thống CloudBox: tài khoản, thông tin xác thực, tài liệu, quan hệ chia sẻ, nhật ký và cấu hình hạ tầng. Các thành phần AWS được xem xét gồm EC2, S3, RDS, IAM, ALB, SES, Secrets Manager và CloudWatch. Trọng tâm là sự phối hợp giữa kiểm soát ở tầng ứng dụng với cấu hình của các dịch vụ này.

4. Phạm vi nghiên cứu

Phạm vi thực nghiệm gồm ba môi trường. Môi trường kiểm thử tự động sử dụng SQLite và thư mục tạm; môi trường máy ảo Ubuntu sử dụng Docker Compose, Unicorn và MySQL; môi trường Cloud sử dụng hạ tầng AWS được tạo bằng Terraform. Các mock AWS trong unit test chỉ kiểm tra logic của chương trình, còn kết quả triển khai AWS được trình bày tách biệt bằng trạng thái tài nguyên, kiểm tra chỉ đọc và smoke test tại endpoint của hệ thống.

Nội dung tập trung vào an toàn ứng dụng lưu trữ và chia sẻ tài liệu, không thực hiện khai thác hệ thống của bên thứ ba. Các kịch bản tấn công chỉ dùng tài khoản, dữ liệu và hạ tầng thử nghiệm do nhóm quản lý. Hiệu năng tải lớn, đánh giá xâm nhập độc lập và chứng nhận tuân thủ nằm ngoài phạm vi. HTTPS, SES, AWS Backup và kiểm thử khôi phục chỉ được ghi nhận là đã bật nếu hồ sơ triển khai có bằng chứng tương ứng; WAF, Redis, bộ quét mã độc, SIEM, Auto Scaling và S3 CRR vẫn thuộc hướng phát triển.

5. Phương pháp nghiên cứu

Phương pháp nghiên cứu kết hợp tổng hợp tài liệu, phân tích kiến trúc, mô hình hóa mối đe dọa và rà soát mã nguồn. Rủi ro được xếp hạng theo thang điểm định tính có quy ước rõ ràng. Thiết kế được chuyển thành các yêu cầu kiểm soát, sau đó đối chiếu với route, service, model và cấu hình hạ tầng.

Thực nghiệm sử dụng bộ kiểm thử có sẵn trong dự án, chạy lại trong môi trường độc lập và ghi nhận kết quả trong tháng 09-2026. Mỗi kết luận được gắn với loại bằng chứng tương ứng: đọc mã, thực thi kiểm thử trên Ubuntu, chạy Docker/MySQL, kiểm tra tài nguyên AWS hoặc mô phỏng dịch vụ ngoài. Cách tiếp cận này giúp tránh suy rộng kết quả của một phép kiểm tra thành mức bảo đảm cho toàn bộ hệ thống.

6. Kết quả đạt được và giới hạn bằng chứng

Báo cáo xây dựng danh sách nguy cơ, ma trận rủi ro, mô hình bảo vệ và ma trận truy vết đến kiểm thử. Kết quả thực thi ghi nhận 78 bài kiểm thử ứng dụng và 10 bài kiểm thử mô-đun bảo mật đều thành công. Nhóm đã triển khai hạ tầng thử nghiệm AWS bằng Terraform và tổ chức bằng chứng riêng cho Docker/Ubuntu, Terraform và trạng thái tài nguyên Cloud. Đây là kết quả trong phạm vi môi trường thử nghiệm, không phải tỷ lệ bao phủ mã nguồn hoặc bằng chứng hệ thống không còn lỗ hổng. Những tồn tại đáng chú ý gồm quét mã độc, thu hồi phiên, quản lý tài khoản cơ sở dữ liệu và kiểm soát đồng thời.

7. Cấu trúc báo cáo

Chương 1 trình bày cơ sở lý thuyết về điện toán đám mây và an toàn thông tin. Chương 2 phân tích tài sản, nguy cơ và mức ưu tiên xử lý. Chương 3 đề xuất mô hình bảo vệ dữ liệu và các luồng xử lý. Chương 4 mô tả hiện thực CloudBox dựa trên mã nguồn. Chương 5 trình bày kiểm thử, đánh giá mức đáp ứng và rủi ro còn lại. Phần kết luận tổng hợp đóng góp và hướng phát triển; tài liệu tham khảo được tập hợp ở cuối báo cáo, trước phụ lục.

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT VỀ ĐIỆN TOÁN Đám MÂY VÀ AN TOÀN THÔNG TIN

Điện toán đám mây làm thay đổi cách tổ chức triển khai, vận hành và khai thác tài nguyên công nghệ thông tin. Thay vì phải sở hữu toàn bộ máy chủ và thiết bị lưu trữ, tổ chức có thể sử dụng các dịch vụ được cung cấp qua mạng và điều chỉnh tài nguyên theo nhu cầu. Sự thay đổi này tạo thuận lợi cho việc phát triển ứng dụng, nhưng đồng thời đặt ra yêu cầu bảo vệ dữ liệu trong một môi trường có nhiều thành phần và nhiều chủ thể cùng tham gia quản lý.

Chương này trình bày nền tảng về điện toán đám mây, các mô hình dịch vụ, mô hình triển khai và trách nhiệm bảo mật của các bên. Trên cơ sở đó, chương làm rõ những khái niệm và cơ chế an toàn thông tin cần thiết cho hệ thống lưu trữ, chia sẻ tài liệu CloudBox. Những liên hệ với CloudBox trong chương được sử dụng làm cơ sở thiết kế; mức độ hiện thực và hiệu quả thực tế cần được chứng minh trong các chương xây dựng hệ thống và kiểm thử.

1.1. Tổng quan về điện toán đám mây

1.1.1. Khái niệm điện toán đám mây

Theo NIST SP 800-145, điện toán đám mây là mô hình cho phép truy cập qua mạng một cách thuận tiện, theo nhu cầu, đến tập hợp tài nguyên điện toán có thể cấu hình và được dùng chung. Các tài nguyên này có thể được cấp phát hoặc thu hồi nhanh với ít thao tác quản trị hay tương tác trực tiếp với nhà cung cấp. Tài nguyên có thể là năng lực xử lý, mạng, lưu trữ, ứng dụng và các dịch vụ liên quan. [1]

Về quá trình phát triển, Cloud kế thừa các ý tưởng chia sẻ năng lực tính toán, điện toán phân tán và cung cấp tài nguyên như một tiện ích. Công nghệ ảo hóa giúp nhiều máy ảo cùng khai thác một máy chủ vật lý, trong khi sự phát triển của kết nối mạng, giao diện lập trình ứng dụng và công cụ điều phối làm cho việc cấp phát tài nguyên từ xa trở nên thuận tiện hơn. Khi những khả năng này được kết hợp với đo lường mức sử dụng và tự phục vụ, tài nguyên có thể được cung cấp dưới dạng dịch vụ thay vì chỉ là thiết bị do một tổ chức tự sở hữu.

Trong mô hình hạ tầng truyền thống, tổ chức thường phải dự báo nhu cầu, mua thiết bị, bố trí không gian, cài đặt phần mềm và duy trì đội ngũ vận hành. Với Cloud, nhiều công việc hạ tầng được chuyển cho nhà cung cấp, còn khách hàng lựa chọn và cấu hình dịch vụ theo yêu cầu. Tuy nhiên, một hệ thống đặt tại chỗ vẫn có thể là Private Cloud nếu đáp ứng các đặc trưng của Cloud. Do đó, vị trí đặt máy chủ không phải tiêu chí duy nhất để phân biệt hai cách tổ chức hạ tầng.

Đối với lưu trữ và xử lý dữ liệu, Cloud cho phép tách năng lực tính toán khỏi nơi lưu dữ liệu, đồng thời cung cấp nhiều hình thức lưu trữ như lưu trữ khối, lưu trữ tệp và lưu trữ đối tượng. Trong định hướng CloudBox, nội dung tài liệu có thể được lưu dưới dạng đối tượng, còn thông tin chủ sở hữu, kích thước và quyền chia sẻ được quản lý trong cơ sở dữ liệu. Việc tách này giúp lựa chọn công cụ phù hợp cho từng loại dữ liệu, nhưng cũng đòi hỏi xử lý nhất quán giữa tệp và bản ghi mô tả.

1.1.2. Đặc điểm của điện toán đám mây

NIST xác định năm đặc trưng cốt lõi của Cloud. Tự động hóa là cơ chế quan trọng hỗ trợ các đặc trưng đó, không phải đặc trưng thứ sáu trong định nghĩa NIST. [1]

Tự phục vụ theo nhu cầu: Người sử dụng có thể yêu cầu tài nguyên thông qua giao diện quản trị hoặc API mà không cần nhà cung cấp xử lý thủ công từng yêu cầu. Chẳng hạn, nhóm phát triển có thể tạo một môi trường thử nghiệm khi cần và thu hồi sau khi hoàn thành. Quyền tự phục vụ vẫn phải chịu sự kiểm soát của chính sách truy cập và hạn mức tài nguyên.

Truy cập rộng qua mạng: Dịch vụ được cung cấp bằng các cơ chế mạng tiêu chuẩn để nhiều loại thiết bị có thể sử dụng. Khả năng này thuận lợi cho làm việc từ xa, nhưng không đồng nghĩa mọi tài nguyên phải công khai trên Internet. Cơ sở dữ liệu và dịch vụ nội bộ vẫn có thể chỉ được truy cập qua mạng riêng.

Gộp và chia sẻ tài nguyên: Nhà cung cấp tập hợp tài nguyên để phục vụ nhiều khách hàng, rồi phân bổ theo nhu cầu. Sự chia sẻ có thể diễn ra ở mức phần cứng, nền tảng hoặc ứng dụng. Điều kiện quan trọng là phải duy trì sự cách ly phù hợp giữa các khách hàng để việc dùng chung tài nguyên không trở thành quyền truy cập dữ liệu của nhau.

Co giãn nhanh: Năng lực phục vụ có thể tăng khi tải cao và giảm khi nhu cầu giảm. Co giãn khác với việc chỉ mua thêm tài nguyên theo kế hoạch dài hạn: nó chú trọng điều chỉnh gần với nhu cầu thực tế. Tuy nhiên, ứng dụng phải có kiến trúc phù hợp; việc tăng số máy chủ không tự giải quyết các điểm nghẽn ở cơ sở dữ liệu hoặc trạng thái phiên.

Đo lường dịch vụ: Việc sử dụng tài nguyên được theo dõi qua các đại lượng như thời gian xử lý, dung lượng và lưu lượng truyền. Đo lường hỗ trợ tính phí, giám sát và tối ưu vận hành. Người quản trị cần hiểu từng loại chi phí thay vì chỉ quan tâm giá của máy chủ.

Tự động hóa cấp phát: Công cụ điều phối và Infrastructure as Code giúp tạo môi trường từ mô tả cấu hình có thể lưu phiên bản. Với CloudBox, Terraform là phương án mô tả hạ tầng nhất quán. Dù vậy, tự động hóa cũng có thể lặp lại một cấu hình sai trên nhiều tài nguyên, vì vậy mã hạ tầng cần được rà soát như mã ứng dụng.

1.1.3. Ưu điểm của điện toán đám mây

Giảm chi phí đầu tư ban đầu: Tổ chức có thể bắt đầu với tài nguyên vừa đủ mà không cần mua trước toàn bộ thiết bị. Điều này phù hợp với đồ án và ứng dụng mới có lượng người dùng chưa ổn định. Lợi ích nằm ở khả năng điều chỉnh mức đầu tư; tổng chi phí sử dụng lâu dài vẫn phụ thuộc vào tải, kiến trúc và cách quản trị.

Rút ngắn thời gian triển khai: Môi trường có thể được tạo từ cấu hình hoặc mẫu có sẵn, giúp nhóm phát triển tập trung vào chức năng. Khả năng tạo lại môi trường cũng hỗ trợ kiểm thử, đào tạo và khôi phục sau lỗi cấu hình.

Mở rộng linh hoạt: Khi nhu cầu tăng, ứng dụng có thể được nâng cấu hình hoặc phân phối tải cho nhiều thành phần. Khả năng mở rộng chỉ phát huy hiệu quả nếu các thành phần hỗ trợ chạy song song và không phụ thuộc vào trạng thái cục bộ không được chia sẻ.

Hỗ trợ sao lưu và phục hồi: Các dịch vụ quản lý cung cấp những cơ chế giúp giảm công việc xây dựng hạ tầng dự phòng. Tuy nhiên, nhóm vận hành vẫn phải chọn lịch sao lưu, thời gian giữ bản sao và kiểm tra khả năng phục hồi. Có dịch vụ sao lưu không đồng nghĩa dữ liệu đã được bảo vệ đúng yêu cầu.

Truy cập từ nhiều vị trí: Người dùng có thể khai thác tài liệu từ nhiều thiết bị nếu có kết nối và được cấp quyền. Trong CloudBox, đặc điểm này hỗ trợ chia sẻ tài liệu giữa các thành viên, đồng thời làm cho xác thực và kiểm soát quyền trên từng tệp trở thành yêu cầu thiết yếu.

Sử dụng dịch vụ được quản lý: Dịch vụ cơ sở dữ liệu, lưu trữ, giám sát và quản lý bí mật giúp giảm khối lượng vận hành thủ công. Nhóm phát triển có thể ưu tiên logic nghiệp vụ, nhưng vẫn phải hiểu cấu hình, giới hạn và trách nhiệm của mình đối với từng dịch vụ.

1.1.4. Hạn chế của điện toán đám mây

Phụ thuộc vào nhà cung cấp: Việc sử dụng API hoặc dịch vụ chuyên biệt có thể khiến chuyển đổi sang nền tảng khác tốn công sức. Đối với CloudBox, lớp giao tiếp lưu trữ nên tách khỏi xử lý nghiệp vụ để giảm sự phụ thuộc giữa chức năng tài liệu và một dịch vụ cụ thể.

Khó dự báo chi phí nếu thiếu giám sát: Tài nguyên không được thu hồi, số lượng bản sao lớn hoặc lưu lượng tải xuống tăng có thể làm chi phí vượt dự kiến. Cần đặt ngân sách, theo dõi mức sử dụng và xác định người chịu trách nhiệm với tài nguyên được tạo.

Rủi ro cấu hình sai: Quyền truy cập quá rộng hoặc dịch vụ nội bộ bị mở ra ngoài có thể làm mất tác dụng của các biện pháp bảo vệ khác. Việc chia sẻ hạ tầng và sử dụng công nghệ ảo hóa đòi hỏi cơ chế cách ly, giám sát và quản lý đặc quyền phù

hợp. [2]

Phụ thuộc kết nối và dịch vụ trung gian: Mất đường truyền hoặc sự cố một thành phần có thể khiến người dùng không truy cập được ứng dụng dù dữ liệu còn nguyên vẹn. Vì vậy, thiết kế phải tính đến lỗi kết nối, thời gian chờ và khả năng phục hồi hoạt động.

Quyền riêng tư và tuân thủ: Tổ chức cần xác định dữ liệu nào được thu thập, ai được phép xử lý, thời gian lưu giữ và điều kiện chia sẻ. Việc lựa chọn khu vực lưu dữ liệu và nhà cung cấp cần phù hợp với yêu cầu áp dụng cho tổ chức. Chứng nhận của nhà cung cấp không tự động chứng minh toàn bộ ứng dụng của khách hàng đáp ứng các yêu cầu đó.

Bảng 1.1: Đối chiếu hạ tầng truyền thống và Cloud trong phạm vi đề tài

Tiêu chí	Hạ tầng truyền thống	Cloud
Cấp phát	Thường gắn với mua sắm và cài đặt thiết bị	Có thể cấp phát qua API và cấu hình
Chi phí	Đầu tư thiết bị và duy trì vận hành	Kết hợp phí tài nguyên, dịch vụ và vận hành
Mở rộng	Bị giới hạn bởi thiết bị sẵn có	Có thể điều chỉnh trong giới hạn dịch vụ
Trách nhiệm	Tổ chức quản lý phần lớn hệ thống	Phân chia theo dịch vụ được lựa chọn
Bảo vệ dữ liệu	Do tổ chức thiết kế và kiểm chứng	Vẫn cần khách hàng thiết kế và kiểm chứng

1.2. Các mô hình dịch vụ Cloud

Các mô hình IaaS, PaaS và SaaS thể hiện mức độ dịch vụ mà khách hàng sử dụng và ranh giới quản lý giữa khách hàng với nhà cung cấp. On-premises mô tả cách đặt và vận hành hệ thống tại chỗ, không phải mô hình dịch vụ thứ tư cùng cấp với ba mô hình trên. Cách phân loại này dựa trên định nghĩa của NIST. [1]

1.2.1. Infrastructure as a Service

Infrastructure as a Service (IaaS) cung cấp các tài nguyên hạ tầng như năng lực xử lý, lưu trữ và kết nối mạng. Khách hàng có thể triển khai hệ điều hành và phần mềm của mình trên tài nguyên được cấp. Quyền kiểm soát này nằm ở tài nguyên được thuê, không bao gồm toàn quyền quản lý phần cứng và nền tảng vật lý của nhà cung cấp.

Trong cách phân chia điển hình, nhà cung cấp vận hành trung tâm dữ liệu, thiết bị và lớp hạ tầng ảo hóa. Khách hàng quản lý hệ điều hành khách, phần mềm đã cài, dữ liệu và các cấu hình truy cập thuộc phạm vi của mình. Vì vậy, một máy ảo được tạo thành công chưa có nghĩa máy ảo đó đã được cấu hình an toàn.

Ưu điểm của IaaS là khả năng tùy chỉnh môi trường và hỗ trợ ứng dụng cần nhiều quyền kiểm soát hệ điều hành. Hạn chế là khách hàng phải dành nguồn lực cho cập nhật, giám sát và xử lý sự cố. Amazon EC2 là ví dụ IaaS trong kiến trúc đề xuất của CloudBox. Nếu ứng dụng Flask và Docker chạy trên EC2, nhóm triển khai vẫn phải bảo vệ hệ điều hành và các thành phần do mình cài đặt. [3]

1.2.2. Platform as a Service

Platform as a Service (PaaS) cung cấp nền tảng để phát triển và chạy ứng dụng. Khách hàng chủ yếu đưa mã nguồn hoặc gói ứng dụng lên môi trường được hỗ trợ, còn nền tảng đảm nhiệm nhiều công việc liên quan đến hệ điều hành, môi trường thực thi và cấp phát tài nguyên bên dưới.

Một dịch vụ triển khai ứng dụng web quản lý sẵn runtime, chẳng hạn mô hình của Google App Engine, là ví dụ thường dùng để giải thích PaaS. Điểm cốt lõi không nằm ở tên thương mại mà ở việc khách hàng kiểm soát ứng dụng và cấu hình của mình, trong khi không trực tiếp quản trị toàn bộ hệ thống nền. Các dịch vụ cụ thể có thể cho phép mức tùy chỉnh khác nhau.

PaaS giúp giảm công sức vận hành và rút ngắn thời gian đưa ứng dụng vào sử dụng. Đổi lại, ứng dụng phải phù hợp với ngôn ngữ, runtime, hạn mức và cơ chế triển khai của nền tảng. Lỗi xác thực, phân quyền hoặc xử lý dữ liệu trong mã nguồn vẫn là trách nhiệm của nhóm phát triển, ngay cả khi máy chủ đã được nhà cung cấp quản lý.

1.2.3. Software as a Service

Software as a Service (SaaS) cung cấp ứng dụng hoàn chỉnh để người dùng sử dụng qua mạng. Khách hàng không trực tiếp quản lý hệ điều hành hoặc hạ tầng chạy phần mềm mà chủ yếu cấu hình tài khoản, dữ liệu và các tùy chọn nghiệp vụ được cho phép.

Các dịch vụ thư điện tử và cộng tác trực tuyến, như ứng dụng Gmail trong Google Workspace, minh họa cách sử dụng này. Người dùng tương tác với chức năng có sẵn thay vì triển khai mã nguồn của mình. Thuận lợi là giảm công việc cài đặt và bảo trì; hạn chế là mức tùy biến bị giới hạn, đồng thời khả năng xuất dữ liệu và tích hợp phụ thuộc dịch vụ.

Dù nhà cung cấp quản lý ứng dụng, khách hàng vẫn phải bảo vệ tài khoản, cấp quyền phù hợp và kiểm soát nội dung chia sẻ. Một tài liệu bị chia sẻ nhầm có thể gây rò rỉ dù nền tảng hoạt động đúng. Ngoài ra, SaaS không đồng nghĩa với serverless: serverless mô tả cách cung cấp và vận hành tài nguyên thực thi, trong khi SaaS mô tả việc cung cấp phần mềm hoàn chỉnh cho người dùng.

1.2.4. So sánh các mô hình dịch vụ

Bảng dưới tổng hợp sự khác nhau ở mức khái quát. Trong thực tế, cần đọc ranh giới trách nhiệm của từng dịch vụ vì một sản phẩm có thể kết hợp đặc điểm của nhiều nhóm.

Bảng 1.2: So sánh IaaS, PaaS và SaaS

Tiêu chí	IaaS	PaaS	SaaS
Đối tượng sử dụng	Người quản trị và đội phát triển	Đội phát triển ứng dụng	Người dùng nghiệp vụ
Kiểm soát chính	Hệ điều hành khách và ứng dụng	Mã ứng dụng và cấu hình	Tài khoản, dữ liệu và tùy chọn
Công việc quản trị	Nhiều thành phần do khách hàng quản lý	Giảm quản trị nền tảng	Chủ yếu quản trị sử dụng
Tùy chỉnh	Rộng, trong giới hạn tài nguyên thuê	Theo khả năng nền tảng	Theo chức năng sản phẩm
Bảo mật phía khách hàng	Hệ điều hành, ứng dụng, danh tính, dữ liệu	Ứng dụng, danh tính, dữ liệu	Danh tính, chia sẻ, dữ liệu
Chi phí cần xét	Tài nguyên và nhân lực vận hành	Dịch vụ nền tảng và ứng dụng	Thuê bao và các giới hạn sử dụng

Không thể kết luận mô hình nào luôn rẻ hơn hoặc an toàn hơn. Quyết định cần căn cứ vào yêu cầu tùy chỉnh, năng lực nhân sự và mức độ kiểm soát mong muốn. CloudBox sử dụng phương án EC2 để minh họa trách nhiệm vận hành ứng dụng; S3 và RDS bổ sung các khả năng lưu trữ được quản lý. Việc kết hợp dịch vụ không làm mất đi trách nhiệm bảo vệ dữ liệu ở tầng ứng dụng.

1.3. Các mô hình triển khai Cloud

Mô hình triển khai thể hiện phạm vi sử dụng và cách tổ chức môi trường đám mây. NIST phân biệt Public, Private, Community và Hybrid Cloud. Trong phạm vi đề tài, ba mô hình Public, Private và Hybrid được phân tích; Community Cloud là môi trường dùng chung cho một cộng đồng có yêu cầu tương đồng và không được triển khai trong CloudBox. [1]

1.3.1. Public Cloud

Public Cloud là môi trường đám mây được cung cấp cho tập khách hàng rộng, trong đó hạ tầng thường do nhà cung cấp dịch vụ vận hành. Các khách hàng có thể cùng sử dụng nền tảng vật lý nhưng phải được cách ly về truy cập và dữ liệu. Từ “public” mô tả cách cung cấp dịch vụ, không có nghĩa dữ liệu của khách hàng mặc nhiên được công khai.

Ưu điểm là dễ bắt đầu, có nhiều dịch vụ và có thể điều chỉnh tài nguyên mà

không phải xây dựng trung tâm dữ liệu riêng. Hạn chế là phụ thuộc vào giới hạn, chính sách và cơ chế vận hành của nhà cung cấp. Khách hàng phải kiểm soát cấu hình tài nguyên, đặc biệt những điểm kết nối với Internet. Phương án AWS của CloudBox thuộc hướng Public Cloud, nhưng bucket chứa tài liệu và cơ sở dữ liệu vẫn được thiết kế để hạn chế truy cập.

1.3.2. Private Cloud

Private Cloud được dành riêng cho một tổ chức, có thể phục vụ nhiều đơn vị bên trong tổ chức đó. Môi trường này có thể do tổ chức hoặc bên thứ ba vận hành và không nhất thiết phải đặt trong trụ sở. Điều kiện để gọi là Cloud vẫn là những khả năng như tự phục vụ, gộp tài nguyên và đo lường dịch vụ.

Mô hình này cho phép chủ động hơn về chính sách và cách tích hợp với hệ thống nội bộ. Đổi lại, tổ chức cần nguồn lực để xây dựng, duy trì và mở rộng môi trường. Private Cloud không tự động an toàn hơn Public Cloud: nếu hệ thống thiếu cập nhật, phân quyền không phù hợp hoặc không có quy trình khôi phục, dữ liệu vẫn có thể bị ảnh hưởng nghiêm trọng.

1.3.3. Hybrid Cloud

Hybrid Cloud kết hợp các môi trường Cloud riêng biệt có cơ chế liên kết cho phép trao đổi dữ liệu hoặc phối hợp xử lý. Theo hướng tiếp cận này, tổ chức có thể giữ một phần tải trong môi trường riêng và sử dụng môi trường công cộng cho phần có nhu cầu linh hoạt hơn.

Lợi ích là tận dụng khả năng của từng môi trường và hỗ trợ quá trình chuyển đổi từng bước. Hạn chế là tăng độ phức tạp trong đồng bộ dữ liệu, quản lý danh tính và giám sát. Sự nhất quán của chính sách truy cập cần được duy trì ở cả hai phía. Việc CloudBox có một bản chạy local và một bản dự kiến trên AWS chưa đủ để kết luận hệ thống là Hybrid Cloud; cần có kiến trúc liên kết và cơ chế vận hành phối hợp cụ thể.

1.3.4. So sánh các mô hình triển khai

Lựa chọn mô hình cần xuất phát từ đặc điểm dữ liệu và yêu cầu vận hành. Với phạm vi đề án, Public Cloud giúp minh họa các dịch vụ lưu trữ và danh tính mà không cần xây dựng toàn bộ hạ tầng. Môi trường local hỗ trợ phát triển và kiểm thử chức năng, còn đánh giá cấu hình Cloud cần được thực hiện riêng trên môi trường tương ứng.

Bảng 1.3: So sánh các mô hình triển khai được xem xét

Tiêu chí	Public	Private	Hybrid
Chi phí ban đầu	Thường thấp hơn khi thuê tài nguyên	Có thể cao nếu tự xây dựng	Phụ thuộc các môi trường kết hợp
Kiểm soát	Trong phạm vi dịch vụ	Chủ động theo phạm vi tổ chức	Chia theo từng thành phần
Mở rộng	Theo năng lực và hạn mức nhà cung cấp	Theo tài nguyên riêng đã đầu tư	Cần điều phối giữa môi trường
Bảo mật	Chia sẻ trách nhiệm	Phụ thuộc năng lực quản trị	Cần chính sách nhất quán
Phù hợp	Ứng dụng cần triển khai nhanh	Nhu cầu quản trị chuyên biệt	Tích hợp và chuyển đổi từng bước

1.4. Mô hình trách nhiệm chia sẻ

1.4.1. Trách nhiệm của nhà cung cấp Cloud

Trong mô hình trách nhiệm chia sẻ, nhà cung cấp bảo vệ phần hạ tầng thuộc quyền vận hành của mình. Với AWS, phạm vi này bao gồm trung tâm dữ liệu, thiết bị, mạng và các thành phần nền tảng cung cấp dịch vụ. Khái niệm này thường được gọi là bảo mật *của* đám mây. [3]

Việc xác định trách nhiệm cần dựa vào đúng dịch vụ đang dùng. Một dịch vụ quản lý cơ sở dữ liệu có ranh giới khác với máy ảo để khách hàng tự cài cơ sở dữ liệu. Vì vậy, người thiết kế phải xem xét thành phần nào được nhà cung cấp vận hành, thành phần nào cần khách hàng cấu hình và đâu là bằng chứng để xác nhận cấu hình đó.

1.4.2. Trách nhiệm của khách hàng

Khách hàng chịu trách nhiệm về cách sử dụng dịch vụ, bao gồm dữ liệu, danh tính, quyền truy cập và cấu hình trong phạm vi được giao. Đối với máy ảo IaaS, khách hàng còn quản lý hệ điều hành khách và phần mềm đã triển khai. Trách nhiệm này thường được gọi là bảo mật *trong* đám mây. [3]

Đối với đề tài, trách nhiệm phải được chuyển thành công việc rõ ràng: xác định chủ sở hữu dữ liệu, quản lý tài khoản, phê duyệt thay đổi quyền và kiểm thử chức năng phục hồi. Nếu chỉ nêu rằng nhà cung cấp có khả năng bảo mật tốt mà không kiểm chứng cấu hình ứng dụng, báo cáo sẽ bỏ sót nguyên nhân rõ ràng xuất phát từ chính cách triển khai.

1.4.3. Áp dụng mô hình trách nhiệm chia sẻ vào đề tài

Trong CloudBox, trách nhiệm được phân tích theo từng thành phần để tránh khoảng trống kiểm soát. Bảng dưới là phân công thiết kế đề xuất, không phải xác

nhận rằng các cấu hình đã được triển khai thực tế.

Bảng 1.4: Phân định trách nhiệm trong phương án CloudBox

Thành phần	Phạm vi nhà cung cấp	Công việc của nhóm CloudBox
EC2	Hạ tầng vật lý và nền tảng máy ảo	Bảo vệ hệ điều hành khách, Docker, ứng dụng và kết nối
S3	Nền tảng dịch vụ lưu trữ đối tượng	Chính sách truy cập, lựa chọn mã hóa, quản lý vòng đời tài liệu
RDS	Hạ tầng và các tác vụ quản lý của dịch vụ	Quyền cơ sở dữ liệu, kết nối, cấu hình bảo vệ và phục hồi
IAM	Vận hành dịch vụ danh tính AWS	Thiết kế vai trò, policy và vòng đời thông tin xác thực
CloudBox	Cung cấp tài nguyên nền bên dưới	Mã nguồn, người dùng, quyền trên tài liệu và nhật ký nghiệp vụ

Với S3, nhóm cần kiểm soát bucket policy và ngăn công khai tài liệu ngoài ý muốn. Việc một object được mã hóa không thay thế cho kiểm tra quyền đọc object đó. Trong phương án đề xuất, ứng dụng chỉ yêu cầu những thao tác lưu trữ cần thiết và không cấp quyền quản trị bucket cho người dùng cuối. [4]

Với RDS, cần phân biệt quyền quản lý tài nguyên AWS với quyền đăng nhập và thao tác dữ liệu trong hệ quản trị cơ sở dữ liệu. Thiết kế cần giới hạn nguồn kết nối và sử dụng kết nối được mã hóa. Tài khoản dùng bởi ứng dụng không nên đồng thời là tài khoản quản trị toàn bộ cơ sở dữ liệu. [5]

Quyền IAM của tiến trình ứng dụng và quyền của người dùng CloudBox cũng là hai lớp khác nhau. Một tiến trình có quyền đọc S3 vẫn phải kiểm tra người dùng đang yêu cầu có được tải tài liệu cụ thể hay không. Đây là điểm kết nối giữa bảo mật hạ tầng và bảo mật nghiệp vụ của đề tài.

1.5. Tổng quan về an toàn thông tin

1.5.1. Tài sản thông tin

Tài sản thông tin là dữ liệu hoặc thành phần có giá trị đối với hoạt động của hệ thống và cần được bảo vệ. Việc nhận diện tài sản giúp tránh cách tiếp cận chỉ tập trung vào máy chủ mà bỏ qua tài khoản, quyền truy cập và thông tin vận hành.

Trong CloudBox, nội dung tài liệu là tài sản nghiệp vụ trực tiếp; siêu dữ liệu như tên tệp, chủ sở hữu, thời điểm tải lên và quan hệ chia sẻ giúp hệ thống tổ chức và kiểm soát tài liệu. Siêu dữ liệu cũng có thể tiết lộ thông tin nhạy cảm, vì vậy không nên coi đây là dữ liệu luôn được phép công khai.

Nhóm tài sản xác thực gồm mật khẩu ở thời điểm nhập, giá trị băm mật khẩu, OTP và trạng thái phiên. Mật khẩu dạng rõ không được lưu lâu dài. Phiên cookie có

thể đại diện cho một phiên đã đăng nhập, nên việc bảo vệ cookie quan trọng tương tự bảo vệ khả năng truy cập tài khoản. OTP cần được giới hạn mục đích sử dụng, thời gian tồn tại và số lần thử.

Secret key, thông tin kết nối cơ sở dữ liệu và quyền truy cập dịch vụ là tài sản vận hành. Nếu chúng bị lộ, phạm vi ảnh hưởng có thể vượt quá một tài khoản người dùng. Nhật ký và bản sao lưu cũng cần được phân loại, vì có thể chứa dấu vết hoạt động hoặc bản sao dữ liệu đã được bảo vệ ở hệ thống chính.

1.5.2. Mối đe dọa, lỗ hổng và rủi ro

Mối đe dọa: yếu tố có khả năng gây hại đến tài sản, có thể xuất phát từ con người, lỗi kỹ thuật hoặc sự cố môi trường. Lỗ hổng: điểm yếu trong thiết kế, cấu hình, phần mềm hoặc quy trình mà mối đe dọa có thể tác động vào. Tấn công: hành động cố ý nhằm làm tổn hại hệ thống hoặc vượt qua các cơ chế bảo vệ.

Rủi ro: thể hiện khả năng và mức độ hậu quả khi một sự kiện bất lợi xảy ra. Đánh giá rủi ro cần quan tâm đến tài sản bị ảnh hưởng, điều kiện xảy ra và biện pháp kiểm soát hiện có. Một điểm yếu có thể dẫn đến mức rủi ro khác nhau tùy dữ liệu và phạm vi triển khai.

Ví dụ, tài liệu riêng tư là tài sản; người không được cấp quyền là tác nhân có thể gây đe dọa; thiếu kiểm tra chủ sở hữu là lỗ hổng. Nếu người này truy cập được tài liệu của người khác, hậu quả là mất tính bí mật. Biện pháp phù hợp không chỉ là làm khó đoán mã tài liệu, mà là kiểm tra quyền ở phía máy chủ đối với mỗi yêu cầu.

Trong đồ án có thể dùng thang định tính cho khả năng xảy ra và mức ảnh hưởng để xác định thứ tự xử lý. Nếu sử dụng tích hai điểm số làm chỉ số rủi ro, cần nêu rõ quy ước chấm điểm; kết quả không phải xác suất hay thiệt hại tiền tệ đã đo được. Rủi ro cần được theo dõi trong suốt quá trình thiết kế, triển khai và vận hành, thay vì chỉ được đánh giá tại một thời điểm. [2, tr. 119–120]

1.5.3. Bộ ba CIA

Bộ ba CIA gồm tính bí mật (Confidentiality), tính toàn vẹn (Integrity) và tính sẵn sàng (Availability). Ba thuộc tính bổ sung cho nhau và là cơ sở để xác định mục tiêu bảo vệ dữ liệu.

Tính bí mật: thông tin chỉ được tiết lộ cho chủ thể được phép. Trong CloudBox, người dùng chỉ được xem hoặc tải tài liệu thuộc quyền sở hữu hoặc được chia sẻ hợp lệ. Tên tệp, danh sách tài liệu và nhật ký cũng phải được kiểm soát theo phạm vi người xem.

Tính toàn vẹn: dữ liệu được bảo vệ trước thay đổi hoặc phá hủy không phù hợp. Một tệp còn tồn tại nhưng bị thay đổi nội dung không đúng quyền vẫn là sự cố toàn vẹn. Đối với CloudBox, quyền sửa/xóa, ràng buộc cơ sở dữ liệu và kiểm tra nội dung

tệp đều góp phần bảo vệ thuộc tính này.

Tính sẵn sàng: người có quyền có thể truy cập thông tin và dịch vụ khi cần. Hệ thống có thể mất sẵn sàng do lỗi kết nối, hết dung lượng, lỗi phần mềm hoặc tài nguyên bị sử dụng quá mức. Sao lưu, giám sát và quy trình phục hồi hỗ trợ mục tiêu này, nhưng phải được thiết kế theo nhu cầu thực tế.

Một cơ chế riêng lẻ không bảo đảm đồng thời cả ba thuộc tính. Mã hóa giúp bảo vệ bí mật nhưng không thay thế sao lưu; bản sao lưu giúp khôi phục nhưng nếu phân quyền sai lại trở thành nguồn rò rỉ. Do đó, CloudBox cần kết hợp nhiều cơ chế và kiểm thử từng mục tiêu một cách độc lập.

1.5.4. Các nguyên tắc bảo mật

Đặc quyền tối thiểu: chỉ cấp quyền cần thiết cho công việc, trong phạm vi và thời gian phù hợp. Tài khoản ứng dụng không cần quyền quản trị toàn bộ hạ tầng; người nhận tài liệu không mặc nhiên có quyền chia sẻ tiếp hoặc xóa tài liệu.

Phòng thủ nhiều lớp: kết hợp biện pháp ở danh tính, ứng dụng, lưu trữ và vận hành. Ví dụ, kết nối riêng tới cơ sở dữ liệu hỗ trợ giảm khả năng truy cập ngoài ý muốn, còn kiểm tra quyền ở route bảo vệ logic nghiệp vụ. Một lớp bị lỗi không nên khiến toàn bộ dữ liệu lập tức mất bảo vệ.

Từ chối theo mặc định: một yêu cầu chỉ được chấp nhận khi có điều kiện cho phép rõ ràng. Chức năng mới và tài liệu mới cần có chính sách xác định, thay vì mở truy cập rồi mới bổ sung hạn chế sau.

Phân tách nhiệm vụ: giảm việc một chủ thể tự thực hiện toàn bộ quy trình nhạy cảm mà không có kiểm tra. Trong nhóm nhỏ, có thể áp dụng bằng cách để người khác rà soát thay đổi quyền và cấu hình trước khi triển khai.

Secure by Design: đặt yêu cầu bảo mật ngay từ phân tích và thiết kế. Secure by Default: cấu hình ban đầu hạn chế quyền và khả năng để lộ không cần thiết. Ví dụ, chức năng chia sẻ tài liệu cần có cơ chế thu hồi ngay từ thiết kế, còn tài liệu mới nên mặc định là riêng tư.

Zero Trust: không cấp sự tin cậy chỉ vì thiết bị hoặc người dùng nằm trong mạng nội bộ. Quyết định truy cập cần dựa trên danh tính, tài nguyên và chính sách phù hợp. Với CloudBox, việc đã đăng nhập không đủ để truy cập mọi tệp; mỗi thao tác vẫn cần kiểm tra quyền. Áp dụng một số nguyên tắc này chưa có nghĩa đồ án đã xây dựng đầy đủ kiến trúc Zero Trust. [6]

1.6. Các cơ chế bảo vệ dữ liệu

1.6.1. Xác thực người dùng

Xác thực xác định chủ thể đang yêu cầu truy cập là ai, còn phân quyền xác định chủ thể đó được làm gì. Hai cơ chế cần được tách biệt: người dùng đăng nhập thành công vẫn có thể bị từ chối thao tác trên tài liệu không thuộc quyền của mình.

Xác thực bằng mật khẩu so sánh thông tin người dùng cung cấp với dữ liệu xác minh đã lưu. Mật khẩu phải được xử lý bằng cơ chế băm mật khẩu phù hợp; hệ thống không cần lưu mật khẩu dạng rõ để phục vụ đăng nhập. Khi xác thực thất bại, phản hồi cần tránh tiết lộ không cần thiết sự tồn tại của tài khoản.

Xác thực đa yếu tố kết hợp các nhóm yếu tố độc lập như điều người dùng biết, vật người dùng sở hữu hoặc đặc trưng của người dùng. Hai mật khẩu không tạo thành hai yếu tố độc lập. OTP là mã dùng một lần, có thể được sử dụng trong xác thực hoặc khôi phục tài khoản; chỉ riêng việc gửi OTP qua email chưa đủ để khẳng định một luồng đã đáp ứng yêu cầu MFA. [7]

Trong thiết kế CloudBox, OTP khôi phục mật khẩu cần có thời hạn, giới hạn lần thử và vô hiệu hóa sau khi dùng. Giới hạn tốc độ và tạm khóa có kiểm soát giúp hạn chế thử thông tin đăng nhập liên tục, nhưng cần tránh tạo điều kiện để người khác cố ý khóa tài khoản hợp lệ. Quy trình khôi phục cũng phải được bảo vệ vì nó có khả năng thay đổi quyền kiểm soát tài khoản.

1.6.2. Kiểm soát truy cập

Các mô hình kiểm soát truy cập mô tả cách xác định và áp dụng quyền của chủ thể đối với tài nguyên. Lựa chọn mô hình phụ thuộc vào mức linh hoạt, yêu cầu quản trị và đặc điểm dữ liệu.

DAC (Discretionary Access Control): cho phép chủ sở hữu cấp quyền cho chủ thể khác trong phạm vi chính sách. Chức năng chia sẻ tài liệu do chủ sở hữu khởi tạo có nét tương đồng với cách tiếp cận này, nhưng ứng dụng vẫn có thể áp đặt giới hạn riêng.

MAC (Mandatory Access Control): áp dụng chính sách tập trung, thường dựa vào nhãn phân loại và mức cho phép truy cập. Chủ sở hữu không được tự ý vượt qua chính sách bắt buộc. Mô hình phù hợp với môi trường yêu cầu kiểm soát chặt luồng thông tin giữa các mức phân loại.

RBAC (Role-Based Access Control): gán quyền cho vai trò rồi gán người dùng vào vai trò. Với CloudBox, người dùng thường và quản trị viên có các tập quyền chức năng khác nhau. Tách vai trò khỏi danh sách quyền giúp điều chỉnh quyền mà không phải thay đổi từng tài khoản.

ABAC (Attribute-Based Access Control): đánh giá thuộc tính của chủ thể, tài

nguyên, hành động và ngữ cảnh. Ví dụ, yêu cầu tải tệp có thể phụ thuộc vào trạng thái tài khoản, trạng thái tài liệu và thời hạn chia sẻ. ABAC linh hoạt nhưng cần kiểm soát độ phức tạp của chính sách.

Đối với đề tài, RBAC kiểm soát quyền cấp chức năng, còn quyền cấp tài liệu phải dựa thêm vào chủ sở hữu hoặc quan hệ chia sẻ. Một người có quyền sử dụng chức năng tải xuống không có nghĩa được tải xuống mọi tài liệu. Kiểm tra phải thực hiện phía máy chủ trên mỗi yêu cầu, kể cả khi giao diện đã ẩn nút thao tác. [8]

1.6.3. Mã hóa và hàm băm

Mã hóa đối xứng: sử dụng khóa bí mật cho quá trình bảo vệ và khôi phục dữ liệu. Đây là hướng phù hợp để xử lý lượng dữ liệu lớn, nhưng yêu cầu quản lý khóa cẩn thận. Khi thiết kế, cần dùng thư viện và chế độ mã hóa đã được đánh giá, thay vì tự xây dựng thuật toán hoặc ghép các bước mật mã tùy ý.

Mã hóa bất đối xứng: sử dụng cặp khóa công khai và khóa riêng. Tùy thuật toán và giao thức, mật mã bất đối xứng hỗ trợ trao đổi khóa, mã hóa hoặc chữ ký số. Trong thực tế, các hệ thống thường kết hợp hai loại mật mã để tận dụng khả năng thiết lập tin cậy và hiệu quả xử lý dữ liệu.

Hàm băm: tạo giá trị có độ dài cố định từ dữ liệu đầu vào và không được thiết kế để giải mã ngược như mã hóa. SHA-256 có thể hỗ trợ so sánh nội dung tệp. Tuy nhiên, nếu đối tượng tấn công thay được cả tệp lẫn giá trị băm lưu kèm, phép so sánh không còn chứng minh được tính toàn vẹn. Giá trị đối chiếu phải được bảo vệ; khi cần xác thực nguồn gốc phải xem xét thêm MAC hoặc chữ ký số.

Băm mật khẩu: có yêu cầu khác với băm tệp. Các cơ chế chuyên dụng như Argon2id hoặc scrypt sử dụng salt và chi phí tính toán để làm tăng công sức dò mật khẩu khi dữ liệu xác minh bị lộ. Không nên dùng SHA-256 đơn thuần để lưu mật khẩu. Với CloudBox, cần xác định và kiểm tra thuật toán của thư viện sử dụng thay vì chỉ ghi chung rằng mật khẩu đã được băm. [9]

Mã hóa khi truyền: bảo vệ dữ liệu trên các chặng kết nối, điển hình bằng TLS. Không chỉ kết nối từ trình duyệt đến ứng dụng mà kết nối từ ứng dụng đến dịch vụ dữ liệu cũng cần được xem xét. Mã hóa khi lưu trữ: bảo vệ dữ liệu trên thiết bị hoặc trong dịch vụ lưu trữ. Cả hai đều cần quản lý khóa và quyền truy cập phù hợp; mã hóa không ngăn ứng dụng trả dữ liệu cho sai người nếu logic phân quyền bị lỗi.

1.6.4. Ghi log và giám sát

Nhật ký ứng dụng phục vụ theo dõi hoạt động và chẩn đoán lỗi, chẳng hạn request thất bại hoặc lỗi kết nối cơ sở dữ liệu. Nhật ký kiểm toán tập trung vào sự kiện có ý nghĩa truy trách nhiệm, như thay đổi vai trò, cấp quyền chia sẻ hoặc xóa tài liệu. Hai nhóm có thể dùng chung hạ tầng thu thập nhưng cần mục đích và trường thông tin rõ

ràng.

Trong thiết kế CloudBox, một sự kiện nên cho biết thời điểm, chủ thể, hành động, tài nguyên liên quan và kết quả. Mã tương quan giúp kết nối các bản ghi của cùng yêu cầu khi chúng xuất hiện ở nhiều thành phần. Thời gian cần được thống nhất để phục vụ phân tích trình tự sự kiện.

Giám sát chuyển các dấu vết thành tín hiệu phục vụ vận hành. Ví dụ, số lần đăng nhập thất bại tăng nhanh hoặc dung lượng lưu trữ gần ngưỡng cần tạo cảnh báo có người tiếp nhận. Thu thập log mà không có cơ chế rà soát và phản ứng chỉ tạo ra dữ liệu lưu trữ, chưa bảo đảm phát hiện sự cố kịp thời. Haber, Chappell và Hills cũng nhấn mạnh việc ghi lại các hoạt động quan trọng như xác thực và thay đổi quyền, đồng thời kết hợp log với giám sát sự kiện để nhận biết hành vi bất thường. [22, tr. 139–140]

Bản thân log cũng cần được bảo vệ. Không ghi mật khẩu, OTP dạng rõ, phiên token hoặc secret vào nhật ký. Cần hạn chế quyền đọc, chỉnh sửa và xóa log, xác định thời gian giữ và tránh thu thập dữ liệu cá nhân vượt nhu cầu. Một bảng nhật ký mà tài khoản quản trị có thể sửa tùy ý chưa cung cấp bằng chứng chống sửa đổi đủ mạnh.

1.6.5. Sao lưu và phục hồi

Sao lưu tạo bản dữ liệu có thể dùng để khôi phục khi dữ liệu chính bị mất hoặc hỏng. Sao lưu đầy đủ chụp toàn bộ tập dữ liệu trong phạm vi lựa chọn; sao lưu gia tăng chỉ lưu thay đổi kể từ lần sao lưu trước; sao lưu vi sai lưu thay đổi kể từ bản đầy đủ gần nhất. Mỗi cách có chi phí lưu trữ và yêu cầu khôi phục khác nhau.

RPO (Recovery Point Objective): mục tiêu về mức mất dữ liệu có thể chấp nhận, biểu diễn bằng khoảng thời gian trước sự cố. RTO (Recovery Time Objective): mục tiêu về thời gian khôi phục hoạt động sau gián đoạn. Ví dụ minh họa: RPO một giờ hướng đến mất không quá khoảng một giờ dữ liệu; RTO hai giờ hướng đến phục hồi dịch vụ trong hai giờ. Đây là ví dụ giải thích khái niệm, không phải số liệu đã đo của CloudBox.

Point-in-time recovery: cho phép khôi phục cơ sở dữ liệu đến một thời điểm trong phạm vi dữ liệu phục hồi được lưu giữ. Khả năng này thường dựa vào bản sao và nhật ký thay đổi của hệ quản trị. Phải kiểm tra thời gian giữ, thời điểm có thể chọn và những thao tác cần thiết để đưa hệ thống trở lại sử dụng.

Sao lưu cơ sở dữ liệu và sao lưu tệp của CloudBox cần có điểm nhất quán phù hợp. Khôi phục siêu dữ liệu mà thiếu tệp tương ứng có thể tạo ra tài liệu không tải được; khôi phục tệp mà thiếu quan hệ quyền có thể khiến ứng dụng không quản lý được chúng. Bản sao lưu cũng cần quyền truy cập và cơ chế bảo vệ tương xứng với dữ liệu chính.

Kiểm thử phục hồi cần được thực hiện trên môi trường riêng, bao gồm đọc được tệp, kiểm tra nội dung, xác nhận quan hệ quyền và đo thời gian thực hiện. Bản sao

chỉ có giá trị khi có thể sử dụng để phục hồi. Cơ chế sao chép hoặc dự phòng phục vụ tính sẵn sàng không thay thế hoàn toàn sao lưu, vì thao tác xóa nhầm có thể được sao chép sang các bản đang hoạt động.

1.7. Một số tiêu chuẩn và khung tham chiếu

Các nguồn tham chiếu giúp biến yêu cầu bảo mật thành tiêu chí có thể kiểm tra. Mỗi nguồn có mục đích khác nhau: nhận diện nhóm rủi ro, xác minh ứng dụng, quản trị rủi ro hoặc rà soát cấu hình. Đề tài lựa chọn những nội dung phù hợp với CloudBox, không coi việc nhắc tên tiêu chuẩn là bằng chứng tuân thủ.

OWASP Top 10: Đây là tài liệu nâng cao nhận thức về những nhóm rủi ro quan trọng đối với ứng dụng web. Bản năm 2025 được dùng làm nguồn tham khảo cho các vấn đề như kiểm soát truy cập và cấu hình bảo mật. Trong đề tài, tài liệu hỗ trợ định hướng phân tích nguy cơ, nhưng không thay thế danh sách kiểm thử đầy đủ. [10]

OWASP ASVS: Application Security Verification Standard mô tả yêu cầu xác minh an toàn ứng dụng ở mức cụ thể hơn. Nhóm có thể chọn các yêu cầu phù hợp với xác thực, phiên, phân quyền và xử lý dữ liệu để xây dựng ca kiểm thử. Khi ghi nhận đáp ứng, cần chỉ rõ phiên bản, yêu cầu và bằng chứng; việc tham khảo ASVS không đồng nghĩa toàn bộ hệ thống đã được đánh giá đạt chuẩn. [11]

NIST Cybersecurity Framework: CSF 2.0 tổ chức hoạt động quản trị rủi ro an ninh mạng theo sáu chức năng: Govern, Identify, Protect, Detect, Respond và Recover. Với CloudBox, có thể lần lượt liên hệ đến phân công trách nhiệm, nhận diện tài sản, áp dụng kiểm soát, giám sát, xử lý sự cố và phục hồi. Khung này giúp báo cáo quan tâm cả hoạt động vận hành, thay vì chỉ mô tả biện pháp ngăn chặn. [12]

CIS AWS Foundations Benchmark: Bộ hướng dẫn này cung cấp cơ sở rà soát cấu hình nền tảng AWS. Các nội dung được chọn phải phù hợp với tài nguyên thực tế và được ghi nhận theo phiên bản sử dụng. Đối với đề án, nhóm có thể dùng nó làm nguồn xây dựng danh sách kiểm tra cấu hình; không tự gán trạng thái đáp ứng cho những tài nguyên chưa được triển khai hoặc kiểm tra. [13]

AWS Well-Architected Security Pillar: Trụ cột bảo mật cung cấp định hướng đánh giá kiến trúc AWS, bao gồm quản lý danh tính, bảo vệ dữ liệu, phát hiện và ứng phó. Trong CloudBox, nguồn này hỗ trợ rà soát quan hệ giữa ứng dụng, dịch vụ lưu trữ và quyền vận hành, đồng thời giúp xác định phần còn thiếu trong kiến trúc đề xuất. [14]

ISO/IEC 27001: ISO/IEC 27001:2022 quy định yêu cầu đối với hệ thống quản lý an toàn thông tin. Trọng tâm không chỉ là công cụ kỹ thuật mà còn có quản trị, đánh giá rủi ro và cải tiến. Đề án sử dụng định hướng quản lý để làm rõ phạm vi, tài sản và trách nhiệm; không tuyên bố đạt chứng nhận ISO từ việc xây dựng một ứng dụng thử

nghiệm. [15]

1.8. Kết luận chương

Điện toán đám mây cung cấp cách khai thác tài nguyên linh hoạt, nhưng mức độ bảo vệ dữ liệu phụ thuộc vào sự phối hợp giữa nhà cung cấp và khách hàng. Đối với CloudBox, xác thực cần kết hợp với quyền trên từng tài liệu; mã hóa cần đi kèm quản lý khóa; ghi log cần gắn với giám sát; sao lưu cần được kiểm chứng bằng phục hồi. Các cơ sở này là nền tảng để Chương 2 nhận diện nguy cơ và Chương 3 xây dựng mô hình bảo vệ nhiều lớp.

CHƯƠNG 2. CÁC NGUY CƠ AN TOÀN THÔNG TIN TRÊN MÔI TRƯỜNG CLOUD

Nguy cơ an toàn thông tin cần được phân tích theo tài sản và hành vi nghiệp vụ, thay vì chỉ liệt kê tên kỹ thuật tấn công. Đối với CloudBox, một yêu cầu tải tài liệu đi qua trình duyệt, ứng dụng, cơ sở dữ liệu và nơi lưu tệp. Sai sót ở bất kỳ điểm quyết định quyền nào đều có thể ảnh hưởng đến dữ liệu. Chương này xây dựng mô hình nguy cơ cho kiến trúc đó và xác định thứ tự ưu tiên xử lý trước khi lựa chọn giải pháp.

2.1. Tổng quan về nguy cơ an toàn thông tin trên Cloud

Cloud giữ lại nhiều nguy cơ của ứng dụng web truyền thống nhưng bổ sung bề mặt quản trị thông qua API, vai trò dịch vụ và cấu hình tài nguyên từ xa. Một tài khoản bị cấp quyền quá rộng có thể đồng thời tác động đến máy chủ, dữ liệu và nhật ký. Tốc độ cấp phát nhanh cũng làm cho lỗi cấu hình được nhân rộng nếu mẫu hạ tầng không được rà soát.

Tài liệu của Estrin nhấn mạnh việc kết hợp quản lý danh tính, giới hạn kết nối và bảo vệ dịch vụ dữ liệu thay vì chỉ bảo vệ máy ảo. Áp dụng vào CloudBox, phạm vi phân tích phải bao gồm quyền của người dùng cuối lẫn quyền mà ứng dụng sử dụng để truy cập AWS. Hai lớp danh tính này phục vụ mục đích khác nhau và không thể thay thế nhau. [16]

Chia sẻ hạ tầng đặt ra yêu cầu cách ly giữa khách hàng, nhưng không phải mọi sự cố Cloud đều xuất phát từ lỗi cách ly của nhà cung cấp. Trong phạm vi đề án, các nguy cơ gần nhất là sai cấu hình, sai phân quyền ứng dụng, lộ thông tin xác thực và thiếu quy trình phục hồi. Chúng nằm phần lớn trong trách nhiệm của nhóm phát triển và vận hành.

2.2. Phân loại dữ liệu và tài sản cần bảo vệ

2.2.1. Dữ liệu định danh

Tên đăng nhập, email và vai trò giúp ứng dụng nhận diện tài khoản và xác định phạm vi chức năng. Email còn được sử dụng trong khôi phục mật khẩu nên việc sửa email cần được xem như thao tác nhạy cảm. Nếu một người thay được email của tài khoản khác, kênh khôi phục có thể bị chuyển sang người không có quyền.

Vai trò và trạng thái hoạt động là dữ liệu quyết định quyền truy cập, không chỉ là thông tin hiển thị. Hệ thống phải kiểm soát ai được sửa các trường này và tránh nhận trực tiếp giá trị vai trò từ dữ liệu đăng ký. Danh sách người dùng trả về cho chức năng

chia sẻ cần giới hạn trường và số lượng kết quả để giảm khả năng thu thập thông tin hàng loạt.

2.2.2. Dữ liệu xác thực

Giá trị băm mật khẩu, OTP và cookie phiên có thể được sử dụng để xác minh hoặc đại diện cho danh tính. Dữ liệu băm vẫn cần được bảo vệ vì đối tượng có được nó có thể thử đoán ngoại tuyến. OTP có không gian giá trị nhỏ nên cần giới hạn thời gian và số lần thử, ngay cả khi đã được băm.

Khóa ký phiên của Flask có ảnh hưởng trên toàn bộ ứng dụng. Nếu bị lộ, tính tin cậy của dữ liệu phiên có thể mất đi. Việc lưu khóa trong biến môi trường chỉ giải quyết cách truyền cấu hình; quyền đọc môi trường, log chẩn đoán và bản sao của máy chủ vẫn cần được kiểm soát.

2.2.3. Dữ liệu nghiệp vụ

Nội dung tài liệu là tài sản chính, trong khi siêu dữ liệu liên kết tệp với chủ sở hữu, trạng thái và quan hệ chia sẻ. Một tệp không bị thay đổi nhưng trường chủ sở hữu bị sửa vẫn có thể dẫn tới truy cập trái phép. Vì vậy, bảo vệ toàn vẹn phải bao gồm cả nội dung và quan hệ dữ liệu.

Tài liệu trong thùng rác vẫn chiếm dung lượng và có thể cần phục hồi. Trạng thái xóa mềm không đồng nghĩa dữ liệu đã bị tiêu hủy khỏi bản sao, phiên bản cũ hoặc bộ nhớ đệm. Quy trình xóa cần xác định rõ thời gian giữ và phạm vi còn tồn tại của dữ liệu.

2.2.4. Dữ liệu vận hành

Nhật ký, cấu hình triển khai, thông tin kết nối và Terraform state hỗ trợ vận hành nhưng có thể tiết lộ kiến trúc hoặc bí mật. State cần được bảo vệ độc lập với mã Terraform; đánh dấu một biến là nhạy cảm không làm dữ liệu tự biến mất khỏi mọi nơi lưu giữ.

Phân loại tài sản nên gắn với người chịu trách nhiệm. Người quản trị ứng dụng chịu trách nhiệm tài khoản và quyền; người vận hành hạ tầng chịu trách nhiệm cấu hình tài nguyên; chủ sở hữu tài liệu chịu trách nhiệm lựa chọn người nhận. Với nhóm nhỏ, một người có thể đảm nhiệm nhiều vai trò nhưng nhiệm vụ và bằng chứng thay đổi vẫn phải phân biệt.

2.3. Nguy cơ đối với danh tính và quyền truy cập

2.3.1. Mật khẩu yếu

Mật khẩu ngắn, dễ đoán hoặc được dùng lại làm giảm hiệu quả của cơ chế đăng nhập. Việc áp dụng quy tắc ký tự không tự bảo đảm người dùng chọn mật khẩu khó

đoán. Cần cho phép mật khẩu đủ dài, bảo vệ dữ liệu xác minh và xem xét phát hiện mật khẩu đã bị lộ trong giai đoạn phát triển tiếp theo.

Trong CloudBox, chiếm được một tài khoản có thể làm lộ cả tài liệu sở hữu lẫn tài liệu được người khác chia sẻ. Do đó, hậu quả không giới hạn ở thông tin hồ sơ. Đối với quản trị viên, tác động còn bao gồm thay đổi quyền của nhiều người dùng.

2.3.2. Tấn công brute force

Thử nhiều mật khẩu, dùng cặp thông tin xác thực bị lộ và thử liên tục OTP đều nhằm vượt qua bước xác thực. Giới hạn theo địa chỉ mạng đơn lẻ có thể không phản ánh toàn bộ hoạt động đối với một tài khoản. Ngược lại, khóa tài khoản quá dễ có thể bị lợi dụng để cản trở người dùng hợp lệ.

Account enumeration là nguy cơ suy ra tài khoản tồn tại từ phản hồi khác nhau. CloudBox chủ động cung cấp chức năng kiểm tra tên đăng nhập để hỗ trợ đăng ký; điều này tạo đánh đổi giữa tiện dụng và riêng tư. Cần ghi nhận sự đánh đổi và giới hạn tốc độ thay vì tuyên bố hệ thống hoàn toàn che giấu sự tồn tại của tài khoản.

2.3.3. Chiếm đoạt tài khoản

Tài khoản có thể bị chiếm qua lừa đảo, lộ cookie, thiết bị bị xâm nhập hoặc quy trình khôi phục thiếu chặt chẽ. Cookie có HttpOnly giúp giảm khả năng đọc trực tiếp bằng JavaScript, nhưng không ngăn mọi hành động mà mã chạy trong trang có thể thực hiện dưới phiên hiện tại.

Luồng khôi phục mật khẩu cần bảo vệ cả giai đoạn nhận OTP và giai đoạn sau khi OTP đã được xác minh. Nếu trạng thái cho phép đặt lại mật khẩu tồn tại quá lâu hoặc được dùng nhiều lần, việc giới hạn thời hạn OTP ban đầu chưa đủ. Đây là điểm cần được rà soát riêng trong hiện thực.

2.3.4. Phân quyền không phù hợp

Cấp quyền vượt nhu cầu làm tăng phạm vi thiệt hại khi một tài khoản bị sử dụng sai. Ở tầng ứng dụng, lỗi có thể là người dùng thường truy cập chức năng quản trị. Ở tầng AWS, lỗi có thể là tiến trình web được phép sửa chính sách hoặc đọc dữ liệu ngoài bucket cần thiết.

Quyền cũng có thể trở nên không phù hợp theo thời gian. Tài khoản không còn sử dụng, quan hệ chia sẻ cũ và vai trò của nhân sự đã chuyển nhiệm vụ cần được rà soát, thu hồi. Cơ chế cấp quyền phải đi cùng cơ chế kết thúc quyền.

2.3.5. Leo thang đặc quyền

Leo thang ngang xảy ra khi người dùng thao tác lên tài nguyên của người khác dù vai trò không thay đổi. Leo thang dọc xảy ra khi người dùng có được khả năng thuộc vai trò cao hơn. Một decorator kiểm tra đăng nhập không xử lý được cả hai tình

huống này.

CloudBox cần kiểm tra riêng quyền chức năng và quan hệ với tài liệu. Đối với quản trị, việc tự sửa vai trò hoặc tự vô hiệu hóa tài khoản quan trọng còn có thể gây mất khả năng quản lý. Cần kiểm soát các thao tác nhạy cảm bằng chính sách rõ ràng và nhật ký phù hợp.

2.4. Nguy cơ đối với ứng dụng Cloud

2.4.1. Broken Access Control

Kiểm soát truy cập bị phá vỡ khi máy chủ chấp nhận thao tác vượt chính sách. Mã tài liệu khó đoán chỉ làm giảm khả năng tìm thấy tài nguyên, không chứng minh người gửi yêu cầu có quyền. Cùng một tài liệu có thể được truy cập qua giao diện web hoặc API, nên cả hai đường đi phải áp dụng cùng điều kiện.

Tình huống kiểm tra điển hình gồm người không được chia sẻ yêu cầu tải tệp, người nhận yêu cầu xóa và người đã bị thu hồi quyền tiếp tục truy cập. Ngoài dữ liệu trả về, cần xác nhận các yêu cầu bị từ chối không gây thay đổi trong cơ sở dữ liệu.

2.4.2. SQL Injection

SQL Injection xuất hiện khi dữ liệu đầu vào bị diễn giải như một phần cấu trúc truy vấn. Nguyên nhân điển hình là nối chuỗi SQL với giá trị do người dùng cung cấp. Kiểm tra dữ liệu đầu vào hỗ trợ chất lượng dữ liệu nhưng không thay thế ràng buộc tham số.

Sử dụng ORM giúp chuẩn hóa truy vấn, song vẫn có thể phát sinh nguy cơ nếu lập trình viên dùng câu lệnh thô không an toàn. Các trường dùng để sắp xếp hoặc chọn cột cần ánh xạ qua danh sách cho phép. Tài khoản cơ sở dữ liệu có quyền hạn chế giúp giảm hậu quả khi tầng ứng dụng bị lỗi.

2.4.3. Cross-Site Scripting

XSS xảy ra khi nội dung không tin cậy được đưa vào ngữ cảnh thực thi trên trình duyệt. Trong hệ thống tài liệu, tên tệp và dữ liệu hồ sơ là các đầu vào cần chú ý. Dữ liệu có thể được lưu rồi hiển thị lại cho nhiều người, làm tăng phạm vi ảnh hưởng của một lỗi xử lý đầu ra.

Cách bảo vệ phụ thuộc ngữ cảnh HTML, thuộc tính, URL hay JavaScript. Auto-escaping của template là nền tảng nhưng có thể bị vô hiệu hóa bởi cách đánh dấu nội dung an toàn tùy tiện. CSP bổ sung giới hạn thực thi; nó không sửa lỗi phân quyền hoặc biến mọi nội dung tải lên thành vô hại.

2.4.4. Cross-Site Request Forgery

CSRF lợi dụng việc trình duyệt tự gửi cookie khi thực hiện yêu cầu để gây thao tác ngoài ý muốn của người dùng. Các chức năng xóa, chia sẻ, đổi quyền và đăng xuất cần được bảo vệ nếu sử dụng xác thực bằng cookie. GET không nên tạo thay đổi trạng thái nghiệp vụ.

Token CSRF phải được kiểm tra tại máy chủ. Với API sử dụng cùng cookie phiên, gọi là API không làm nguy cơ tự biến mất. SameSite hỗ trợ hạn chế một số yêu cầu chéo trang nhưng cần được kết hợp với cơ chế xác minh yêu cầu.

2.4.5. Quản lý phiên không an toàn

Phiên không hết hạn hợp lý, không được thu hồi sau đổi mật khẩu hoặc chứa dữ liệu nhạy cảm có thể làm kéo dài truy cập trái phép. Với cookie phiên được ký, tính toàn vẹn và tính bí mật là hai vấn đề khác nhau: chữ ký không che nội dung cookie khỏi người sở hữu nó.

Xóa cookie trên trình duyệt khi đăng xuất không tự làm vô hiệu mọi bản sao cookie đã bị sao chép. Muốn thu hồi phía máy chủ cần có trạng thái có thể kiểm tra, như phiên bản phiên hoặc kho phiên tập trung. Chính sách cần phân biệt đăng xuất thiết bị hiện tại với đăng xuất tất cả thiết bị.

2.4.6. API không an toàn

API có thể để lộ dữ liệu thừa, chấp nhận trường ngoài dự kiến hoặc bỏ qua điều kiện quyền của giao diện. JSON cần được kiểm tra kiểu dữ liệu; một chuỗi mang ý nghĩa “false” không nên được tự hiểu như giá trị Boolean hợp lệ.

Thông báo lỗi cần đủ cho người dùng nhưng tránh trả stack trace, cấu trúc thư mục và thông tin kết nối. Phân trang, giới hạn tìm kiếm và giới hạn kích thước yêu cầu giúp giảm thu thập dữ liệu hàng loạt và tiêu thụ tài nguyên. CORS không phải cơ chế thay thế xác thực.

2.5. Nguy cơ từ tệp tải lên

2.5.1. Giả mạo định dạng tệp

Phần mở rộng và MIME do phía gửi cung cấp có thể không phù hợp với nội dung. Vì vậy, kiểm tra nhiều tín hiệu độc lập có ý nghĩa hơn việc tin một trường duy nhất. OWASP khuyến nghị giới hạn loại tệp theo nhu cầu, đổi tên lưu trữ, giới hạn kích thước và tách nơi lưu tệp khỏi vùng phục vụ web trực tiếp. [17]

Chữ ký đầu tệp chỉ nhận diện một phần định dạng. Một PDF hoặc tệp Office có cấu trúc hợp lệ vẫn có thể chứa nội dung nguy hiểm. Báo cáo cần phân biệt kiểm tra định dạng với phân tích mã độc; kết quả thứ nhất không chứng minh kết quả thứ hai.

2.5.2. Path traversal

Tên do người dùng nhập không nên quyết định đường dẫn lưu vật lý. Nếu ghép trực tiếp tên với thư mục đích, ứng dụng có thể đọc hoặc ghi ra ngoài phạm vi dự kiến. Chuẩn hóa tên hiển thị và kiểm tra đường dẫn sau khi phân giải là hai bước có mục đích khác nhau.

Đối với kho lưu trữ đối tượng, khóa đối tượng không phải đường dẫn hệ điều hành nhưng vẫn phải tuân theo không gian tên của ứng dụng. Phần xử lý lưu trữ nên áp dụng cùng quy tắc kiểm tra đầu vào cho cả ổ đĩa cục bộ và S3, tránh thay đổi hành vi khi chuyển môi trường.

2.5.3. Tập nén nguy hiểm

Tập nén có thể chứa nhiều mục, đường dẫn không phù hợp hoặc dữ liệu bùng ra lớn hơn nhiều lần kích thước ban đầu. Ngay cả khi ứng dụng chưa giải nén, việc chấp nhận tập như một tài liệu an toàn có thể chuyển rủi ro sang người tải xuống.

Giới hạn số mục, tổng kích thước và tỷ lệ nén hỗ trợ phát hiện bất thường. Tuy nhiên, chỉ đọc thông tin trong danh mục ZIP không tương đương giải nén có giới hạn và quét toàn bộ nội dung. Kiểm tra này cần được mô tả đúng mức, đặc biệt với định dạng Office dựa trên ZIP.

2.5.4. Tập chứa mã độc

Tập có thể mang mã độc hoặc nội dung khai thác phần mềm độc tài liệu. Cần có cơ chế cách ly và quyết định khi nào cho phép tải xuống. Nếu chưa có bộ quét, trạng thái “chưa quét” phải được phản ánh rõ trong đánh giá rủi ro.

Một trường trạng thái trong cơ sở dữ liệu chỉ tạo khả năng quản lý quy trình. Muốn chứng minh đã quét cần có thành phần thực thi, phiên bản bộ quét, kết quả liên kết với đúng phiên bản tập và xử lý khi quét thất bại. Việc cho tải tập chưa quét là một quyết định chấp nhận rủi ro, không phải một biện pháp chống mã độc.

2.5.5. Tấn công làm cạn kiệt tài nguyên

Tải lên và tải xuống tiêu thụ băng thông, dung lượng, bộ nhớ và thời gian xử lý. Nguy cơ có thể xuất hiện từ một tập lớn hoặc nhiều tập hợp lệ được gửi đồng thời. Hạn mức lưu trữ theo người dùng cần tính cả tài liệu xóa mềm vì nội dung vẫn tồn tại.

Kiểm tra tổng dung lượng rồi ghi thêm dữ liệu là hai bước tách biệt. Nếu nhiều yêu cầu thực hiện đồng thời, tổng cuối cùng có thể vượt hạn mức lưu trữ dù từng yêu cầu đều vượt qua kiểm tra ban đầu. Đây là nguy cơ về tính nguyên tử, cần kiểm thử cạnh tranh hoặc cơ chế giữ chỗ dung lượng.

2.6. Nguy cơ đối với dữ liệu lưu trữ

2.6.1. Rò rỉ dữ liệu

Dữ liệu có thể lộ qua bucket công khai, quyền rộng, cơ sở dữ liệu mở ra mạng hoặc đường tải xuống thiếu xác thực. URL có chữ ký cũng cần được xem như một quyền truy cập tạm thời; việc giữ bí mật URL không thay cho việc kiểm soát người được cấp URL.

Đối với CloudBox, ứng dụng là điểm quyết định quyền tải tài liệu. Quyền IAM cho phép tiến trình đọc bucket không nói lên người dùng nào được đọc từng tệp. Nếu tầng nghiệp vụ quyết định sai, S3 vẫn có thể trả dữ liệu đúng theo quyền của tiến trình.

2.6.2. Dữ liệu bị sửa đổi

Thay thế nội dung, sửa chủ sở hữu, thay quan hệ chia sẻ hoặc chỉnh nhật ký đều làm suy giảm toàn vẹn. Giá trị băm chỉ có ý nghĩa đối chiếu khi giá trị tham chiếu được bảo vệ. Cần xác định ai có quyền cập nhật nội dung và thời điểm nào giá trị băm được tính lại.

Nhật ký trong cùng cơ sở dữ liệu giúp truy vết nghiệp vụ nhưng có thể bị tác động bởi chủ thể có quyền quản trị cơ sở dữ liệu. Cơ chế lưu ngoài hệ thống chính hoặc quyền ghi tách biệt sẽ làm tăng độ tin cậy của bằng chứng.

2.6.3. Mất dữ liệu

Xóa nhầm, lỗi phần mềm và thao tác phục hồi không đúng có thể khiến dữ liệu mất hoặc không sử dụng được. Đặc biệt, lưu tệp và siêu dữ liệu ở hai dịch vụ không tạo thành một giao dịch chung. Lỗi giữa hai bước có thể sinh tệp mồ côi hoặc bản ghi trở tới tệp không tồn tại.

Sao lưu cần kiểm chứng cả khả năng đọc dữ liệu và quan hệ quyền sau phục hồi. Việc kiểm tra một tệp sao lưu SQLite hợp lệ chưa xác nhận toàn bộ tài liệu trong kho lưu trữ cục bộ đã được khôi phục. Tương tự, snapshot RDS không bao gồm nội dung S3.

2.6.4. Dữ liệu không được mã hóa

Kết nối HTTP làm mất lớp bảo vệ truyền tải giữa trình duyệt và hệ thống. Cấu hình HTTPS ở điểm vào chưa tự bảo vệ mọi chặng nội bộ. Cần ghi nhận riêng chặng trình duyệt–ALB, ALB–ứng dụng, ứng dụng–RDS và ứng dụng–S3.

S3 hiện cung cấp mã hóa mặc định cho các đối tượng mới bằng SSE-S3; do đó không nên mô tả mọi bucket mới là không mã hóa nếu người dùng chưa bật công tắc riêng. Điều cần kiểm tra là cơ chế thực tế, quyền sử dụng dữ liệu, đối tượng cũ và yêu cầu quản lý khóa. [18]

2.7. Nguy cơ cấu hình sai hạ tầng Cloud

2.7.1. Cấu hình sai Amazon S3

Sai bucket policy hoặc ACL có thể làm rộng phạm vi đọc dữ liệu. Block Public Access, quyền sở hữu bucket và chính sách yêu cầu kết nối an toàn cần được đánh giá đồng thời. Một chính sách từ chối HTTP bảo vệ điều kiện truyền tải, không tự giới hạn mọi principal được phép đọc.

Versioning hỗ trợ khôi phục phiên bản cũ nhưng làm tăng dung lượng và có thể giữ lại dữ liệu đã xóa ở tầng ứng dụng. Cần phối hợp lifecycle với thời gian lưu thùng rác và yêu cầu xóa dữ liệu; không đồng nhất xóa bản ghi với xóa mọi phiên bản.

2.7.2. Cấu hình sai Amazon RDS

RDS có địa chỉ công khai, security group rộng hoặc tài khoản ứng dụng quyền cao làm tăng rủi ro. Đặt cơ sở dữ liệu trong subnet riêng giúp hạn chế kết nối trực tiếp, nhưng ứng dụng bị xâm nhập vẫn có thể dùng quyền được cấp.

Yêu cầu TLS ở máy chủ cần đi cùng cấu hình tin cậy chứng chỉ ở máy khách. Chính sách backup, bảo vệ xóa và khả năng phục hồi phải được xác minh từ trạng thái triển khai; việc khai báo trong Terraform là đầu vào cho kiểm tra, chưa phải kết quả vận hành.

2.7.3. Cấu hình sai Amazon EC2

Các cổng quản trị mở rộng, phần mềm chưa cập nhật và thông tin xác thực tĩnh làm tăng bề mặt tấn công. Role gắn với instance giảm nhu cầu lưu khóa AWS dài hạn. IMDSv2 bổ sung yêu cầu token khi truy cập siêu dữ liệu, nhưng không thay thế hạn chế quyền của vai trò.

Một EC2 đặt trong public subnet không nhất thiết cho phép mọi kết nối vào, vì security group vẫn áp dụng. Tuy nhiên, địa chỉ công khai và egress rộng là các yếu tố cần nêu rõ khi đánh giá kiến trúc, tránh gọi toàn bộ tầng ứng dụng là mạng riêng.

2.7.4. Cấu hình sai IAM

Quyền wildcard cần được đánh giá theo hành động, tài nguyên và điều kiện. Một số API chỉ hỗ trợ tài nguyên dạng wildcard, nên không thể kết luận mọi dấu sao đều là lỗi. Trọng tâm là quyền có vượt công việc thực tế và có thể giới hạn thêm hay không.

Role dùng để triển khai hạ tầng thường cần quyền rộng hơn vai trò của tiến trình web. Không phân tách hai vai trò này sẽ làm một sự cố ứng dụng có khả năng tác động đến toàn bộ môi trường. Hoạt động đặc quyền cần được ghi nhận và rà soát định kỳ.

2.7.5. Quản lý secret không an toàn

Secret trong mã nguồn, image, log hoặc tệp cấu hình được chia sẻ có thể tồn tại lâu sau khi đã xóa ở một vị trí. Cần thu hồi và thay giá trị khi xác nhận lộ, không chỉ xóa dòng chứa giá trị. Bản sao và lịch sử phiên bản cũng thuộc phạm vi xử lý.

Secrets Manager hỗ trợ quản lý tập trung nhưng ứng dụng vẫn có thể ghi secret ra tệp lúc khởi động. Vì vậy, đánh giá cần theo toàn bộ đường đi từ kho bí mật đến tiến trình sử dụng, bao gồm quyền đọc tệp, quyền đọc môi trường và cơ chế thay đổi giá trị.

2.8. Nguy cơ từ chuỗi cung ứng phần mềm

Ứng dụng phụ thuộc vào các thư viện, image nền, công cụ CI/CD và gói triển khai. Lỗi bảo mật ở một trong các thành phần này có thể ảnh hưởng đến hệ thống. Cố định phiên bản giúp cài đặt lại cùng một môi trường, nhưng phiên bản đó vẫn có thể chứa lỗ hổng. Tương tự, cố định digest của image và commit của action giúp tránh thay đổi ngoài dự kiến; nhóm vẫn cần rà soát và cập nhật khi có bản sửa phù hợp.

Mishra trình bày DevSecOps như việc tích hợp bảo mật xuyên suốt quá trình phát triển. Với CloudBox, ý nghĩa thực tế là đưa kiểm thử, rà soát thư viện phụ thuộc, image và mã hạ tầng vào quy trình thay đổi, đồng thời lưu bằng chứng của từng lần chạy. Một workflow được khai báo chứa chứng minh workflow đó đã chạy thành công. [19]

2.9. Nguy cơ từ con người và quy trình

Chia sẻ sai người, thay đổi quyền không được rà soát và không kiểm tra bản sao lưu có thể gây sự cố dù ứng dụng không có lỗi kỹ thuật rõ ràng. Giải pháp cần hỗ trợ người dùng nhận biết người nhận, xem lại quyền đã cấp và thu hồi thuận tiện.

Quy trình phản ứng sự cố cần xác định người tiếp nhận cảnh báo, phạm vi cô lập, cách bảo toàn bằng chứng và điều kiện mở lại dịch vụ. Hướng tiếp cận kiểm toán Cloud của Majumdar và cộng sự cho thấy khoảng cách giữa chính sách cấp cao và dữ liệu kỹ thuật phải được giải quyết bằng bằng chứng có thể kiểm tra. Trong đồ án, ma trận truy vết được dùng để thu hẹp khoảng cách đó. [20]

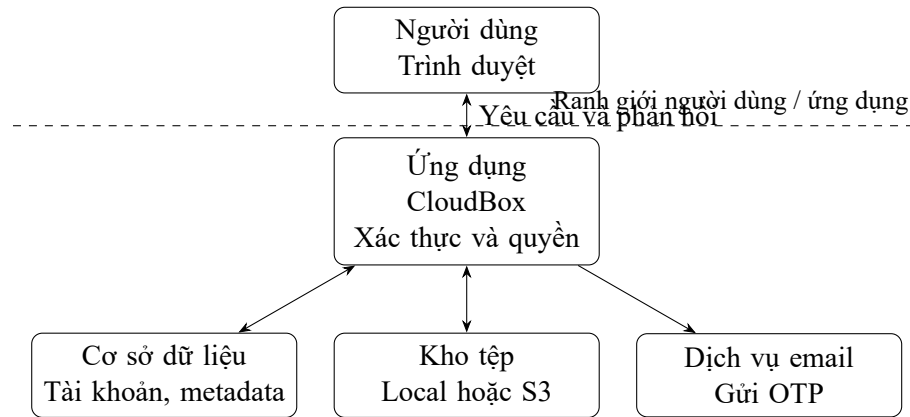
2.10. Mô hình hóa mối đe dọa

2.10.1. Xác định tác nhân

Các tác nhân gồm khách chưa đăng nhập, người dùng hợp lệ, người nhận tài liệu, quản trị viên và tiến trình dịch vụ. Một người dùng hợp lệ vẫn có thể gửi yêu cầu ngoài quyền. Dịch vụ email và AWS là thành phần ngoài phạm vi ứng dụng; phản hồi lỗi hoặc gián đoạn của chúng phải được xử lý như tình huống có thể xảy ra.

2.10.2. Xây dựng biểu đồ luồng dữ liệu

Hình dưới mô tả luồng logic. Cơ sở dữ liệu lưu danh tính và quan hệ quyền; kho tệp lưu nội dung. Ứng dụng cần kiểm tra siêu dữ liệu trước khi đọc tệp. Luồng OTP đi qua dịch vụ email nhưng quyền đặt lại mật khẩu phải được quyết định tại ứng dụng.



Hình 2.1: Luồng dữ liệu logic của CloudBox

2.10.3. Xác định ranh giới tin cậy

Ranh giới thứ nhất nằm giữa trình duyệt và máy chủ: mọi trường đầu vào đều cần được xem xét, kể cả trường ẩn. Ranh giới thứ hai nằm giữa ứng dụng và dịch vụ dữ liệu: thông tin xác thực của ứng dụng chỉ được cấp phạm vi cần thiết. Ranh giới thứ ba là hoạt động quản trị, nơi quyền sửa cấu hình có thể vượt quyền nghiệp vụ thông thường.

Trong phương án ALB, thông tin forwarded header chỉ đáng tin nếu ứng dụng thực sự chỉ nhận kết nối từ proxy đã xác định. Cấu hình proxy và security group phải được xét như một cặp kiểm soát. Chỉ cài middleware đọc header chưa chứng minh địa chỉ nguồn hoặc giao thức của yêu cầu là đáng tin.

2.10.4. Phân tích theo STRIDE

STRIDE được dùng như danh sách câu hỏi có hệ thống cho từng tác nhân, luồng và kho dữ liệu. Một nguy cơ có thể thuộc nhiều nhóm; mục đích là tránh bỏ sót thuộc tính bị ảnh hưởng, không bắt buộc mỗi sự kiện chỉ được gán một nhãn.

2.11. Đánh giá rủi ro

Đề tài sử dụng thang ba mức cho khả năng xảy ra L và ảnh hưởng I . Giá trị $L = 1$ biểu thị tình huống cần điều kiện đặc biệt hoặc quyền nội bộ; $L = 2$ biểu thị đường tác động có thể tiếp cận nhưng cần điều kiện bổ sung; $L = 3$ biểu thị bề mặt

Bảng 2.1: Áp dụng STRIDE cho CloudBox

Nhóm	Tình huống cần xem xét	Kiểm soát trọng tâm
Giả mạo danh tính	Sử dụng tài khoản hoặc phiên của người khác	Xác thực, quản lý vòng đời phiên
Sửa đổi	Thay siêu dữ liệu, nội dung hoặc quan hệ quyền	Quyền cấp đối tượng, ràng buộc dữ liệu
Chối bỏ	Không xác định được ai đã đổi quyền	Nhật ký hành động và bảo vệ log
Tiết lộ thông tin	Độc tài liệu ngoài phạm vi chia sẻ	Kiểm tra quyền, kho riêng tư, TLS
Từ chối dịch vụ	Vượt hạn mức lưu trữ, quá tải tài lên hoặc lỗi lưu trữ	Giới hạn tài nguyên, giám sát, phục hồi
Nâng quyền	Người dùng đổi vai trò hoặc lạm dụng IAM	Phân tách nhiệm vụ, đặc quyền tối thiểu

thường xuyên tiếp xúc đầu vào không tin cậy và không cần quyền cao. Đây là ước lượng thiết kế, không phải tần suất thống kê của sự cố.

Ảnh hưởng $I = 1$ giới hạn ở thao tác đơn lẻ, dễ phục hồi; $I = 2$ ảnh hưởng một tài khoản hoặc một tập tài liệu có thể khôi phục; $I = 3$ ảnh hưởng nhiều tài khoản, dữ liệu nhạy cảm hoặc khả năng vận hành toàn hệ thống. Chỉ số ưu tiên được tính bằng $R = L \times I$: từ 1 đến 2 là thấp, từ 3 đến 4 là trung bình, từ 6 đến 9 là cao. Các mức được dùng nhất quán để chọn thứ tự xử lý.

Ma trận tiếp theo đánh giá nguy cơ trước các kiểm soát đề xuất, với giả định hệ thống tiếp nhận người dùng qua Internet. Chưa có số liệu đủ để tính mức rủi ro còn lại bằng số sau triển khai. Chương 5 vì vậy đánh giá phần còn lại theo bằng chứng và giới hạn cụ thể, tránh tạo cảm giác chính xác giả từ việc giảm điểm tùy ý.

2.12. Ma trận rủi ro

Bảng 2.2: Ma trận ưu tiên rủi ro trước kiểm soát

Mã	Tài sản	Nguyên nhân / nguy cơ	L	I	R	Hướng xử lý
R01	Tài khoản	Thử mật khẩu, dùng lại thông tin xác thực	3	2	6	Giới hạn thử, bấm, theo dõi
R02	Tài liệu	Thiếu quyền cấp đối tượng	3	3	9	Owner hoặc chia sẻ hợp lệ
R03	Quyền quản trị	Sửa vai trò trái phép	2	3	6	RBAC, kiểm soát tự quản lý
R04	Phiên	Cookie bị lộ, không thu hồi	2	3	6	Cookie an toàn, phiên bản phiên

Mã	Tài sản	Nguyên nhân / nguy cơ	L	I	R	Hướng xử lý
R05	Tài liệu và người nhận	Định dạng hợp lệ nhưng có mã độc	3	3	9	Cách ly và bộ quét chuyên dụng
R06	Tài nguyên	Tải lên lớn, nhiều file, vượt hạn mức lưu trữ	3	2	6	Giới hạn request, cơ chế kiểm tra và cập nhật dung lượng trong cùng một thao tác
R07	Kho lưu trữ	S3 hoặc kết nối DB mở rộng	2	3	6	Policy, SG, mạng và quyền riêng
R08	Toàn bộ dữ liệu	Secret hoặc quyền dịch vụ bị lộ	2	3	6	Kho bí mật, vai trò giới hạn
R09	Siêu dữ liệu và tệp	Lỗi ghi hai hệ thống, xóa nhầm	2	3	6	Bù trừ, đối soát, sao lưu
R10	Trình duyệt và quyền	XSS, CSRF tại thao tác thay đổi	3	2	6	Escape, token, CSP
R11	Ứng dụng	Thư viện, image hoặc quy trình CI/CD lỗi	2	3	6	Khóa phiên bản và kiểm tra CI
R12	Bảng chứng	Log thiếu, sửa hoặc bị xóa	2	2	4	Log tập trung, quyền tách biệt
R13	Khôi phục tài khoản	Quyền reset tồn tại hoặc dùng lại	2	3	6	Reset một lần, có hạn sử dụng
R14	Sẵn sàng	Một instance và thiếu diễn tập	2	3	6	Kiểm thử restore, dự phòng theo nhu cầu

R02 và R05 được ưu tiên cao vì dữ liệu riêng tư và nội dung không tin cậy là trung tâm của hệ thống. R07–R09 cần xử lý đồng thời: hạ tầng riêng tư không bù được secret bị lộ, còn sao lưu không thay thế phân quyền. Mỗi rủi ro được gắn với thành phần hiện thực và phép kiểm tra ở các chương sau.

2.13. Kết luận chương

Nguy cơ của CloudBox trải rộng từ danh tính đến dữ liệu và vận hành, nhưng có chung điểm quyết định là quyền truy cập và trạng thái tài liệu. Phân tích STRIDE làm rõ các ranh giới cần bảo vệ; ma trận rủi ro chỉ ra kiểm soát tài liệu, tải lên và bí mật vận hành là những ưu tiên quan trọng. Chương 3 chuyển các kết quả này thành mô hình bảo vệ có thể hiện thực và kiểm thử.

CHƯƠNG 3. ĐỀ XUẤT MÔ HÌNH BẢO VỆ DỮ LIỆU TRÊN MÔI TRƯỜNG CLOUD

Mô hình được đề xuất theo nguyên tắc phòng thủ nhiều lớp, lấy tài liệu và quyền truy cập làm trung tâm. Một thao tác chỉ được chấp nhận khi danh tính, quyền chức năng, quan hệ với tài liệu và trạng thái tài nguyên đều phù hợp. Cách tiếp cận này phù hợp với nguyên tắc xác minh rõ ràng và cấp quyền tối thiểu trong kiến trúc Zero Trust và hướng dẫn kiểm soát truy cập của OWASP. [6, 8] Chương này mô tả yêu cầu thiết kế; Chương 4 và Chương 5 phân biệt những yêu cầu đã hiện thực với phần còn thiếu.

3.1. Mục tiêu và phạm vi của mô hình

3.1.1. Mục tiêu bảo vệ

Mục tiêu của mô hình là giảm thiểu rủi ro đối với tài khoản, tài liệu và hạ tầng CloudBox, thay vì đưa ra cam kết an toàn tuyệt đối. Các mục tiêu được xác định theo bộ ba bí mật, toàn vẹn và sẵn sàng, đồng thời bổ sung khả năng kiểm soát truy cập và truy vết sự kiện.

- Bảo đảm tính bí mật: chỉ người dùng đã xác thực và có quyền hợp lệ mới được truy cập tài liệu; dữ liệu lưu trữ trên S3 và RDS không được công khai trực tiếp.
- Bảo đảm tính toàn vẹn: dữ liệu nghiệp vụ được bảo vệ bằng ràng buộc cơ sở dữ liệu, quyền sở hữu và giá trị SHA-256 của nội dung tệp được lưu trong siêu dữ liệu.
- Hỗ trợ tính sẵn sàng: áp dụng giới hạn kích thước, hạn mức lưu trữ, health check, RDS automated backup và S3 Versioning để giảm tác động của lỗi vận hành và việc xóa nhầm.
- Kiểm soát truy cập: kết hợp RBAC ở cấp chức năng với kiểm tra chủ sở hữu hoặc quan hệ chia sẻ ở cấp tài liệu.
- Tăng khả năng truy vết: ghi nhận các sự kiện xác thực và quản trị quan trọng, tập trung log ứng dụng và VPC Flow Logs trên CloudWatch trong môi trường AWS.
- Giảm cấu hình thủ công: sử dụng Docker để đóng gói ứng dụng và Terraform để quản lý hạ tầng AWS dưới dạng mã.

3.1.2. Phạm vi hiện thực

Mô hình được hiện thực thông qua ứng dụng Flask CloudBox và mã hạ tầng AWS được khai báo bằng Terraform. Môi trường local sử dụng SQLite và local filesystem; môi trường Docker sử dụng Flask/Gunicorn cùng MySQL; môi trường AWS sử dụng

ALB, EC2, RDS MySQL, S3, IAM, Secrets Manager, CloudWatch và VPC Flow Logs. Theo cấu hình thiết kế, EC2 được đặt trong public subnet để tránh chi phí NAT Gateway nhưng không mở SSH và chỉ nhận lưu lượng ứng dụng từ Security Group của ALB. RDS nằm trong các private cơ sở dữ liệu subnet và không được public.

Bảng 3.1: Phạm vi và trạng thái hiện thực của mô hình

Nhóm	Trạng thái trong dự án	Cách trình bày
Ứng dụng Flask, RBAC, OTP, CSRF, kiểm tra file	Đã xây dựng và có kiểm thử	Thành phần hiện thực
Terraform, EC2, ALB, RDS, S3, IAM, CloudWatch	Đã khai báo bằng IaC và triển khai trong môi trường AWS thử nghiệm	Thành phần hiện thực; đối chiếu bằng log apply, AWS API và ảnh trạng thái tài nguyên
HTTPS, SES, AWS Backup, kiểm thử khôi phục	Có cấu hình tùy chọn	Chỉ ghi đã bật khi có bằng chứng thực tế
Redis, WAF, bộ quét mã độc, SIEM, Auto Scaling, S3 CRR	Chưa triển khai	Hướng phát triển, không xem là kết quả

3.2. Yêu cầu của mô hình

3.2.1. Yêu cầu chức năng

- Cho phép đăng ký, đăng nhập, đăng xuất và khôi phục mật khẩu bằng OTP.
- Cho phép người dùng tải lên, tải xuống, đánh dấu yêu thích, xóa mềm và khôi phục tài liệu.
- Cho phép chủ sở hữu chia sẻ quyền xem và thu hồi quyền chia sẻ tài liệu với người dùng khác.
- Cho phép quản trị viên quản lý tài khoản, vai trò, quyền, tài liệu và xem nhật ký hoạt động.
- Hỗ trợ lưu siêu dữ liệu trên SQLite hoặc MySQL và lưu nội dung tệp trên local filesystem hoặc Amazon S3.

3.2.2. Yêu cầu bảo mật

- Mật khẩu và OTP không được lưu ở dạng rõ; quá trình xác minh sử dụng giá trị băm do Werkzeug tạo ra.
- Các endpoint nhạy cảm phải có rate limit; tài khoản phải bị khóa tạm thời sau nhiều lần đăng nhập sai.
- Mọi request thay đổi dữ liệu sử dụng phiên cookie phải được bảo vệ bằng CSRF token.
- Quyền chức năng phải được xác minh bằng vai trò và quyền; quyền tài liệu phải

được xác minh bằng owner hoặc DocumentShare.

- Tập tải lên phải được kiểm tra phần mở rộng, MIME, chữ ký nội dung, cấu trúc tệp nén, kích thước, hạn mức lưu trữ và storage key.
- S3 phải private, bật mã hóa và từ chối insecure transport; RDS phải không mở công khai, mã hóa storage và yêu cầu secure transport.
- EC2 sử dụng IAM vai trò và temporary thông tin xác thực; không đưa AWS access key dài hạn vào source code hoặc container.
- Các thao tác quản trị và sự kiện xác thực quan trọng phải được ghi nhận mà không làm lộ mật khẩu, OTP hoặc secret.

3.2.3. Yêu cầu vận hành

- Ứng dụng có thể chạy local để phát triển và kiểm thử mà không phụ thuộc tài khoản AWS.
- Ứng dụng được đóng gói bằng Docker và chạy với Gunicorn; MySQL được tách thành container riêng trong môi trường Docker Compose.
- Schema cơ sở dữ liệu được quản lý bằng migration thay vì chỉnh sửa thủ công trong môi trường dùng chung.
- Hạ tầng AWS được khai báo bằng Terraform và có thể kiểm tra bằng fmt, validate, plan, integration test và smoke test.
- Quy trình CI/CD CI phải chạy kiểm thử Python, Bandit, pip-audit, Terraform validation và Trivy trước khi chấp nhận thay đổi.
- Kiến trúc mặc định ưu tiên chi phí đồ án: một EC2 và RDS Single-AZ; các khả năng có chi phí cao hơn phải được bật có chủ đích.

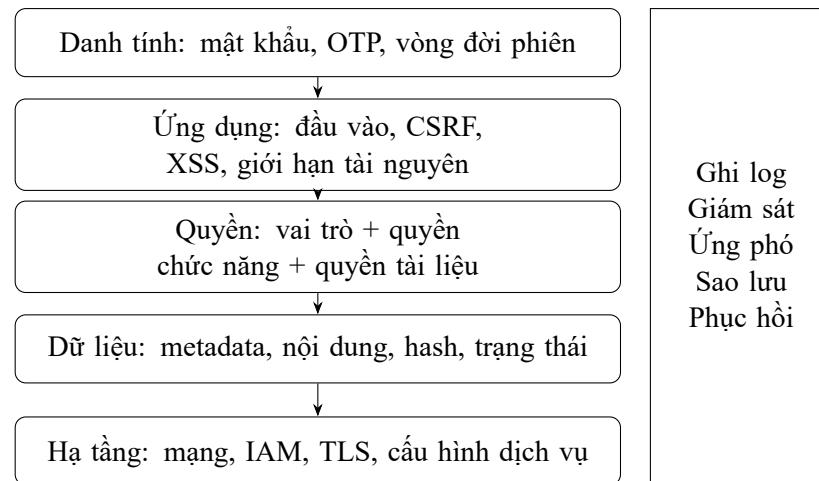
3.3. Kiến trúc tổng thể của mô hình

Kiến trúc gồm lớp danh tính, ứng dụng, kiểm soát truy cập, dữ liệu, hạ tầng và hai lớp xuyên suốt là giám sát cùng phục hồi. Các lớp không hoạt động độc lập: kết quả xác thực cung cấp chủ thể cho kiểm tra quyền; siêu dữ liệu xác định đối tượng; lớp lưu trữ thực hiện thao tác sau khi được cho phép. Điểm kiểm soát trọng tâm nằm trước thao tác với dữ liệu, không chỉ trước khi hiển thị giao diện. Route web và API phải dùng cùng chính sách nghiệp vụ; các thay đổi quyền cần có hiệu lực trên yêu cầu tiếp theo thay vì phụ thuộc vào giao diện còn đang mở.

3.4. Lớp bảo vệ danh tính

3.4.1. Bảo vệ mật khẩu

Mật khẩu được băm bằng thư viện chuyên dụng với salt và tham số chi phí. Cơ sở dữ liệu lưu giá trị xác minh, không lưu mật khẩu dạng rõ. Việc kiểm tra mật khẩu



Hình 3.1: Các lớp của mô hình bảo vệ đề xuất

phải thông qua hàm xác minh của thư viện, tránh tự so sánh giá trị băm theo một quy trình riêng.

Chính sách cần giới hạn độ dài phù hợp, hỗ trợ thông báo dễ hiểu và tránh ghi mật khẩu trong log. Khi thay đổi thuật toán hoặc tham số băm, có thể nâng cấp dữ liệu xác minh ở lần đăng nhập thành công kế tiếp. Mã nguồn cần ghi nhận chính xác thư viện và cơ chế thực tế để kiểm tra lại được.

3.4.2. Chống tấn công đăng nhập

Mô hình kết hợp giới hạn tốc độ theo nguồn với bộ đếm thất bại theo tài khoản. Phản hồi sai thông tin xác thực nên đồng nhất trong phạm vi có thể, còn sự kiện được ghi lại phục vụ phát hiện bất thường. Cơ chế khóa tạm thời phải có đường phục hồi cho người dùng hợp lệ.

Khi ứng dụng chạy bằng nhiều tiến trình hoặc nhiều máy chủ, bộ đếm yêu cầu cần được lưu ở nơi dùng chung. Nếu mỗi tiến trình đếm riêng, tổng số yêu cầu mà hệ thống chấp nhận có thể vượt giới hạn đã đặt. Vì vậy, cần chọn nơi lưu bộ đếm phù hợp trước khi mở rộng ứng dụng.

3.4.3. Khôi phục mật khẩu bằng OTP

OTP được sinh từ nguồn ngẫu nhiên phù hợp, gắn với tài khoản và mục đích khôi phục. Hệ thống lưu dữ liệu xác minh, thời hạn và số lần thử. Gửi mã mới phải làm rõ mã cũ còn hiệu lực hay không; gửi email thất bại không được biến thành đăng nhập hoặc hiển thị mã cho người không được phép.

Sau khi xác minh OTP, hệ thống cần cấp quyền đặt lại mật khẩu có thời hạn ngắn và chỉ dùng được một lần. Khi người dùng đặt mật khẩu mới, quyền này phải hết hiệu lực và các phiên đăng nhập cũ phải được thu hồi. Các bước cần được xử lý nhất quán để tránh trường hợp mật khẩu đã đổi nhưng quyền đặt lại hoặc phiên cũ vẫn còn dùng

được.

3.4.4. Bảo vệ phiên

Thiết lập phiên sau xác thực phải loại bỏ trạng thái không cần thiết trước đăng nhập. Cookie sử dụng HttpOnly và SameSite phù hợp; Secure được bật trong môi trường HTTPS. Chỉ nên lưu định danh tối thiểu, vì cookie ký không phải nơi giữ secret.

Mô hình sử dụng phiên bản phiên ở phía máy chủ để thu hồi hàng loạt sau đổi mật khẩu hoặc vô hiệu hóa tài khoản. Đối với đăng xuất, cần xác định mức bảo đảm: xóa cookie hiện tại hay vô hiệu mọi bản sao. Yêu cầu cao hơn cần cơ chế phiên phía máy chủ hoặc đánh dấu thu hồi phù hợp. Hướng dẫn Flask là nguồn tham chiếu cho các thuộc tính cookie và biện pháp bảo vệ web cơ bản. [21]

3.5. Lớp kiểm soát truy cập

3.5.1. Mô hình RBAC

Mỗi người dùng được gán một vai trò, còn mỗi vai trò có một tập quyền cụ thể. Cách tổ chức này cho phép điều chỉnh quyền mà không phải sửa logic của từng chức năng. Chẳng hạn, quyền xem tài liệu cho phép người dùng sử dụng chức năng xem, nhưng ứng dụng vẫn phải kiểm tra họ được xem những tài liệu nào.

Vai trò quản trị cần có tập quyền quản lý cụ thể. Thay đổi vai trò và quyền phải được kiểm tra phía máy chủ và ghi nhật ký. Việc ấn nút trên giao diện chỉ cải thiện trải nghiệm, không được xem là biện pháp thực thi quyền.

3.5.2. Kiểm soát quyền ở cấp tài liệu

Điều kiện tải xuống có thể biểu diễn như sau: người dùng đang hoạt động, phiên hợp lệ, có quyền xem, tài liệu chưa bị xóa, trạng thái phát hành phù hợp và người dùng là chủ sở hữu hoặc người nhận còn quyền. Khi bất kỳ điều kiện nào không đúng, yêu cầu bị từ chối.

Người nhận không được sửa chủ sở hữu, xóa tài liệu hoặc chia sẻ tiếp nếu chính sách không cho phép. Thu hồi quan hệ chia sẻ phải tác động đến yêu cầu mới. Nội dung đã được người nhận tải hợp lệ về thiết bị nằm ngoài khả năng thu hồi trực tiếp của ứng dụng; giới hạn này cần được hiểu trong nghiệp vụ chia sẻ.

3.5.3. Nguyên tắc đặc quyền tối thiểu

Quyền AWS của tiến trình giới hạn ở bucket, secret và log cần sử dụng. Tài khoản cơ sở dữ liệu của ứng dụng cần tách khỏi tài khoản thực hiện migration và tài khoản quản trị RDS. Quyền khởi tạo secret có thể cần lúc bootstrap nhưng không nhất thiết cần trong toàn bộ thời gian chạy web.

Bảng 3.2: Chính sách quyền tài liệu của mô hình

Thao tác	Chủ sở hữu	Người nhận	Người khác
Xem và tải nội dung	Có, nếu trạng thái hợp lệ	Có, khi còn chia sẻ	Không
Chia sẻ hoặc thu hồi	Có, khi có quyền	Không	Không
Xóa mềm và khôi phục	Có, khi có quyền	Không	Không
Đổi thuộc tính tài liệu	Trong phạm vi được thiết kế	Không mặc nhiên	Không

Đặc quyền tối thiểu phải được đánh giá theo vòng đời, không chỉ tại thời điểm cấp quyền. Khi bỏ một chức năng hoặc thay kiến trúc, cần thu hồi quyền không còn dùng. Các quyền ngoại lệ phải có lý do, người chịu trách nhiệm và thời điểm rà soát.

3.6. Lớp bảo vệ ứng dụng

3.6.1. Bảo vệ chống CSRF

Form và API sử dụng cookie phải gửi token CSRF được máy chủ kiểm tra. Các thao tác thay đổi dữ liệu sử dụng phương thức thích hợp và không dựa vào GET. Khi token thiếu hoặc sai, ứng dụng trả lỗi trước khi thực hiện nghiệp vụ.

Với giao diện JavaScript, token được lấy theo cơ chế của ứng dụng rồi gửi trong header. Kiểm thử cần xác nhận cả luồng hợp lệ và luồng bị từ chối, tránh chỉ kiểm tra token có xuất hiện trong HTML.

3.6.2. Bảo vệ chống XSS

Đầu ra được escape theo ngữ cảnh; hạn chế chèn trực tiếp dữ liệu vào mã JavaScript và thuộc tính có khả năng thực thi. Nội dung file được phục vụ dưới dạng tải xuống khi không có nhu cầu hiển thị trực tiếp. Tên tệp phải được xử lý như dữ liệu.

CSP sử dụng nonce cho script cần thiết và hạn chế nguồn tải ngoài. Nonce phải mới theo phản hồi và không bị tái sử dụng như một giá trị cố định. Chính sách style hoặc nguồn ngoài còn được cho phép cần được ghi nhận khi đánh giá mức chặt chẽ của cấu hình.

3.6.3. Bảo vệ chống SQL Injection

Lớp truy cập dữ liệu sử dụng ORM hoặc truy vấn tham số hóa. Các bộ lọc tìm kiếm được biểu diễn bằng toán tử của thư viện thay vì nối chuỗi. Những trường mang tính cấu trúc như tên cột sắp xếp được ánh xạ từ danh sách cố định.

Bảo vệ còn bao gồm ràng buộc khóa ngoại, duy nhất và kiểm tra lỗi giao dịch. Không trả chi tiết lỗi cơ sở dữ liệu cho trình duyệt. Khi cần ghi lỗi để chẩn đoán,

thông tin bí mật phải được loại bỏ.

3.6.4. Các header bảo mật HTTP

CSP kiểm soát nguồn tài nguyên; HSTS hướng trình duyệt tiếp tục sử dụng HTTPS; nosniff hạn chế suy đoán MIME; frame-ancestors và X-Frame-Options giới hạn nhúng trang. Referrer-Policy và Permissions-Policy giảm thông tin hoặc khả năng không cần thiết cung cấp cho trang.

Các header là lớp bổ trợ. HSTS chỉ có ý nghĩa khi được triển khai đúng trên HTTPS; việc thêm header trên môi trường không có chứng chỉ không tạo kết nối mã hóa. Kiểm thử cần đối chiếu nội dung header và điều kiện phát sinh thay vì chỉ tìm tên header.

3.7. Lớp bảo vệ tệp tải lên

Lớp tải lên áp dụng allowlist định dạng, giới hạn kích thước, chuẩn hóa tên, kiểm tra chữ ký/cấu trúc và lưu tệp ngoài vùng thực thi trực tiếp theo các nguyên tắc phòng vệ nhiều lớp cho chức năng tải tệp. [17] Luồng tải lên được chia thành nhận dữ liệu, xác minh quyền, kiểm tra định dạng, kiểm tra tài nguyên, lưu tạm, xử lý an toàn và phát hành. Allowlist bao gồm những loại cần cho nghiệp vụ; loại không được hỗ trợ bị từ chối. Tên hiển thị và khóa lưu trữ được tách biệt để tránh phụ thuộc vào đầu vào làm đường dẫn.

Kiểm tra tệp nén phải giới hạn số thành phần, kích thước khai báo, tỷ lệ nén và loại đường dẫn. Không cần giải nén nội dung trực tiếp vào vùng chạy ứng dụng. Nếu sau này cần xử lý sâu, công việc nên chạy trong môi trường tách biệt có giới hạn CPU, bộ nhớ và thời gian.

Mô hình đầy đủ có các trạng thái chờ kiểm tra, sạch, nhiễm hoặc thất bại. Chỉ trạng thái được chính sách cho phép mới được tải. Giá trị băm của nội dung gắn với kết quả kiểm tra để tránh dùng kết quả cũ cho tệp đã thay đổi. Phiên bản hiện tại chưa có bộ quét mã độc nên chưa đáp ứng đầy đủ phần thiết kế này.

3.8. Lớp bảo vệ dữ liệu lưu trữ

3.8.1. Bảo vệ siêu dữ liệu

Siêu dữ liệu được lưu trong cơ sở dữ liệu có ràng buộc về chủ sở hữu và quan hệ chia sẻ. Khóa duy nhất trên cặp tài liệu-người nhận ngăn bản ghi chia sẻ trùng. Truy vấn danh sách phải lọc ngay theo phạm vi người dùng để giảm khả năng vô tình trả dữ liệu thừa.

Giao dịch giúp giữ các thay đổi trong cơ sở dữ liệu nhất quán với nhau. Tuy nhiên, khi tệp được lưu ở một dịch vụ khác, cần xử lý cả trường hợp tệp đã lưu nhưng

bản ghi chưa được tạo, hoặc ngược lại. Có thể chạy tác vụ định kỳ để đối chiếu khóa lưu trữ với thông tin trong cơ sở dữ liệu, từ đó phát hiện tệp không có bản ghi tương ứng và bản ghi bị thiếu tệp.

3.8.2. Bảo vệ nội dung tệp

Kho local đặt ngoài vùng static và có quyền hệ điều hành hạn chế. Với S3, bucket riêng tư và ứng dụng truy cập bằng vai trò; người dùng cuối đi qua điểm kiểm tra quyền. Mã hóa lưu trữ giúp bảo vệ dữ liệu ở hạ tầng, nhưng quyền đọc vẫn phải chính xác.

Khi tải tệp, ứng dụng cần giới hạn tài nguyên và xử lý lỗi kho lưu trữ. Không nên trả đường dẫn vật lý hoặc thông tin xác thực cho người dùng. Các tệp tạm phục vụ tải xuống cần được xóa sau khi kết thúc phản hồi để tránh tích lũy dữ liệu.

3.8.3. Bảo vệ tính toàn vẹn

SHA-256 được tính từ nội dung đã nhận và lưu cùng siêu dữ liệu. Đối chiếu giá trị băm hữu ích khi xác minh phục hồi hoặc phát hiện lỗi truyền/lưu. Muốn phát hiện sửa đổi có chủ ý, cần bảo vệ cả giá trị tham chiếu và quyền cập nhật nó.

Ngoài giá trị băm, toàn vẹn còn dựa vào kiểm tra quyền sửa, ràng buộc dữ liệu và quy trình thay đổi. Không nên mô tả việc chỉ lưu giá trị băm là đã kiểm tra nội dung ở mọi lần tải xuống nếu mã nguồn chưa thực hiện bước đó.

3.9. Lớp bảo vệ hạ tầng AWS

Các kiểm soát hạ tầng được lựa chọn theo mô hình trách nhiệm chia sẻ và trụ cột bảo mật của AWS; trạng thái triển khai cụ thể được kiểm chứng ở Chương 4 và Chương 5. [3, 14]

3.9.1. Bảo vệ mạng

Phương án sử dụng ALB làm điểm vào, EC2 chạy ứng dụng và RDS đặt trong subnet dành cho cơ sở dữ liệu. Security group của EC2 chỉ nhận cổng ứng dụng từ security group của ALB; RDS chỉ nhận cổng MySQL từ nhóm ứng dụng. Quản trị máy chủ thông qua Systems Manager giúp giảm nhu cầu mở SSH.

Cấu hình TLS cần xem theo từng chặng. Trong bản thiết kế tăng cường, có thể mã hóa thêm kết nối ALB–EC2 khi yêu cầu bảo vệ nội bộ đòi hỏi. Chương 4 ghi nhận chính xác cấu hình hiện có để tránh nhầm lẫn giữa phương án mong muốn và trạng thái mã hạ tầng.

3.9.2. Bảo vệ Amazon S3

Bật Block Public Access, quản lý quyền sở hữu bucket, từ chối kết nối không an toàn và giới hạn vai trò vào bucket của ứng dụng. Versioning hỗ trợ khôi phục, còn

lifecycle kiểm soát thời gian giữ phiên bản cũ và tải lên chưa hoàn thành.

Chính sách xóa phải xét cả phiên bản lịch sử. Nếu cần ngăn xóa trong thời hạn bắt buộc, cần đánh giá Object Lock và quy trình quản trị tương ứng. Đây là yêu cầu bổ sung có tác động đến chi phí và khả năng xóa, không thể xem như một tùy chọn luôn phù hợp.

3.9.3. Bảo vệ Amazon RDS

RDS không công khai, sử dụng security group giới hạn nguồn, mã hóa storage và yêu cầu TLS. Tài khoản ứng dụng chỉ được thao tác trên dữ liệu phục vụ chức năng; tài khoản migration có quyền thay schema trong thời điểm triển khai.

Backup tự động và khả năng khôi phục theo thời điểm được cấu hình theo RPO/RTO đã lựa chọn. Phải diễn tập khôi phục vào môi trường mới, cập nhật kết nối và kiểm tra ứng dụng. Cấu hình Multi-AZ nếu được dùng phục vụ tính sẵn sàng, không thay thế bản sao lưu độc lập.

3.9.4. Bảo vệ Amazon EC2

EC2 sử dụng vai trò và thông tin xác thực tạm thời, yêu cầu IMDSv2, mã hóa đĩa và cập nhật phần mềm. Container chạy bằng người dùng không phải root; quyền đọc tệp cấu hình bị hạn chế. Chính sách network egress cần cân bằng bootstrap với vận hành lâu dài.

Nếu chỉ có một máy chủ chạy ứng dụng, sự cố ở máy đó có thể làm gián đoạn toàn bộ dịch vụ. Khi bổ sung máy chủ, cần xem lại cách chia sẻ phiên đăng nhập, bộ đếm yêu cầu, tác vụ nền và dữ liệu lưu trữ. Chỉ có ALB chưa đủ để tự động mở rộng hoặc duy trì dịch vụ khi máy chủ ứng dụng ngừng hoạt động.

3.9.5. Quản lý secret

Secret được cấp qua cấu hình môi trường hoặc kho bí mật; không đưa vào Git, image hay log. Cần biết tiến trình nào có quyền đọc, có thể đổi giá trị và cách ứng dụng nhận giá trị mới. Quyền sửa secret được tách khỏi quyền chỉ sử dụng khi có thể.

Cấu hình bằng biến môi trường phù hợp với container nhưng không phải cơ chế mã hóa. Nếu secret được ghi xuống tệp lúc khởi động, tệp đó cần quyền truy cập hạn chế và không nằm trong gói phân phối. Việc quay vòng secret phải được kiểm thử để không làm gián đoạn dịch vụ ngoài dự kiến.

3.10. Lốp ghi log và giám sát

Nhật ký nghiệp vụ ghi thời điểm, chủ thể, thao tác, đối tượng và kết quả. Các sự kiện ưu tiên gồm đăng nhập thất bại, reset mật khẩu, thay vai trò, thay quyền, vô hiệu hóa tài khoản và thay quyền chia sẻ. Mã tương quan giúp đối chiếu sự kiện giữa ứng

dụng và dịch vụ.

Giám sát cần biến dấu vết thành điều kiện cảnh báo có người tiếp nhận. Các cảnh báo tài nguyên như CPU và dung lượng giúp vận hành nhưng không thay thế cảnh báo hành vi như nhiều lần từ chối tải tài liệu. Log không chứa mật khẩu, OTP, token hay khóa bí mật; quyền xóa log phải được kiểm soát riêng.

3.11. Lớp sao lưu và phục hồi

Phương án sao lưu phải bao phủ cả siêu dữ liệu và nội dung. Với local, cần sao lưu SQLite bằng cơ chế nhất quán và sao lưu thư mục tệp theo thời điểm phù hợp. Với AWS, kết hợp backup RDS với phiên bản S3 và manifest hoặc quy trình đối soát để biết tập tệp tương ứng.

RPO và RTO là mục tiêu cần được chủ hệ thống lựa chọn. Trong phạm vi này chưa có thực nghiệm phục hồi toàn hệ thống nên không gán số đo đạt được. Quy trình đề xuất gồm dừng hoặc hạn chế ghi, chọn điểm phục hồi, khôi phục vào môi trường riêng, xác minh quyền và nội dung, sau đó mới chuyển sử dụng.

3.12. Bảo mật quá trình phát triển và triển khai

Mã nguồn và cấu hình được quản lý bằng Git, thay đổi được kiểm tra trước khi đưa vào nhánh triển khai. Unit test và integration test phát hiện sai hành vi; Bandit tìm một số mẫu mã có rủi ro; pip-audit đối chiếu thư viện phụ thuộc với dữ liệu lỗ hổng; Trivy kiểm tra image và cấu hình. Các công cụ bổ sung cho nhau và đều có giới hạn.

Quy trình CI/CD cần dừng khi vi phạm ngưỡng đã đặt, lưu phiên bản công cụ và kết quả. Ngoại lệ phải có phạm vi, lý do và thời hạn. Credential triển khai ngắn hạn giảm việc lưu khóa dài hạn, nhưng trust policy của CI/CD vẫn phải giới hạn đúng repository, nhánh và môi trường.

3.13. Luồng hoạt động của mô hình

3.13.1. Luồng đăng nhập an toàn

Ứng dụng nhận thông tin qua kết nối phù hợp, kiểm tra giới hạn tốc độ rồi xác minh tài khoản và mật khẩu. Khi thất bại, bộ đếm được cập nhật và phản hồi không tiết lộ dữ liệu nhạy cảm. Khi thành công, trạng thái phiên được khởi tạo với định danh và phiên bản hiện tại; quyền được kiểm tra lại ở các yêu cầu sau.

3.13.2. Luồng tải lên an toàn

Sau xác thực và quyền, ứng dụng kiểm tra tên, loại, kích thước, nội dung đặc trưng và hạn mức lưu trữ. Khóa lưu trữ được sinh, giá trị băm được tính, tệp được ghi và siêu dữ liệu được lưu. Nếu siêu dữ liệu thất bại sau khi đã ghi tệp, hệ thống thực

hiện bù trừ và ghi nhận phần dọn dẹp chưa thành công.

Đối với mô hình có bộ quét, tệp ở trạng thái cách ly cho đến khi có kết quả gắn với đúng nội dung. Quy trình phải xử lý cả tình huống dịch vụ quét không khả dụng. Không tự chuyển lỗi quét thành kết quả sạch để duy trì tính tiện dụng.

3.13.3. Luồng tải xuống an toàn

Ứng dụng xác minh phiên và quyền xem, truy vấn tài liệu theo quan hệ sở hữu/chia sẻ, kiểm tra trạng thái xóa và trạng thái phát hành. Chỉ sau các bước đó mới đọc tệp. Không tìm thấy tệp hoặc lỗi lưu trữ được chuyển thành phản hồi phù hợp và dấu vết vận hành.

Quyền được đánh giá tại thời điểm xử lý yêu cầu. Một tải xuống đang truyền dữ liệu có thể không bị cắt ngay khi chia sẻ bị thu hồi; đây là khác biệt giữa ngăn yêu cầu mới và thu hồi nội dung đã cấp. Yêu cầu nghiệp vụ cần xác định mức bảo đảm mong muốn.

3.13.4. Luồng khôi phục mật khẩu

Yêu cầu được tiếp nhận với phản hồi hạn chế tiết lộ tài khoản. OTP được sinh, lưu dữ liệu xác minh và gửi qua kênh đã cấu hình. Xác minh thành công tạo quyền đặt lại mật khẩu ngắn hạn; thay đổi mật khẩu đồng thời tiêu thụ quyền này và tăng phiên bản phiên. Người dùng sau đó đăng nhập lại bằng thông tin mới.

3.14. Ma trận nguy cơ và biện pháp bảo vệ

Bảng 3.3: Truy vết từ nguy cơ đến phương pháp xác minh

Nguy cơ	Lớp bảo vệ	Thành phần dự kiến	Phương pháp kiểm tra
R01	Danh tính	Hàm xác thực, limiter, bộ đếm	Đăng nhập sai và vượt ngưỡng
R02–03	Kiểm soát truy cập	Decorator, owner, quan hệ chia sẻ	Người khác tải/xóa; user gọi admin
R04, R13	Phiên và khôi phục	Phiên version, OTP, reset một lần	Cookie cũ, OTP hết hạn và dùng lại
R05–06	Tải lên	Validator, hạn mức lưu trữ, bộ quét	Định dạng sai, nén bất thường, trạng thái
R07–08	Hạ tầng và bí mật	Policy S3, SG, IAM, secret	Đối chiếu cấu hình và thử trên môi trường riêng
R09	Dữ liệu, phục hồi	Giao dịch, bù trừ, backup	Giả lập lỗi ghi, phục hồi và đối soát

Nguy cơ	Lớp bảo vệ	Thành phần dự kiến	Phương pháp kiểm tra
R10	Ứng dụng	CSRF, template, CSP	Thiếu token, kiểm tra đầu ra và header
R11	Phát triển	CI, khóa thư viện phụ thuộc và image	Chạy công cụ và kiểm tra bước kiểm tra bảo mật
R12	Giám sát	Nhật ký kiểm toán, tập trung log	Hành động nhạy cảm và quyền sửa log
R14	Vận hành	Health check, backup, dự phòng	Gián đoạn có kiểm soát và diễn tập restore

3.15. Kết luận chương

Mô hình chuyển mục tiêu bảo vệ thành điều kiện kiểm soát tại từng bước xử lý. Điểm cốt lõi là kết hợp RBAC với quyền cấp tài liệu, kiểm tra tải lên với quản lý trạng thái và sao lưu với phục hồi có kiểm chứng. Ma trận truy vết tạo cơ sở để đánh giá hiện thực ở chương tiếp theo, đồng thời giữ rõ những yêu cầu chưa được đáp ứng đầy đủ.

CHƯƠNG 4. XÂY DỰNG HỆ THỐNG CLOUDBOX

Chương này mô tả hiện thực từ cấu trúc mã nguồn, các hàm xử lý, môi trường Docker và hạ tầng AWS đi kèm. Tên dự án trong mã nguồn là `cloud-security-project`, còn tên ứng dụng là CloudBox. Phần mô tả cấu hình được đối chiếu với mã nguồn; phần kết quả triển khai được đối chiếu với lần chạy Docker trên máy ảo Ubuntu và lần áp dụng Terraform trong môi trường AWS thử nghiệm. Những dịch vụ tùy chọn không có bằng chứng được giữ ở trạng thái đề xuất hoặc chưa xác nhận.

4.1. Giới thiệu hệ thống CloudBox

CloudBox là ứng dụng web quản lý tài liệu cá nhân và chia sẻ cho tài khoản khác. Người dùng thao tác qua giao diện HTML hoặc API; quản trị viên có khu vực quản lý riêng. Hệ thống liên kết nội dung tài liệu với chủ sở hữu, trạng thái và danh sách người nhận trong cơ sở dữ liệu.

Phạm vi hiện thực bao gồm xác thực, khôi phục mật khẩu, phân quyền, vòng đời tài liệu, lưu trữ local/S3 và một phần nhật ký hoạt động. Bộ kiểm thử cho phép tái lập các tình huống chấp nhận và từ chối truy cập. Docker Compose cung cấp môi trường Flask/Gunicorn–MySQL trên Ubuntu; Terraform tạo hạ tầng AWS để kiểm chứng các kiểm soát mạng, danh tính, lưu trữ và giám sát ở môi trường Cloud.

4.2. Công nghệ sử dụng

Python và Flask đảm nhiệm xử lý HTTP; Jinja dựng giao diện; SQLAlchemy biểu diễn model và truy vấn; Flask-Migrate quản lý migration. Flask-WTF cung cấp CSRF và Flask-Limiter cung cấp giới hạn tốc độ. Boto3 là lớp giao tiếp AWS. Phiên bản được khóa trong tệp thư viện phụ thuộc nhằm giảm khác biệt giữa các lần cài đặt. Bảng phản ánh khai báo của dự án, không phải khuyến nghị rằng đây luôn là phiên bản mới nhất. SQLite được dùng cho thử nghiệm cục bộ; MySQL 8.4 được khai báo trong môi trường container và RDS. Bộ kiểm thử trên Ubuntu sử dụng Python 3.14, thể hiện qua đường dẫn thư viện trong log; image Docker khai báo Python 3.12. Đây là hai môi trường thực thi riêng.

4.3. Kiến trúc hệ thống

4.3.1. Kiến trúc ứng dụng

Hàm `create_app` trong tệp `app/app.py` thực hiện khởi tạo ứng dụng Flask, nạp cấu hình, gắn các extension và đăng ký các Blueprint. Nhóm route gồm các chức năng xác thực, quản lý tài liệu, chia sẻ, quản trị và API. Nhóm service xử lý xác thực, OTP,

Bảng 4.1: Một số phiên bản khóa trong mã nguồn

Thành phần	Phiên bản	Vai trò
Flask	3.1.3	Ứng dụng web và Blueprint
Flask-SQLAlchemy	3.1.1	Tích hợp ORM với Flask
SQLAlchemy	2.0.52	Model, phiên và truy vấn
Werkzeug	3.1.8	Băm mật khẩu và tiện ích HTTP
Flask-WTF	1.3.0	Bảo vệ CSRF
Flask-Limiter	4.1.1	Giới hạn tốc độ yêu cầu
Flask-Migrate	4.1.0	Migration schema
PyMySQL	1.2.0	Kết nối MySQL
Boto3	1.43.89	Giao tiếp dịch vụ AWS
Gunicorn	26.2.0	WSGI server trong container

email, vòng đời tài liệu và lưu trữ. Các model tập trung mô tả cấu trúc dữ liệu và các mối quan hệ trong cơ sở dữ liệu.

Cách phân chia này giúp route đảm nhiệm việc tiếp nhận yêu cầu và tạo phản hồi, trong khi service xử lý logic nghiệp vụ dùng chung. Ví dụ, chức năng tải tài liệu lên từ giao diện web và từ API có thể sử dụng chung dịch vụ tạo tài liệu. Tuy nhiên, từng route vẫn phải kiểm tra xác thực, quyền và quyền đối với tài liệu trước khi gọi service.

Bảng 4.2: Phân chia trách nhiệm các thư mục

Thư mục	Nội dung và trách nhiệm
app/routes	Nhận yêu cầu, kiểm tra truy cập và tạo phản hồi
app/services	Nghiệp vụ xác thực, tài liệu, OTP và kho lưu trữ
app/models	Tài khoản, vai trò, tài liệu, chia sẻ, OTP và log
app/templates, static	Giao diện Jinja, CSS và JavaScript
migrations	Các phiên bản thay đổi schema
tests, security	Kiểm thử và mô-đun kiểm tra bảo mật
docker, terraform	Cấu hình đóng gói và hạ tầng
scripts	Sao lưu, smoke test và kiểm tra tích hợp

4.3.2. Kiến trúc local

Ứng dụng dùng SQLite khi không có URL cơ sở dữ liệu ngoài và lưu nội dung trong thư mục tải lên được cấu hình. Cơ chế tự tạo schema mặc định bật cho SQLite, thuận tiện cho môi trường phát triển. Các bài kiểm thử tạo dữ liệu riêng trong thư mục tạm, không phụ thuộc cơ sở dữ liệu sử dụng thật.

Lưu trữ cục bộ không đồng nghĩa dữ liệu được mã hóa. Quyền tệp và mã hóa ổ đĩa thuộc môi trường chạy, chưa được một hàm lưu tệp thông thường bảo đảm. Do

đó, báo cáo chỉ ghi nhận kiểm tra đường dẫn và kiểm soát truy cập qua ứng dụng cho môi trường này.

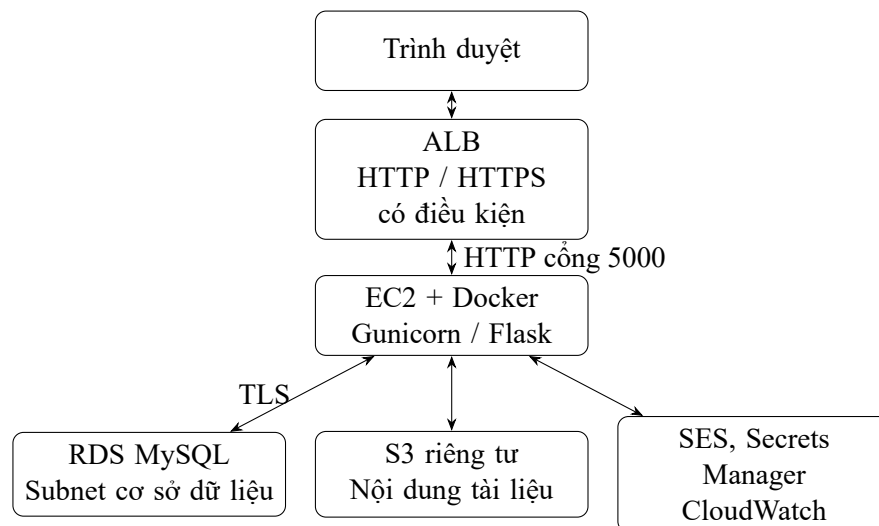
4.3.3. Kiến trúc Docker

Dockerfile sử dụng Python 3.12 slim với digest cố định, cài thư viện phụ thuộc và chạy bằng người dùng ứng dụng không phải root. Gunicorn được cấu hình hai worker, mỗi worker bốn thread. Health check gọi HTTP vào ứng dụng để kiểm tra khả năng trả lời.

Compose khai báo MySQL, dịch vụ migration và dịch vụ web với volume dữ liệu. Profile tích hợp có thêm web thứ hai để phục vụ kiểm tra chia sẻ dữ liệu giữa instance. Tuy nhiên, limiter mặc định vẫn dùng bộ nhớ; hai worker ngay trong một container đã có thể sở hữu bộ đếm riêng. Đây là giới hạn hiện hữu trước cả khi mở rộng nhiều máy.

4.3.4. Kiến trúc AWS

Terraform khai báo ALB ở hai public subnet, một EC2 ở public subnet đầu tiên và RDS trong nhóm subnet cơ sở dữ liệu. EC2 có địa chỉ công khai nhưng cổng 5000 chỉ nhận từ ALB theo security group. S3 lưu nội dung, RDS lưu siêu dữ liệu; SES gửi OTP khi được cấu hình, còn Secrets Manager và CloudWatch hỗ trợ vận hành. HTTPS ở ALB phụ thuộc cấu hình chứng chỉ và tên miền. Chặng ALB tới target ứng



Hình 4.1: Kiến trúc CloudBox được khai báo và triển khai bằng Terraform trên AWS

dụng sử dụng HTTP cổng 5000 theo cấu hình hiện tại. Không có cơ sở để gọi toàn bộ đường truyền là TLS đầu cuối hoặc kiến trúc này là nhiều instance có tính sẵn sàng cao.

4.4. Phân tích chức năng hệ thống

4.4.1. Chức năng xác thực

Hệ thống có đăng ký, đăng nhập, đăng xuất bằng POST và khôi phục mật khẩu qua OTP. Tên đăng nhập được kiểm tra độ dài 6–24 ký tự cùng các điều kiện ký tự của dự án; email được chuẩn hóa; mật khẩu được kiểm tra trước khi bấm. Đăng nhập chấp nhận tên đăng nhập hoặc email không phân biệt hoa thường.

Đăng ký trùng trả lỗi phù hợp và rollback giao dịch. Kiểm tra tên đăng nhập khả dụng hỗ trợ giao diện nhưng chủ động tiết lộ một phần thông tin tồn tại tài khoản. Đây là hành vi thiết kế cần được cân nhắc nếu triển khai cho dữ liệu nhạy cảm.

4.4.2. Chức năng quản lý tài liệu

Người dùng xem danh sách, tải lên, tải xuống, đánh dấu yêu thích, chuyển vào thùng rác và khôi phục. Xóa mềm cập nhật cờ và thời điểm xóa; nội dung chưa bị xóa ngay. Lệnh dọn thùng rác xóa vĩnh viễn các bản ghi đủ thời gian giữ và dọn object tương ứng theo cơ chế cố gắng hoàn thành.

Hạn mức lưu trữ tính cả dữ liệu đang ở thùng rác. Điều này phản ánh dung lượng thực tế, nhưng ứng dụng chưa có cơ chế giữ chỗ nguyên tử cho nhiều tải lên đồng thời. Khôi phục tài liệu không phải phục hồi từ backup; nó chỉ đổi trạng thái của nội dung còn được giữ.

4.4.3. Chức năng chia sẻ

Chủ sở hữu có quyền chia sẻ được tìm người nhận, tạo quan hệ và thu hồi. Khóa duy nhất trên cặp tài liệu–người nhận hạn chế trùng lặp. Người nhận được xem hoặc tải khi quan hệ còn hiệu lực, không tự có quyền xóa tài liệu.

Các route kiểm tra tài liệu thuộc chủ sở hữu trước khi sửa danh sách chia sẻ. Kiểm thử cần đối chiếu sau thu hồi để xác nhận quyền không chỉ bị ẩn trên giao diện. Hệ thống không cung cấp cơ chế thu hồi bản sao đã được tải về hợp lệ.

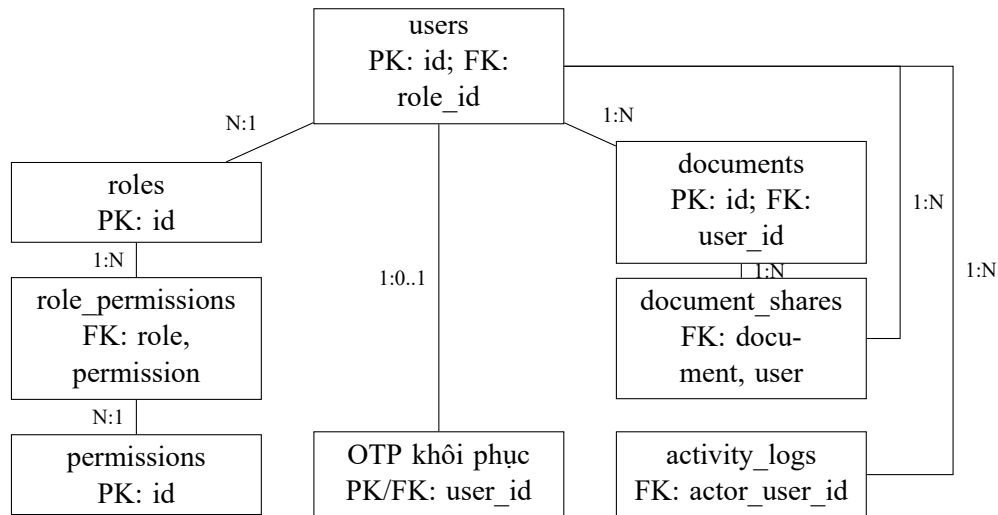
4.4.4. Chức năng quản trị

Khu vực quản trị bao gồm tài khoản, trạng thái hoạt động, vai trò, quyền, siêu dữ liệu tài liệu và nhật ký hoạt động. Mã nguồn có kiểm soát một số hành động tự quản lý nguy hiểm và bảo vệ vai trò mặc định. Quyền vào trang quản trị được thực hiện ở phía máy chủ.

Chức năng quản trị tài liệu được tách khỏi luồng tải nội dung của người dùng. Bộ kiểm thử kiểm tra quản trị viên không có nút tải nội dung trong trang quản trị và không mặc nhiên sử dụng workspace như người dùng thường. Sự tách biệt này giúp làm rõ ranh giới quản trị với quyền dữ liệu cá nhân.

4.5. Thiết kế cơ sở dữ liệu

Mô hình có tám bảng chính: users, roles, permissions, role_permissions, documents, document_shares, password_reset_otps và activity_logs. Mỗi user thuộc một vai trò; vai trò liên kết nhiều quyền qua bảng trung gian. Một tài liệu có một chủ sở hữu và có thể được chia sẻ cho nhiều user. Mã nguồn cung cấp ba phiên bản migra-



Hình 4.2: Quan hệ dữ liệu chính của CloudBox (sơ đồ rút gọn)

Bảng 4.3: Các trường phục vụ bảo vệ dữ liệu

Bảng	Trường và ý nghĩa
users	password lưu giá trị băm; is_active; failed_login_attempts; locked_until; session_version
documents	storage_key, user_id, file_size, content_type, sha256, scan_status, is_deleted, deleted_at
document_shares	document_id và shared_with_user_id; cặp giá trị là duy nhất
password_reset_otps	user_id, otp_hash, expires_at và attempts
activity_logs	actor_user_id, action, target_type, target_id, details, created_at

tion và lớp tương thích SQLite cũ. Môi trường ngoài SQLite mặc định không tự tạo schema mà yêu cầu chạy migration. Điều này giảm việc tiến trình web tự ý thay đổi cấu trúc dữ liệu khi khởi động.

Bảng nhật ký hoạt động giữ định danh đối tượng theo dạng loại và mã; liên kết đến tài khoản có thể được đặt rỗng khi tài khoản bị xóa. Đây là lựa chọn giúp lưu lại sự kiện, nhưng dữ liệu log vẫn nằm trong cùng hệ quản trị nên chưa đạt tính bất biến trước người có quyền quản trị cơ sở dữ liệu.

4.6. Hiện thực xác thực và quản lý phiên

Dịch vụ xác thực tìm tài khoản, kiểm tra khóa tạm thời, xác minh mật khẩu và kiểm tra trạng thái hoạt động. Mã nguồn sử dụng hàm băm/xác minh của Werkzeug. Chính sách mặc định yêu cầu tối thiểu 12 ký tự; kiểm thử một số chức năng hạ ngưỡng để tạo dữ liệu thử, vì vậy cấu hình test không được đồng nhất với cấu hình mặc định.

Sau năm lần thất bại, tài khoản được đặt thời hạn khóa 15 phút. Route đăng nhập có giới hạn năm yêu cầu mỗi phút. Hai cơ chế khác nhau: bộ đếm thất bại gắn với tài khoản trong cơ sở dữ liệu, còn limiter mặc định dùng `memory://`. Thông báo sai tài khoản/mật khẩu được dùng chung, nhưng trạng thái bị khóa và vô hiệu hóa có phản hồi riêng.

Khi đăng nhập thành công, `session.clear()` loại bỏ trạng thái cũ và lưu định danh, tên người dùng, phiên bản phiên. Tùy chọn ghi nhớ dùng thời hạn cấu hình 30 ngày. Mỗi yêu cầu kiểm tra tài khoản còn tồn tại, còn hoạt động và phiên bản trong cookie khớp với cơ sở dữ liệu.

Đổi mật khẩu làm tăng `session_version` nên các phiên cũ bị từ chối ở yêu cầu tiếp theo. Đăng xuất hiện chỉ xóa phiên ở phía phản hồi; chưa có danh sách thu hồi từng cookie đã sao chép. Flask mặc định sử dụng cookie có chữ ký, không phải một mã phiên ngẫu nhiên trở đến kho server; vì vậy không mô tả `session.clear()` như cơ chế thay mã định danh phiên phía máy chủ.

4.7. Hiện thực khôi phục mật khẩu bằng OTP

OTP gồm sáu chữ số được sinh bằng `secrets.randbelow`, băm bằng Werkzeug và lưu theo user. Thời hạn là 120 giây, số lần thử sai tối đa ba. Bản ghi hiện tại được thay khi sinh mã mới. Email có các chế độ local, SMTP, SES hoặc tắt theo cấu hình.

Khi gửi email thất bại, route xóa OTP và dùng trạng thái không hợp lệ, tránh tiếp tục như đã gửi thành công. Khi xác minh OTP đúng, phiên lưu quyền chuyển sang trang đặt lại mật khẩu. Sau khi thay đổi thành công, ứng dụng tăng phiên bản phiên và xóa OTP.

Điểm chưa hoàn thiện nằm ở giai đoạn sau xác minh: mã nguồn chưa thể hiện hạn sử dụng riêng và token một lần phía máy chủ cho `reset_verified_user_id`. Chỉ xóa trường này ở phản hồi thành công không đủ chứng minh mọi bản sao cookie đã được thu hồi. Cần bổ sung trạng thái giao dịch reset ở cơ sở dữ liệu và kiểm thử hết hạn, dùng lại, cũng như các yêu cầu đồng thời.

4.8. Hiện thực RBAC

Dữ liệu tham chiếu có vai trò admin và user cùng chín quyền: xem, tạo, sửa, xóa, chia sẻ tài liệu; quản lý người dùng; quản lý vai trò; xem báo cáo; quản lý hệ

thống. Các decorator kiểm tra đăng nhập, vai trò hoặc quyền trước khi gọi hàm xử lý.

Quyền được truy vấn qua quan hệ role–permission trong cơ sở dữ liệu. API trả lỗi JSON với mã 401 hoặc 403 khi phù hợp; giao diện có thể chuyển về đăng nhập hoặc trả trang lỗi. Vai trò mặc định được bảo vệ khi xóa; các thay đổi quyền quan trọng có sự kiện nhật ký ở khu vực quản trị.

Một quyền có tên chỉnh sửa tài liệu không có nghĩa ứng dụng đã cung cấp trình soạn thảo nội dung tệp. Trong phiên bản hiện tại, cần đọc endpoint cụ thể để biết quyền được dùng cho thao tác nào, chẳng hạn cập nhật trạng thái yêu thích. Báo cáo không suy rộng chức năng từ tên quyền.

4.9. Hiện thực kiểm soát tài liệu

Hàm truy vấn tài liệu có thể truy cập tại API kết hợp mã tài liệu, trạng thái chưa xóa và điều kiện chủ sở hữu hoặc tồn tại quan hệ chia sẻ. Không thỏa điều kiện trả 404 với thông báo chung. Các route xóa, khôi phục và thay thuộc tính kiểm tra riêng chủ sở hữu.

Trước tải xuống, `ensure_document_downloadable` từ chối trạng thái pending bằng lỗi tương ứng và từ chối infected hoặc failed. Tuy nhiên, trạng thái `not_scanned` vẫn được phép tải. Tài liệu mới được tạo với trạng thái này, do đó không thể kết luận mọi tệp được tải xuống đều đã được quét.

Việc sử dụng storage key ngẫu nhiên giảm phụ thuộc vào tên gốc, nhưng quyền vẫn được kiểm tra từ siêu dữ liệu. Đây là sự kết hợp giữa tránh trùng khóa và thực thi quyền, không phải lấy tính khó đoán làm cơ chế bảo mật duy nhất.

4.10. Hiện thực kiểm tra tệp tải lên

Hàm validator chuẩn hóa tên bằng `secure_filename`, yêu cầu phần mở rộng trong allowlist và giới hạn tên sau chuẩn hóa không quá 180 ký tự. Các loại hỗ trợ gồm PDF, TXT, CSV, PNG, JPG/JPEG, DOCX, XLSX, PPTX và ZIP. MIME được đối chiếu với bảng cho phép; một số dạng ZIP/Office chấp nhận MIME nhị phân chung.

Các tệp PDF, PNG, JPEG và ZIP được kiểm tra chữ ký đầu tệp. TXT/CSV bị từ chối khi phần đầu chứa byte rỗng. Office được kiểm tra như tệp nén có thành phần định dạng và thư mục tương ứng. Những kiểm tra này có phạm vi cụ thể: kiểm tra đầu tệp hoặc danh mục tệp nén, không phân tích ngữ nghĩa toàn bộ nội dung.

Archive bị từ chối nếu chứa đường dẫn tuyệt đối, thành phần vượt thư mục, dấu phân cách không được chấp nhận, symbolic link hoặc mã hóa không được hỗ trợ. Các ngưỡng mặc định là 1.000 mục, tổng kích thước giải nén khai báo 128 MiB và tỷ lệ nén 100. Các ngưỡng có thể cấu hình, cần điều chỉnh theo nhu cầu và kiểm thử khi thay đổi.

Giới hạn request mặc định là 16 MiB và hạn mức lưu trữ người dùng 500 MiB. Tập rỗng bị từ chối. Giá trị băm SHA-256 được tính theo khối 1 MiB, sau đó stream được đưa về vị trí phù hợp. Khóa lưu có cấu trúc theo user, UUID và tên đã chuẩn hóa.

Dịch vụ ghi nội dung trước rồi commit siêu dữ liệu. Nếu commit thất bại, hàm rollback cơ sở dữ liệu và cố xóa nội dung vừa lưu. Nếu bước dọn tập cũng lỗi, hệ thống ghi log; chưa có hàng đợi đối soát tự động. Đây là cơ chế bù trừ, không phải giao dịch nguyên tử xuyên S3 và RDS.

4.11. Hiện thực các biện pháp bảo mật web

Flask-WTF bảo vệ CSRF toàn ứng dụng theo cấu hình. Handler riêng trả lỗi cho token không hợp lệ, giới hạn tốc độ và request quá lớn. Nonce được sinh ở mỗi request rồi sử dụng trong CSP cho script; chính sách vẫn cho phép style inline và nguồn phong được cấu hình.

Header phản hồi gồm CSP, nosniff, X-Frame-Options, Referrer-Policy và Permissions-Policy. HSTS chỉ được thêm khi request được nhận diện là secure. ProxyFix tin một proxy cho địa chỉ và giao thức, do đó môi trường chạy trực tiếp cần kiểm soát việc tiếp nhận header forwarded. Trên phương án AWS, security group giới hạn nguồn ALB là điều kiện quan trọng của giả định này.

Các truy vấn nghiệp vụ chủ yếu dùng biểu thức SQLAlchemy. Tuy vậy, kết quả rà soát ORM không thay thế kiểm tra mọi đường truy vấn và lỗi logic. Các phép kiểm thử chức năng hiện có cung cấp bằng chứng cho từng tình huống, không phải một chứng nhận loại bỏ hoàn toàn SQL Injection hay XSS.

4.12. Hiện thực lưu trữ dữ liệu

4.12.1. Môi trường local

Hàm kiểm tra storage key từ chối khóa tuyệt đối, ký tự rỗng, đường dẫn không chuẩn và thành phần vượt thư mục. Đường dẫn thực được phân giải rồi kiểm tra còn nằm trong tải lên root. Đây là lớp phòng vệ bổ sung ngoài chuẩn hóa tên tệp lúc tải lên.

Database lưu khóa tệp tách khỏi tên hiển thị. Thuộc tính tương thích cho phép đọc dữ liệu cũ chưa có storage key. SQLite sử dụng cấu hình phù hợp cho môi trường cục bộ; việc chuyển sang MySQL cần migration và kiểm thử riêng về kiểu dữ liệu, ràng buộc và đồng thời.

4.12.2. Môi trường AWS

Khi có tên bucket, dịch vụ lưu trữ dùng Boto3 upload/download/delete với cùng giao diện nghiệp vụ. Tải lên yêu cầu SSE-S3 bằng giá trị AES256 và gán ContentType. Tải xuống đọc object về tệp tạm rồi trả qua ứng dụng, giữ điểm kiểm tra quyền trước khi cấp nội dung.

Config hỗ trợ MySQL qua URL hoặc các biến kết nối và cấu hình chứng chỉ CA cho TLS. Trong template khởi động AWS, thông tin DB lấy từ secret quản lý mật khẩu master của RDS. Vì vậy, bản hiện thực chưa đáp ứng mục tiêu dùng tài khoản ứng dụng chỉ có quyền cần thiết; cần tách thông tin xác thực dùng khi cập nhật cấu trúc dữ liệu và khi chạy ứng dụng trước khi nâng mức sử dụng.

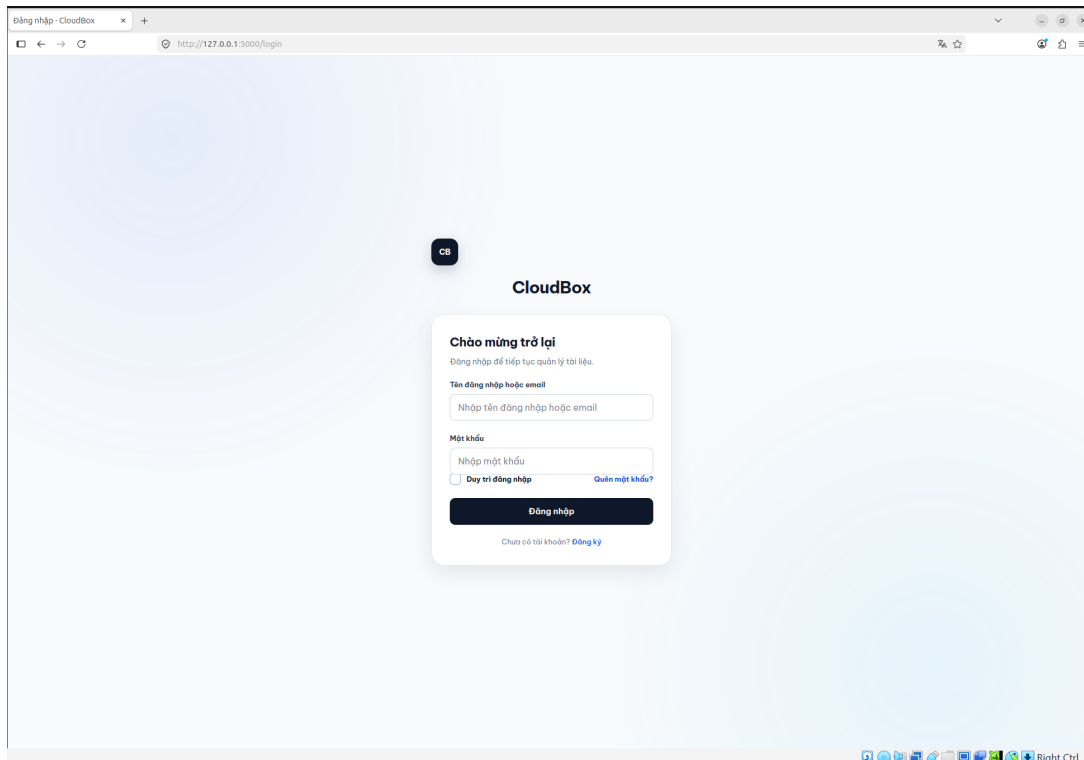
4.13. Docker hóa hệ thống

Image được xây từ thư viện phụ thuộc đã khóa, chạy Gunicorn và không giữ công cụ cài package trong runtime theo Dockerfile. Compose sử dụng health check cho cơ sở dữ liệu và dịch vụ migration để chuẩn bị schema trước khi web hoạt động. Volume giữ dữ liệu qua vòng đời container.

Máy ảo Ubuntu trên VirtualBox được sử dụng để kiểm thử Docker/MySQL. Hình 4.3 ghi nhận Docker 29.7.2, Docker Compose v5.5.0 và hai dịch vụ MySQL, web đều ở trạng thái healthy. Cổng 5000 được ánh xạ đến dịch vụ web; cổng MySQL chỉ được công bố trên loopback của máy ảo. Hình 4.4 thể hiện trang đăng nhập được truy cập bằng trình duyệt trong máy ảo tại <http://127.0.0.1:5000/login>. Các ảnh xác nhận trạng thái dịch vụ và truy cập giao diện tại thời điểm chụp; phép thử lưu dữ liệu qua khởi động lại cần bằng chứng riêng.

```
minh@localhost:~/cloud-security-project$ docker --version
Docker version 29.7.2, build a7dcaao
minh@localhost:~/cloud-security-project$ docker compose version
Docker Compose version v5.5.0
minh@localhost:~/cloud-security-project$ docker compose --env-file .env -f docker/docker-compose.yml ps
NAME                IMAGE              COMMAND                  SERVICE  CREATED      STATUS      PORTS
docker-db-1         mysql:8.4          "docker-entrypoint.s..." db       11 days ago  Up 14 minutes (healthy)  127.0.0.1:3306->3306/tcp, 33060/tcp
docker-web-1        cloud-security-app:local "sh -c 'exec gunicor..." web      10 minutes ago Up 9 minutes (healthy)  0.0.0.0:5000->5000/tcp, [::]:5000->5000/tcp
minh@localhost:~/cloud-security-project$
```

Hình 4.3: Phiên bản Docker, Compose và trạng thái dịch vụ trên máy ảo Ubuntu



Hình 4.4: Giao diện đăng nhập CloudBox trong máy ảo Ubuntu VirtualBox

4.14. Xây dựng hạ tầng AWS bằng Terraform

4.14.1. Cấu trúc hạ tầng và các kiểm soát chính

Terraform được chia thành tệp network, security groups, compute, cơ sở dữ liệu, storage, IAM, TLS, email, observability và backup. Sự phân chia giúp rà soát theo nhóm trách nhiệm nhưng các tham chiếu vẫn tạo quan hệ phụ thuộc giữa tài nguyên.

S3 có versioning bật, SSE-S3, bốn tùy chọn Block Public Access bật và quyền sở hữu BucketOwnerEnforced. Lifecycle xóa phiên bản không hiện hành sau 30 ngày, dọn delete marker và hủy tải lên nhiều phần chưa hoàn tất sau bảy ngày. Do versioning tồn tại, xóa object hiện hành từ ứng dụng không đồng nghĩa mọi phiên bản bị xóa ngay.

RDS MySQL 8.4 bật mã hóa, không công khai và yêu cầu secure transport. Cấu hình Terraform mặc định giữ backup bảy ngày, nhưng lần triển khai trên tài khoản AWS Free Plan sử dụng giá trị một ngày để đáp ứng giới hạn của gói. Multi-AZ và bảo vệ xóa phụ thuộc biến. AWS Backup giữ lâu hơn và kiểm thử khôi phục là tính năng có điều kiện, không được mặc nhiên xem là đang bật.

EC2 yêu cầu IMDSv2, mã hóa root volume và gắn instance profile. Role được phép thao tác object trong bucket ứng dụng, đọc secret DB, đọc/khởi tạo secret ứng dụng và ghi log. Quyền sửa secret phục vụ bootstrap vẫn tồn tại trong vai trò runtime; đây là điểm cần thu hẹp khi hoàn thiện phân tách nhiệm vụ.

CloudWatch khai báo log ứng dụng và VPC flow log giữ 30 ngày. Alarm CPU

EC2 dùng ngưỡng trung bình trên 80% trong ba chu kỳ năm phút; alarm RDS kiểm tra dung lượng trống dưới 2 GiB. SNS email chỉ có khi cấu hình địa chỉ và còn cần hoàn thành xác nhận đăng ký. Chúng là cảnh báo tài nguyên, chưa phải hệ thống phát hiện mọi hành vi truy cập bất thường.

4.14.2. Kết quả triển khai thực tế trên AWS

Nhóm đã thực hiện quy trình terraform init, terraform validate, terraform plan và terraform apply để tạo môi trường AWS thử nghiệm. Việc nghiệm thu không chỉ dựa vào thông báo apply thành công mà còn đối chiếu đầu ra Terraform, trạng thái tài nguyên trên AWS và khả năng truy cập ứng dụng qua ALB. Script scripts/aws_integration_test.py được thiết kế để đọc cấu hình và trạng thái tài nguyên mà không thay đổi tài nguyên; scripts/smoke_test_deployment.py kiểm tra endpoint, header bảo mật, CSRF và cookie phiên.

Trong lần khởi động EC2 đầu tiên, cloud-init dừng vì gói awscli không có bản cài phù hợp từ nguồn APT của image Ubuntu được chọn. Nhóm đã cài AWS CLI v2 từ gói chính thức và chạy lại phần cấu hình còn lỗi để đưa target về trạng thái healthy. Mẫu cloud-init trong mã nguồn sau đó được sửa theo cùng cách cài đặt. Vì vậy, bằng chứng endpoint và kiểm tra tích hợp dưới đây phản ánh hệ thống sau khi khắc phục; chưa có ảnh chứng minh một instance mới dùng mẫu đã sửa hoàn tất toàn bộ bootstrap ngay từ lần khởi động đầu tiên.

```

$ cd /app
$ sudo docker compose \
  --env-file .env \
  -f docker/docker-compose.yml \
  -f docker/docker-compose.aws.yml \
  ps> > >
NAME          IMAGE          COMMAND          SERVICE    CREATED   STATUS    PORTS
docker-web-1  cloud-security-app:local "sh -c 'exec gunicorn..." web        3 hours ago Up 3 hours (healthy) 0.0.0.0:5000->5000/tcp, [::]:5000->5000/tcp
CONTAINER ID  IMAGE          COMMAND          CREATED   STATUS    PORTS    NAMES
f9cd9e582592  cloud-security-app:local "sh -c 'exec gunicorn..." 3 hours ago Up 3 hours (healthy) 0.0.0.0:5000->5000/tcp, [::]:5000->5000/tcp docker-web-1
$ curl -I http://127.0.0.1:5000/
HTTP/1.1 200 OK
Server: gunicorn
Date: Sat, 19 Sep 2026 15:56:09 GMT
Connection: keep-alive
Content-Type: text/html; charset=utf-8

```

Hình 4.5: EC2 sau khắc phục: container ứng dụng healthy và endpoint cục bộ trả HTTP 200

Các ảnh bằng chứng phải được chụp trong cùng đợt nghiệm thu và liên kết với phiên bản mã triển khai. Phần thông tin không cần thiết như số tài khoản, ARN đầy đủ, endpoint cơ sở dữ liệu, cookie và giá trị secret phải được che. Nếu môi trường đang dùng ALB HTTP cho mục đích thử nghiệm, báo cáo ghi rõ https_enabled=false; không diễn giải kết quả đó thành bảo vệ TLS cho môi trường công khai.

```
(.env) PS E:\BtapThucHanh\Antoanthongtin\cloud-security-project> terraform -chdir=terraform validate
Success! The configuration is valid.

(.env) PS E:\BtapThucHanh\Antoanthongtin\cloud-security-project> terraform -chdir=terraform state list
data.aws_ami.ubuntu
data.aws_availability_zones.available
data.aws_caller_identity.current
data.aws_iam_policy_document.documents_bucket
data.aws_iam_policy_document.ec2_application
aws_cloudwatch_log_group.application
aws_cloudwatch_log_group.vpc_flow
aws_cloudwatch_metric_alarm.ec2_cpu
aws_cloudwatch_metric_alarm.rds_storage
aws_db_instance.mysql
aws_db_parameter_group.mysql
aws_db_subnet_group.main
aws_flow_log.main
aws_iam_instance_profile.ec2
aws_iam_role.ec2
aws_iam_role.vpc_flow
aws_iam_role_policy.ec2_application
aws_iam_role_policy.vpc_flow
aws_iam_role_policy_attachment.ssm
aws_instance.web
aws_internet_gateway.main
aws_lb.web
aws_lb_listener.http_forward[0]
aws_lb_target_group.web
aws_lb_target_group_attachment.web
aws_route_table.public
aws_route_table_association.public[0]
aws_route_table_association.public[1]
aws_s3_bucket.documents
aws_s3_bucket_lifecycle_configuration.documents
aws_s3_bucket_ownership_controls.documents
aws_s3_bucket_policy.documents
aws_s3_bucket_public_access_block.documents
aws_s3_bucket_server_side_encryption_configuration.documents
aws_s3_bucket_versioning.documents
aws_secretsmanager.secret.app
aws_security_group.alb
aws_security_group.database
aws_security_group.web
aws_subnet.database[0]
aws_subnet.database[1]
aws_subnet.public[0]
aws_subnet.public[1]
aws_vpc.main
aws_vpc_security_group_egress_rule.alb_to_web
aws_vpc_security_group_egress_rule.web_http_outbound
aws_vpc_security_group_egress_rule.web_https_outbound
aws_vpc_security_group_egress_rule.web_to_database
aws_vpc_security_group_ingress_rule.alb_http
aws_vpc_security_group_ingress_rule.database_from_web
aws_vpc_security_group_ingress_rule.web_from_alb
```

Hình 4.6: Terraform validate thành công và danh sách tài nguyên đang được quản lý trong state

```
Would you like to update the Terraform state to reflect these detected changes?
Terraform will write these changes to the state without modifying any real infrastructure.
There is no undo. Only 'yes' will be accepted to confirm.

Enter a value: yes

Apply complete! Resources: 0 added, 0 changed, 0 destroyed.

Outputs:

application_log_group_name = "/cloudbox/dev/application"
application_url = "http://dev-cloudbox-alb-1986563829.ap-southeast-1.elb.amazonaws.com"
cloudwatch_alarm_names = [
  "dev-cloudbox-ec2-high-cpu",
  "dev-cloudbox-rds-low-storage",
```

Hình 4.7: Kết quả refresh-only apply đồng bộ state mà không tạo, sửa hoặc xóa tài nguyên AWS

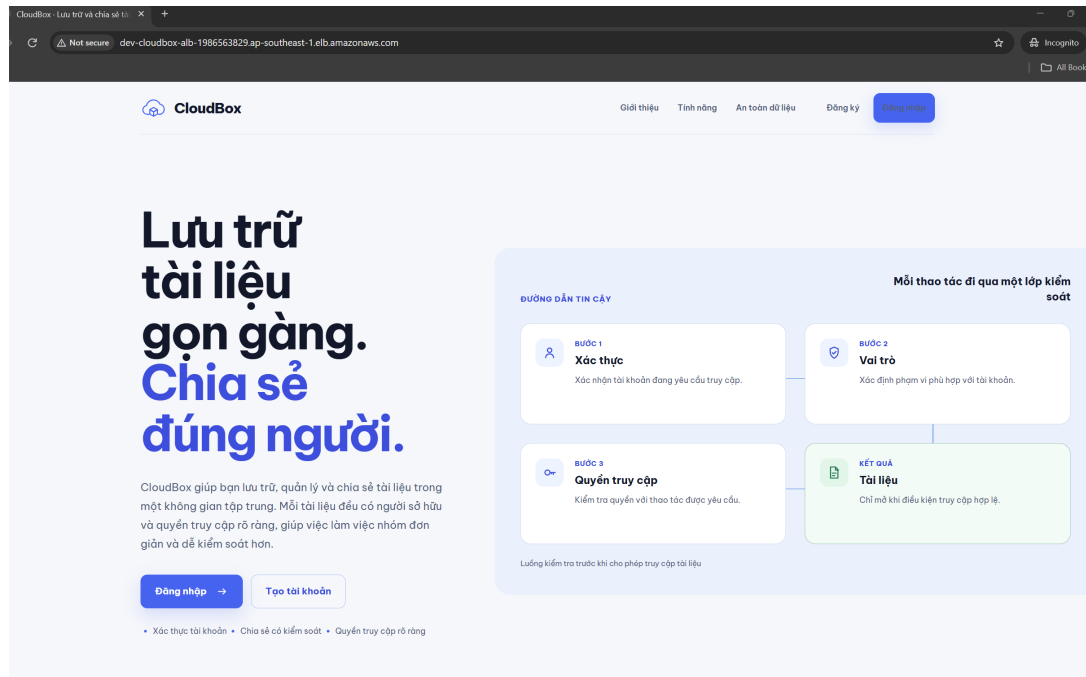
Bảng 4.4: Tài nguyên AWS và bảng chứng nghiệm thu sau triển khai

Thành phần	Điều kiện kiểm tra	Bảng chứng
Terraform	Validate thành công; apply hoàn tất; output có đủ định danh cần thiết	Log đã che dữ liệu nhạy cảm, mã AWS-01
ALB/Target Group	ALB ở trạng thái active; EC2 máy đích ở trạng thái hoạt động bình thường	Console hoặc AWS API, mã AWS-02
EC2/SSM	Instance running; IMDSv2 bắt buộc; SSM online; không mở SSH	Console hoặc script tích hợp, mã AWS-03
RDS MySQL	Available, mã hóa, không mở công khai, có thời gian giữ backup	Console hoặc AWS API, mã AWS-04
S3	Block Public Access đầy đủ, bucket không mở công khai, versioning và mã hóa bật	Console hoặc AWS API, mã AWS-05
IAM/Secrets	EC2 dùng instance profile; không có Allow */*; secret tồn tại	Script tích hợp, mã AWS-06
CloudWatch	Có log group, VPC Flow Logs và các alarm được khai báo	Console hoặc AWS API, mã AWS-07
Ứng dụng	Trang đăng nhập và endpoint CSRF phản hồi qua ALB; header đúng phạm vi HTTP/HTTPS	Smoke test, mã AWS-08

```
[PASS] load_balancer: ALB is active and the EC2 target is healthy
[PASS] iam: instance profile uses dev-cloudbox-ec2-role; no Allow */* statement
[PASS] secrets_manager: RDS secret exists and is not scheduled for deletion
[PASS] observability: log retention=30 day(s), 2 alarm(s), VPC Flow Logs active

9/9 AWS integration checks passed
```

Hình 4.8: Chín kiểm tra tích hợp AWS đạt sau khi triển khai



Hình 4.9: CloudBox hoạt động qua địa chỉ Application Load Balancer

4.15. Xây dựng quy trình CI/CD

CI có các nhóm công việc kiểm thử Python, kiểm tra bảo mật Python, Terraform và container/IaC. Các action được khóa theo commit. Quy trình CI/CD khai báo compileall, pip check, unittest, pip-audit, Bandit, Terraform fmt/init/validate và Trivy. Workflow triển khai dùng OIDC để nhận thông tin xác thực ngắn hạn, chỉ apply khi được yêu cầu thủ công trên nhánh chính, sau đó chờ máy đích ở trạng thái hoạt động bình thường và chạy hai script nghiệm thu. Trạng thái workflow hosted chỉ được ghi là đạt khi có ảnh hoặc URL của run gắn với đúng commit triển khai.

Bandit được cấu hình để báo lỗi ở mức High. Trivy kiểm tra mức High/Critical và bỏ qua các lỗi hồng chưa có bản sửa khi quét image. Do đó, một lần chạy CI thành công vẫn có thể còn cảnh báo ở mức thấp hơn hoặc thuộc danh sách ngoại lệ. Khi đánh giá kết quả, cần đọc cả cấu hình lọc và lý do chấp nhận ngoại lệ.

Các bài kiểm thử cấu hình CI kiểm tra xem những lệnh và điều kiện cần thiết có còn trong workflow hay không. Chúng giúp phát hiện cấu hình bị thay đổi ngoài dự kiến. Để xác nhận workflow hoạt động, vẫn cần chạy trên GitHub Actions và kiểm tra kết quả tạo image.

4.16. Kết quả xây dựng hệ thống

Mã nguồn thể hiện đầy đủ các nhóm chức năng chính: xác thực, quản lý tài liệu, chia sẻ, quản trị và API. Bộ kiểm thử chứng minh các luồng được kiểm tra có hành vi phù hợp với điều kiện kiểm tra. Môi trường Docker trên Ubuntu chứng minh khả

năng đóng gói ứng dụng cùng MySQL; lần triển khai Terraform chứng minh kiến trúc AWS có thể được khởi tạo thành tài nguyên thực thay vì chỉ tồn tại dưới dạng thiết kế. Phạm vi khẳng định của từng kết quả vẫn phụ thuộc vào mã bằng chứng trong Bảng 4.4 và Chương 5.

Kết quả nổi bật là quyền cấp tài liệu không bị thay thế bởi quyền vai trò, nội dung lưu tách khỏi siêu dữ liệu và có lớp validator dùng chung. Hạn chế chính là khoảng cách giữa mục tiêu bảo vệ hoàn chỉnh với hiện thực: tệp chưa quét vẫn tải được, hạn mức lưu trữ chưa có kiểm soát cạnh tranh, log chưa bao phủ toàn bộ vòng đời tài liệu và tài khoản cơ sở dữ liệu dùng khi chạy ứng dụng còn quyền quản trị.

4.17. Kết luận chương

CloudBox hiện thực được nền tảng ứng dụng và nhiều kiểm soát có thể kiểm thử. Kiến trúc module, dữ liệu quan hệ và cấu hình IaC giúp truy vết từ yêu cầu đến thành phần cụ thể. Tuy nhiên, mức bảo đảm phải dựa trên kiểm thử và trạng thái triển khai; Chương 5 đánh giá kết quả theo đúng phạm vi này.

CHƯƠNG 5. KIỂM THỬ VÀ ĐÁNH GIÁ MÔ HÌNH

Kiểm thử được tổ chức để xác định hành vi của các kiểm soát đã hiện thực và giới hạn của kết luận. Bộ bài kiểm thử tự động được chạy trên mã nguồn phân tích ở Chương 4; môi trường Docker/MySQL được kiểm chứng trên máy ảo Ubuntu; hạ tầng AWS được đánh giá sau khi Terraform apply. Mock dịch vụ ngoài trong unit test và kiểm tra tài nguyên AWS thật được báo cáo thành hai nhóm riêng để tránh dùng kết quả mô phỏng thay cho bằng chứng triển khai.

5.1. Mục tiêu kiểm thử

Mục tiêu thứ nhất là kiểm tra các chức năng cốt lõi: xác thực, tài liệu, chia sẻ và quản trị. Mục tiêu thứ hai là kiểm tra những tình huống phải bị từ chối, chẳng hạn người dùng không có quyền, token CSRF thiếu hoặc tệp không hợp lệ. Mục tiêu thứ ba là đánh giá cách xử lý lỗi và khả năng duy trì trạng thái nhất quán.

Nhóm kiểm tra mã HTTP, dữ liệu trả về, thay đổi trong cơ sở dữ liệu, lời gọi dịch vụ lưu trữ và nhật ký được tạo. Mỗi bài kiểm thử chỉ xác nhận những điều kiện được kiểm tra trong bài đó. Vì vậy, tỷ lệ kiểm thử thành công không cho biết hệ thống an toàn bao nhiêu phần trăm hoặc bao nhiêu phần mã nguồn đã được kiểm tra.

5.2. Môi trường kiểm thử

Bộ kiểm thử chạy trong môi trường Python ảo `.venv-ubuntu` trên máy ảo Ubuntu VirtualBox, sử dụng Python 3.14 theo đường dẫn thư viện trong log. Dữ liệu unit/integration test được tạo trong SQLite và thư mục tạm; Flask test client gửi yêu cầu trực tiếp đến ứng dụng. Docker Compose được dùng cho phép thử vận hành với MySQL. Bộ ảnh Ubuntu xác nhận trạng thái container, giao diện local, smoke test và kết quả unittest. Bằng chứng về tài nguyên AWS được quản lý riêng vì các dịch vụ Cloud thực tế chạy trên AWS. Một số bài kiểm thử chức năng tắt CSRF và limiter để tập trung nghiệp vụ. Nhóm kiểm thử bảo mật bật hoặc cấu hình lại các cơ chế cần kiểm tra. Chính sách mật khẩu trong dữ liệu thử có thể khác mặc định; vì vậy kết quả phải được đọc cùng setup của test, không chỉ cùng tên test.

5.2.1. Kiểm tra endpoint ứng dụng trên Ubuntu

Sau khi container hoạt động, nhóm chạy `scripts/smoke_test_deployment.py` với địa chỉ `http://127.0.0.1:5000` và tùy chọn `--allow-http`. Kết quả ở Hình 5.1 ghi nhận trang đăng nhập và endpoint CSRF đều trả HTTP 200, nhóm các header bảo mật đạt yêu cầu của script. Giá trị `https=false` và `secure_session_cookie=false` phản ánh chế

Bảng 5.1: Phạm vi môi trường thực nghiệm

Thành phần	Trạng thái thực nghiệm
Máy kiểm thử	Máy ảo Ubuntu Linux x86_64; ubuntu-26.04.1; vCPU: 2; RAM: 4GB; chế độ mạng: NAT
Python / Flask	Python 3.14 trong môi trường test; image Docker khai báo Python 3.12
Cơ sở dữ liệu	SQLite, dữ liệu thử nghiệm tạm
Tệp nội dung	Tệp thử và thư mục tạm theo test
HTTP ứng dụng	Flask test client; không phải kiểm thử tải mạng
S3 / SES / AWS API	Mock theo bộ kiểm thử
Docker / MySQL	Docker 29.7.2, Compose v5.5.0; MySQL và web healthy trên Ubuntu
Terraform	Đã thực hiện init, validate, plan và apply cho môi trường thử nghiệm
AWS triển khai thật	Đã tạo tài nguyên; kiểm tra trạng thái bằng output, AWS API/Console và endpoint ALB
Bandit	Phiên bản 1.9.4, lọc mức High theo lệnh CI

độ HTTP local; phép thử này không xác nhận TLS hoặc trạng thái triển khai AWS.

```
(.venv-ubuntu) nminh@localhost:~/cloud-security-project$ python scripts/smoke_test_deployment.py \
http://127.0.0.1:5000 --allow-http
{
  "base_url": "http://127.0.0.1:5000/",
  "login_status": 200,
  "csrf_status": 200,
  "https": false,
  "http_redirect": null,
  "tls_protocol": null,
  "certificate_expires_at": null,
  "security_headers": "ok",
  "secure_session_cookie": false
}
```

Hình 5.1: Kết quả smoke test endpoint HTTP local trên Ubuntu

5.3. Phương pháp kiểm thử

Unit test kiểm tra hàm hoặc service trong phạm vi nhỏ; integration test qua test client kiểm tra phối hợp route, service và SQLite. Mock được dùng để kiểm tra tham số gọi AWS và xử lý phản hồi mà không tạo tài nguyên thật. Kiểm thử cấu hình đọc workflow hoặc cấu trúc dữ liệu để phát hiện thay đổi ngoài dự kiến.

Các lệnh kiểm chứng gồm hai bộ unittest, compileall cho các thư mục mã Python, pip check và Bandit với ngưỡng High. Nhóm kiểm tra triển khai gồm Docker Compose, Terraform validate/apply, script tích hợp AWS chỉ đọc và smoke test endpoint. Nhật ký thực thi được lưu kèm hồ sơ kiểm chứng. Thời gian của bộ test chỉ phục vụ tái lập, không được dùng làm kết quả hiệu năng của ứng dụng.

Đối với hạ tầng, báo cáo kết hợp ba mức bằng chứng: Terraform validate chứng minh cấu hình hợp lệ về cú pháp và schema; Terraform apply chứng minh tài nguyên có thể được tạo; kiểm tra sau triển khai chứng minh một số điều kiện vận hành như

EC2 đang chạy, máy đích ở trạng thái hoạt động bình thường, RDS không mở công khai và S3 không mở công khai. Ba mức này không thay thế cho pentest, kiểm thử phục hồi hoặc đánh giá tuân thủ độc lập.

5.4. Kiểm thử chức năng

5.4.1. Kiểm thử xác thực

Nhóm API kiểm tra dữ liệu đăng ký không hợp lệ, đăng ký thành công và xung đột khi trùng. Dữ liệu mật khẩu được kiểm tra không lưu dạng rõ. Các ca đăng nhập sai, đăng nhập đúng, đăng xuất và tài khoản bị vô hiệu hóa kiểm tra mã phản hồi tương ứng.

Nhóm quản trị còn kiểm tra đăng nhập bằng tên hoặc email không phân biệt hoa thường và hành vi tùy chọn ghi nhớ. Các kết quả cho thấy những luồng được kiểm tra hoạt động như thiết kế, nhưng không bao phủ mọi tổ hợp Unicode, địa chỉ email hoặc tình huống cạnh tranh khi đăng ký.

5.4.2. Kiểm thử quản lý tài liệu

Các ca kiểm tra tải lên và tải xuống xác nhận nội dung cùng siêu dữ liệu; khóa lưu được sinh riêng cho các lần tải lên cùng tên. Vòng đời xóa mềm, khôi phục và dọn dữ liệu quá hạn được kiểm tra bằng trạng thái cơ sở dữ liệu và thao tác storage.

Dung lượng đã sử dụng được kiểm tra trước khi tải tệp lên, bao gồm tài liệu còn trong thùng rác. Tuy nhiên, kiểm tra tuần tự không chứng minh khả năng ngăn nhiều tải lên đồng thời vượt hạn mức lưu trữ. Cần bổ sung phép thử cạnh tranh trước khi đưa ra kết luận về tính nguyên tử.

5.4.3. Kiểm thử chia sẻ

Bộ test sử dụng người sở hữu và người nhận khác nhau để kiểm tra tạo chia sẻ, xử lý trùng, truy cập của người nhận và thu hồi. Quyền được kiểm tra trên endpoint, không chỉ qua thành phần giao diện. Khi thu hồi, yêu cầu tải mới không được tiếp tục theo quan hệ cũ.

Các ca này hỗ trợ kết luận về quyền cấp tài liệu trong phạm vi dữ liệu thử. Chúng không thể kiểm soát nội dung đã được người nhận lưu ngoài hệ thống trước khi thu hồi; đây là giới hạn nghiệp vụ chứ không phải lỗi của kết quả test.

5.4.4. Kiểm thử quản trị

Nhóm quản trị có 22 test, kiểm tra người dùng thường bị từ chối, thay đổi role/permission, trạng thái tài khoản, hành vi tự quản lý và nhật ký hoạt động. Các test cũng xác nhận một số hành động bị từ chối không tạo log thay đổi sai lệch.

Mã nguồn và test cho thấy trang quản trị tài liệu phục vụ siêu dữ liệu thay vì cấp

quyền tải toàn bộ nội dung. Đây là một điểm tích cực của sự phân tách chức năng. Tuy nhiên, chủ thể có quyền trực tiếp trên cơ sở dữ liệu hoặc host vẫn nằm ngoài phạm vi của chính sách giao diện này.

5.5. Kiểm thử bảo vệ danh tính

Nhóm kiểm soát bảo mật kiểm tra mật khẩu, giới hạn đăng nhập, khóa tài khoản, OTP và phiên cũ sau thay đổi mật khẩu. Việc dùng bộ đếm trong cơ sở dữ liệu giúp duy trì trạng thái khóa theo tài khoản. Test limiter xác nhận hành vi trên cấu hình của test, không xác nhận tổng giới hạn qua nhiều worker.

Các ca OTP kiểm tra thất bại theo số lần và sự hết hạn trong phạm vi được khai báo. Email lỗi được mô phỏng để xác nhận luồng không tiếp tục như gửi thành công. Tuy nhiên, chưa có bằng chứng test bao phủ quyền đặt lại mật khẩu sau xác minh bị hết hạn, bị dùng lại qua cookie cũ hoặc được sử dụng đồng thời ở hai yêu cầu.

Đổi mật khẩu làm phiên bản phiên thay đổi và test xác nhận phiên cũ bị vô hiệu hóa. Đăng xuất thông thường chỉ được kiểm tra với client đã nhận phản hồi xóa cookie. Kết quả đó không chứng minh cookie đã sao chép ở nơi khác bị thu hồi phía máy chủ.

5.6. Kiểm thử phân quyền và quyền tài liệu

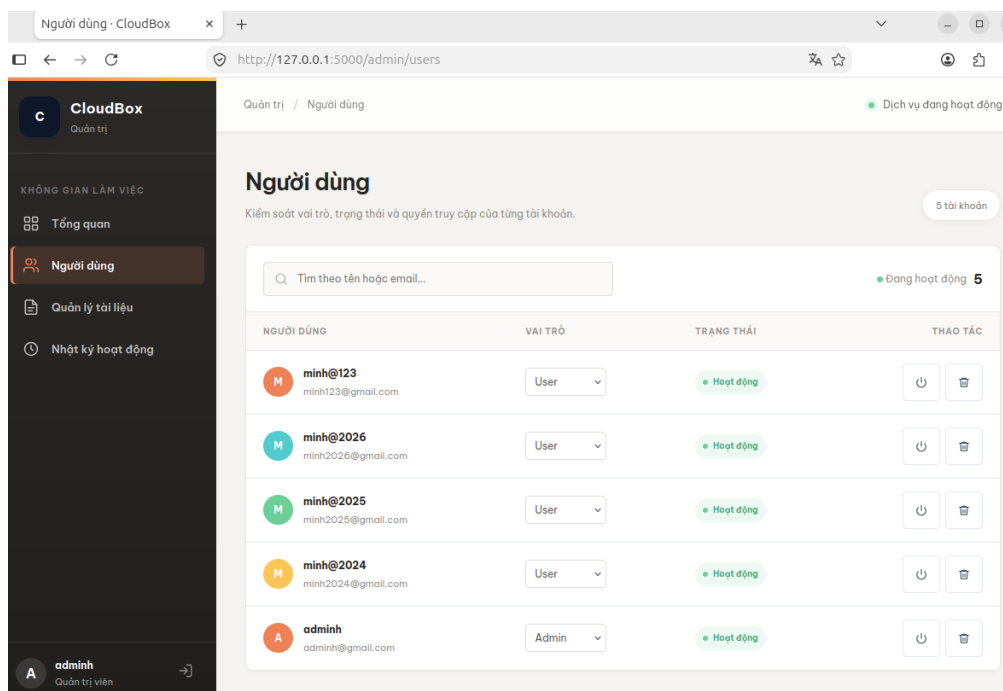
Các tình huống quan trọng gồm user gọi chức năng quản trị, người không được chia sẻ tài liệu, người nhận cổ xóa, chủ sở hữu thực hiện thao tác hợp lệ và tài khoản bị vô hiệu hóa sử dụng phiên đã có. Truy vấn kèm owner hoặc quan hệ chia sẻ là điểm kiểm soát chính được đối chiếu.

Kết quả thành công của các ca hiện có hỗ trợ nhận định rằng ứng dụng đã có kiểm soát cấp đối tượng, không chỉ kiểm tra đăng nhập. Tuy vậy, việc thêm một route mới có thể tạo đường bỏ sót; vì vậy ma trận quyền cần được dùng làm nguồn xây dựng test hồi quy khi mở rộng chức năng.

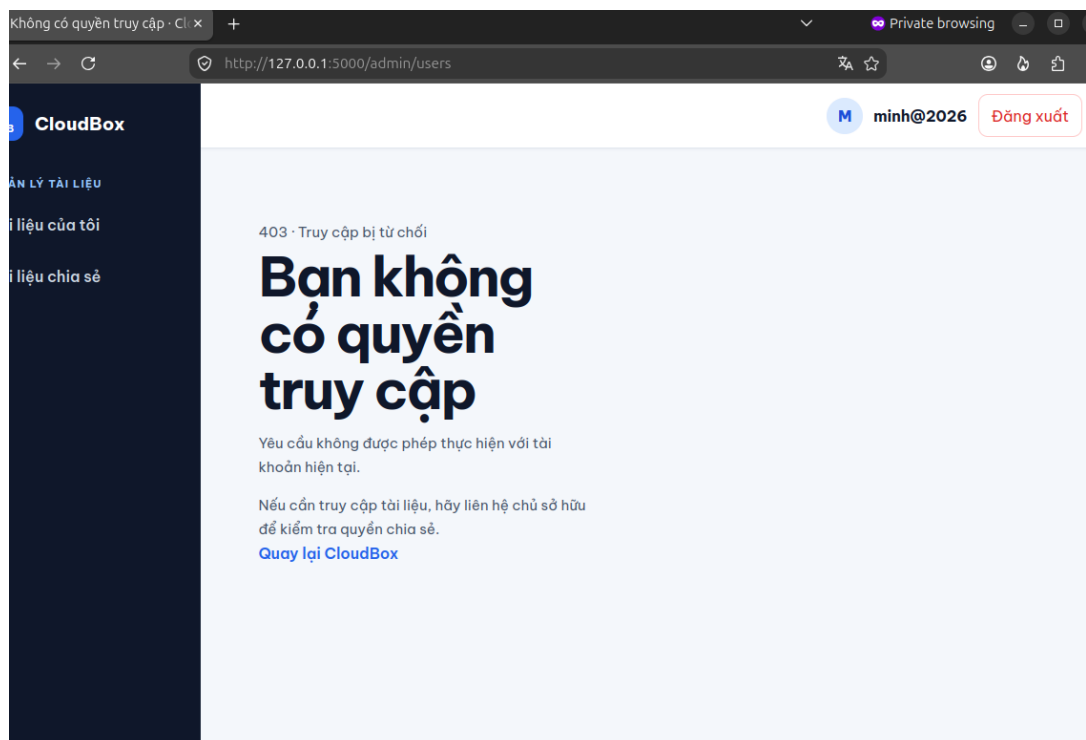
5.6.1. Truy cập chức năng quản trị theo vai trò

Phép thử trên trình duyệt ngày 19-09-2026 sử dụng ứng dụng chạy cục bộ trên Windows, cơ sở dữ liệu SQLite tạm và hai tài khoản kiểm thử. Sau khi đăng nhập bằng admin, nhóm mở trang `http://127.0.0.1:5000/admin/users`; máy chủ trả HTTP 200 và hiển thị danh sách người dùng cùng vai trò (Hình 5.2). Tiếp theo, nhóm đăng xuất bằng chức năng của ứng dụng, đăng nhập bằng `minh@2026` và truy cập trực tiếp đúng URL đó. Máy chủ trả HTTP 403, đồng thời giao diện thông báo không có quyền truy cập (Hình 5.3). URL, trình tự thao tác và mã phản hồi được lưu trong `evidence/rbac-access-results.json`.

Cập ảnh xác nhận kiểm soát vai trò tại route quản trị được thử: đăng nhập thành công không đồng nghĩa được sử dụng chức năng quản trị. Đây là bằng chứng bổ sung



Hình 5.2: Tài khoản admin truy cập thành công trang quản trị người dùng

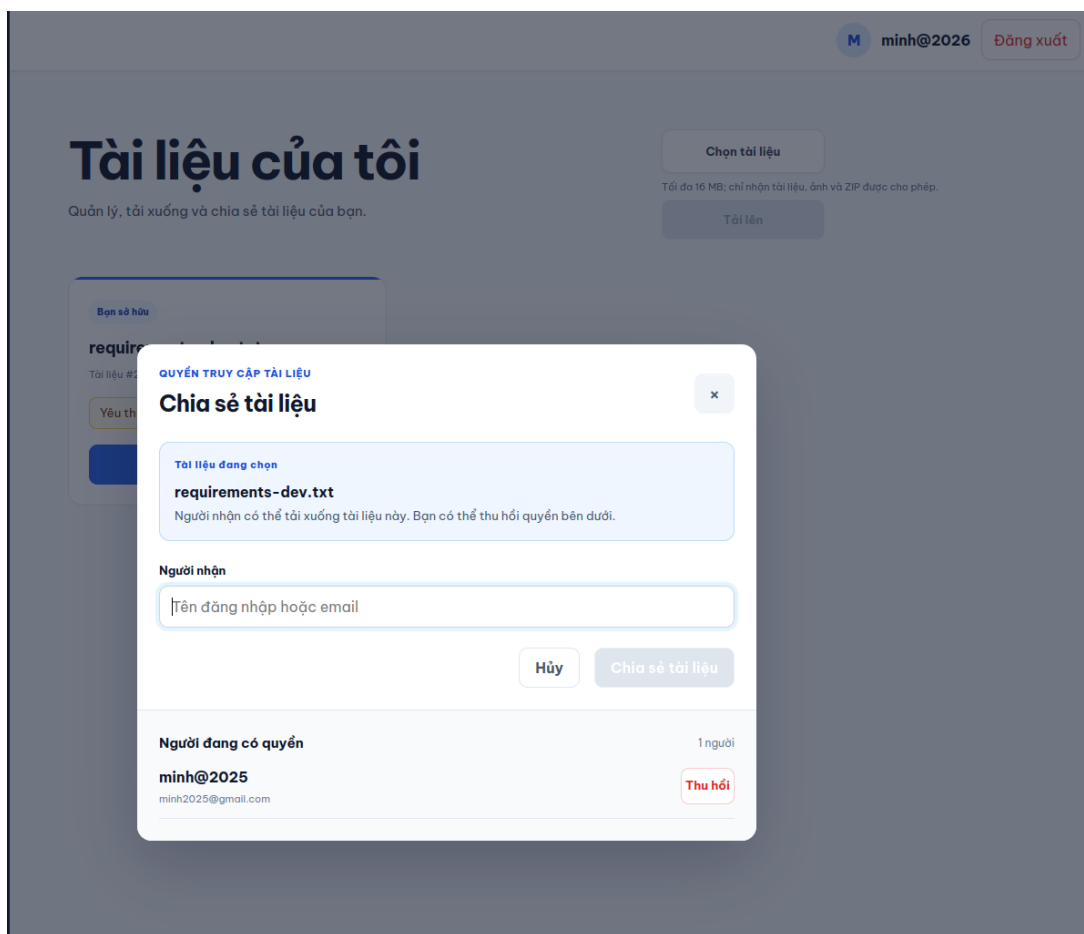


Hình 5.3: Tài khoản thường bị từ chối khi truy cập cùng đường dẫn quản trị

trên môi trường cục bộ, không phải kết quả truy cập qua ALB hay kiểm chứng tất cả endpoint quản trị.

5.6.2. Chia sẻ tài liệu và truy cập của người nhận

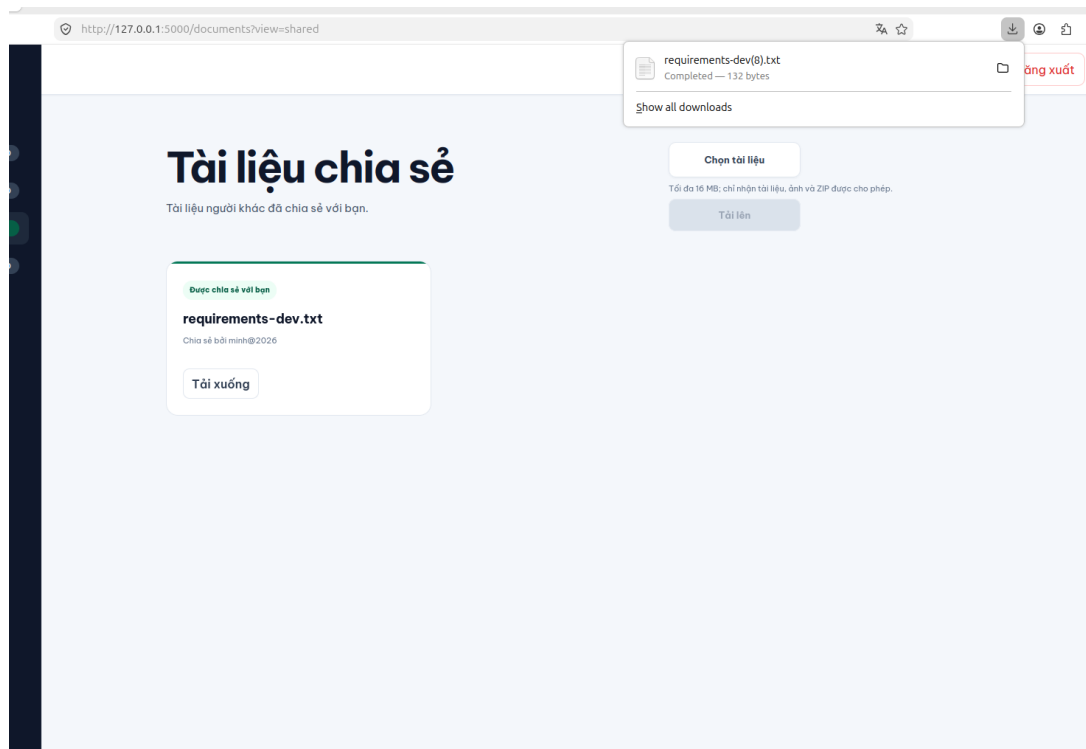
Bộ ảnh giao diện do nhóm cung cấp thể hiện tài liệu `requirements-dev.txt` thuộc tài khoản `minh@2026`. Trong hộp thoại chia sẻ, `minh@2025` xuất hiện ở danh sách người đang có quyền (Hình 5.4). Khi đăng nhập bằng tài khoản người nhận, tài liệu xuất hiện trong mục “Tài liệu chia sẻ”, kèm tên chủ sở hữu và nút tải xuống. Sau khi người nhận chọn tải xuống, trình duyệt hiển thị tệp `requirements-dev(8).txt` ở trạng thái hoàn tất (Hình 5.5). Hai ảnh đối chiếu trạng thái cấp quyền ở phía chủ sở hữu với khả năng truy cập và tải tài liệu ở phía người nhận.



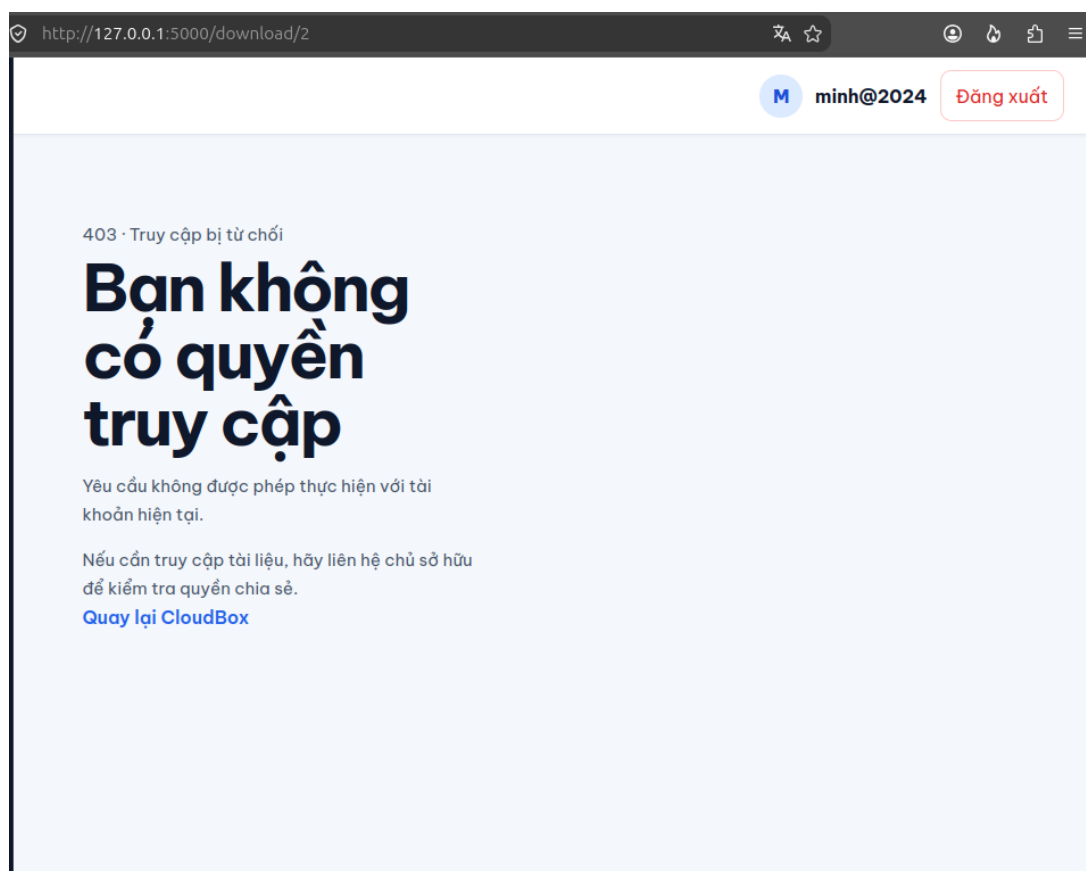
Hình 5.4: Chủ sở hữu kiểm tra tài khoản đang được cấp quyền nhận tài liệu

5.6.3. Từ chối truy cập khi không có quyền hoặc đã thu hồi quyền

Trong tình huống tài khoản chưa được chia sẻ, `minh@2024` truy cập trực tiếp `http://127.0.0.1:5000/download/2`. Hình 5.6 ghi nhận trang “403 – Truy cập bị từ chối” cùng tên tài khoản đang đăng nhập. Kết quả minh họa việc biết đường dẫn hoặc mã tài liệu không đủ để lấy nội dung.

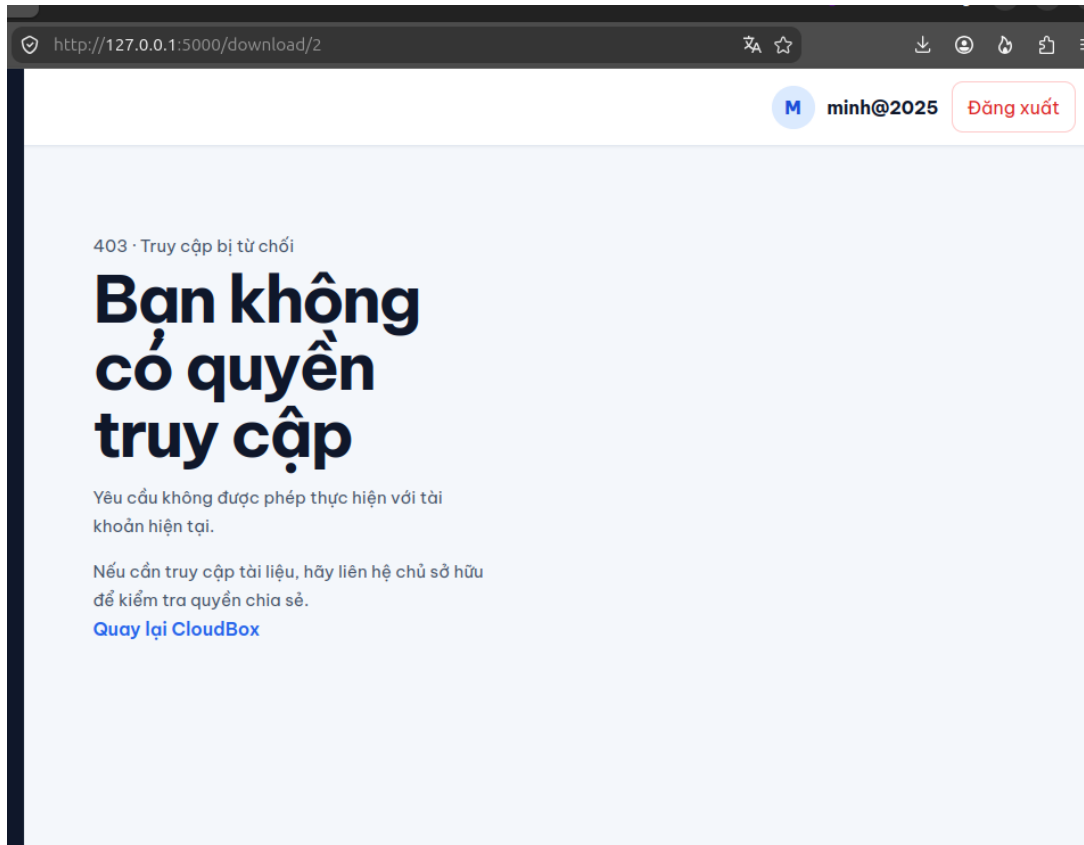


Hình 5.5: Người nhận tải xuống thành công tài liệu đã được chia sẻ



Hình 5.6: Tài khoản không được chia sẻ bị từ chối tại đường dẫn tải tài liệu

Với tình huống thu hồi chia sẻ, tài khoản người nhận minh@2025 truy cập lại cùng đường dẫn /download/2 và nhận trang từ chối (Hình 5.7). Đối chiếu với Hình 5.4 và Hình 5.5, bộ ảnh minh họa trạng thái có quyền trước đó và kết quả truy cập bị chặn trong kịch bản sau thu hồi. Ảnh kết quả không ghi lại thao tác bấm thu hồi hoặc phản hồi HTTP của yêu cầu thu hồi; kết luận được giới hạn ở trạng thái giao diện và kết quả truy cập được ghi nhận.



Hình 5.7: Người nhận bị từ chối khi truy cập lại đường dẫn tải trong kịch bản thu hồi quyền

5.7. Kiểm thử bảo mật ứng dụng web

Các ca CSRF kiểm tra thiếu token hoặc token không hợp lệ và hành vi đăng xuất dùng POST. Nhóm header kiểm tra CSP, nonce, cookie và những header được cấu hình. Các phản hồi lỗi được kiểm tra theo mã HTTP và cấu trúc mong đợi.

Kiểm tra sự có mặt của CSP không chứng minh không còn XSS trong toàn bộ giao diện. Tương tự, dùng ORM không đủ để xác nhận mọi điểm xử lý dữ liệu đều an toàn. Chưa có đánh giá trình duyệt toàn diện, fuzzing hoặc pentest độc lập; các nội dung này được ghi nhận là phạm vi chưa thực hiện.

5.8. Kiểm thử tệp tải lên

Test storage kiểm tra đường dẫn không hợp lệ, tệp nén có thành phần nguy hiểm và cấu trúc định dạng. Test API kiểm tra siêu dữ liệu, hạn mức lưu trữ, trạng thái scan và xử lý lỗi khi lưu cơ sở dữ liệu. Những ca này xác nhận validator và service phản ứng đúng với bộ mẫu được chọn.

Kết quả chặn pending/infected/failed chỉ chứng minh ứng dụng tôn trọng các trạng thái đó khi chúng đã được đặt. Bộ test không cung cấp bộ quét mã độc, và tài liệu mới vẫn mang not_scanned. Vì vậy, yêu cầu phát hành chỉ sau quét sạch của mô hình đầy đủ chưa được đáp ứng.

MIME được đối chiếu từ trường do client cung cấp, kết hợp chữ ký hoặc cấu trúc. Đây không phải công cụ phân loại nội dung hoàn chỉnh. Tệp phức tạp, tệp nén lồng nhau và khai báo siêu dữ liệu bất thường cần được đánh giá thêm với parser có giới hạn tài nguyên nếu hệ thống mở rộng phạm vi chấp nhận.

5.9. Kiểm thử cơ sở dữ liệu và lưu trữ

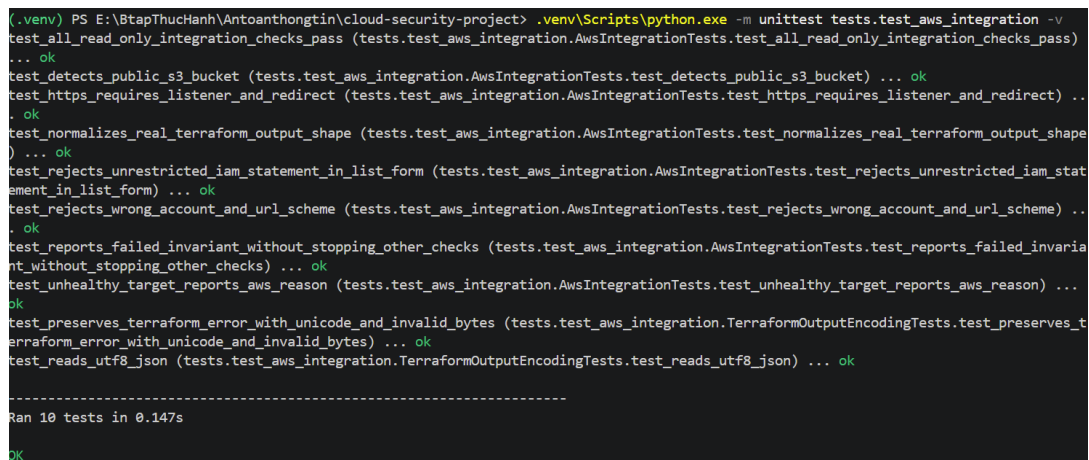
Các test backup chạy với SQLite, kiểm tra sao lưu nhất quán, kiểm tra tính hợp lệ và phục hồi vào tệp mới. Không ghi đè cơ sở dữ liệu đang hoạt động là một đặc tính an toàn của script. Ba test backup đều đạt trong lần thực nghiệm.

Các ca lỗi tải lên mô phỏng thất bại của cơ sở dữ liệu và xác nhận hành vi dọn nội dung đã lưu. Điều này hỗ trợ đánh giá cơ chế bù trừ, nhưng chưa bao phủ mọi lỗi đồng thời của cơ sở dữ liệu và kho tệp. Khi cả commit và cleanup gặp lỗi, vẫn cần đối soát tệp mô côi.

Tích hợp S3 trong bộ unit test được kiểm tra bằng mock. Ngoài bộ test này, đợt nghiệm thu ngày 20-09-2026 đã thực hiện khôi phục một object thử trên bucket thật bằng S3 Versioning và phục hồi một snapshot RDS thành instance riêng. Hai phép thử xác nhận từng cơ chế phục hồi hoạt động độc lập, nhưng chưa phải phục hồi đồng bộ siêu dữ liệu RDS với nội dung S3 và chưa cung cấp số đo RPO/RTO cho toàn hệ thống.

5.10. Kiểm thử triển khai AWS

Bảy test tích hợp AWS trong bộ 78 test ứng dụng đã được chụp trên Ubuntu kiểm tra hành vi của script qua đối tượng mô phỏng. Mã nguồn hiện tại đã bổ sung ba ca về đọc UTF-8, giữ thông báo lỗi Terraform có byte không hợp lệ và mô tả nguyên nhân target không healthy. Lần chạy riêng trên Windows xác nhận cả 10 test của mô-đun đều đạt (Hình 5.8); kết quả này bổ sung cho ảnh tổng kết 78 test cũ, không thay đổi mẫu số 88 của hai suite đã chụp trên Ubuntu. Sau khi Terraform apply, cùng script được chạy ở chế độ chỉ đọc với quyền của môi trường thử nghiệm để truy vấn STS, EC2/SSM, RDS, S3, ELBv2, IAM, Secrets Manager và CloudWatch. Việc tách hai lần chạy giúp phân biệt kiểm thử logic script với kiểm tra tài nguyên thật.



```
(.venv) PS E:\BtapThucHanh\Antoanthongtin\cloud-security-project> .venv\Scripts\python.exe -m unittest tests.test_aws_integration -v
test_all_read_only_integration_checks_pass (tests.test_aws_integration.AwsIntegrationTests.test_all_read_only_integration_checks_pass) ... ok
test_detects_public_s3_bucket (tests.test_aws_integration.AwsIntegrationTests.test_detects_public_s3_bucket) ... ok
test_https_requires_listener_and_redirect (tests.test_aws_integration.AwsIntegrationTests.test_https_requires_listener_and_redirect) ... ok
test_normalizes_real_terraform_output_shape (tests.test_aws_integration.AwsIntegrationTests.test_normalizes_real_terraform_output_shape) ... ok
test_rejects_unrestricted_iam_statement_in_list_form (tests.test_aws_integration.AwsIntegrationTests.test_rejects_unrestricted_iam_statement_in_list_form) ... ok
test_rejects_wrong_account_and_url_scheme (tests.test_aws_integration.AwsIntegrationTests.test_rejects_wrong_account_and_url_scheme) ... ok
test_reports_failed_invariant_without_stopping_other_checks (tests.test_aws_integration.AwsIntegrationTests.test_reports_failed_invariant_without_stopping_other_checks) ... ok
test_unhealthy_target_reports_aws_reason (tests.test_aws_integration.AwsIntegrationTests.test_unhealthy_target_reports_aws_reason) ... ok
test_preserves_terraform_error_with_unicode_and_invalid_bytes (tests.test_aws_integration.TerraformOutputEncodingTests.test_preserves_terraform_error_with_unicode_and_invalid_bytes) ... ok
test_reads_utf8_json (tests.test_aws_integration.TerraformOutputEncodingTests.test_reads_utf8_json) ... ok
Ran 10 tests in 0.147s
OK
```

Hình 5.8: Mười unit test của mô-đun kiểm tra tích hợp AWS đều đạt trên mã nguồn hiện tại

Rà soát Terraform và kiểm tra sau triển khai tập trung vào S3 riêng tư, versioning, SSE-S3, policy từ chối HTTP; RDS không mở công khai, mã hóa và yêu cầu secure transport; EC2 yêu cầu IMDSv2, dùng instance profile, đăng ký SSM và không có ingress SSH; ALB active với máy đích ở trạng thái hoạt động bình thường. Các điều kiện phụ thuộc biến như HTTPS, Multi-AZ, SNS và kiểm thử khôi phục phải được báo cáo theo giá trị output thực tế của lần apply.

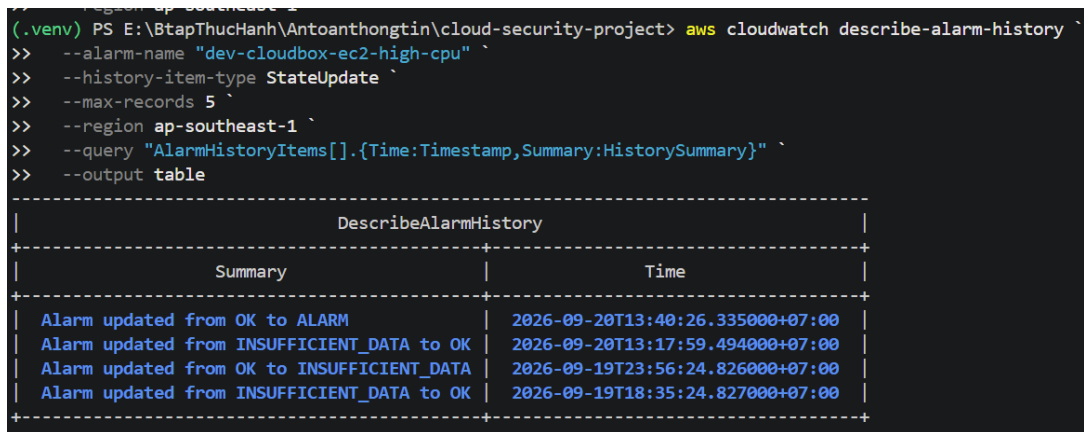
Terraform apply đã tạo môi trường AWS thử nghiệm; bằng chứng tương ứng được đánh mã AWS-01 đến AWS-08 tại Chương 4. Kết quả này xác nhận sự tồn tại và một số thuộc tính của tài nguyên ở thời điểm kiểm tra. Bản thân lần apply không tự động xác nhận email SES đã xác minh, alarm đã chuyển trạng thái, backup có thể phục hồi hoặc HTTPS đã bật; cảnh báo và hai cơ chế phục hồi được kiểm tra riêng trong đợt nghiệm thu ngày 20-09-2026 dưới đây.

Kết quả chạy thật được thể hiện tại Hình 4.8: cả chín kiểm tra tích hợp đều đạt, bao gồm định danh phiên AWS, EC2/SSM, RDS, S3, ALB/target, IAM, Secrets

Manager và observability. Khả năng truy cập giao diện qua endpoint ALB được đổi chiều riêng tại Hình 4.9.

5.10.1. Diễn tập cảnh báo và phục hồi trên AWS

Alarm dev-cloudbox-ec2-high-cpu được đưa thủ công từ trạng thái OK sang ALARM bằng API CloudWatch để kiểm tra đường chuyển trạng thái. Lịch sử tại Hình 5.9 ghi nhận sự kiện lúc 13:40:26 ngày 20-09-2026 theo múi giờ UTC+7. Sau khi xác nhận subscription email và gắn topic SNS vào alarm, nhóm thực hiện thêm một lần chuyển trạng thái để kiểm tra thông báo đến người nhận.

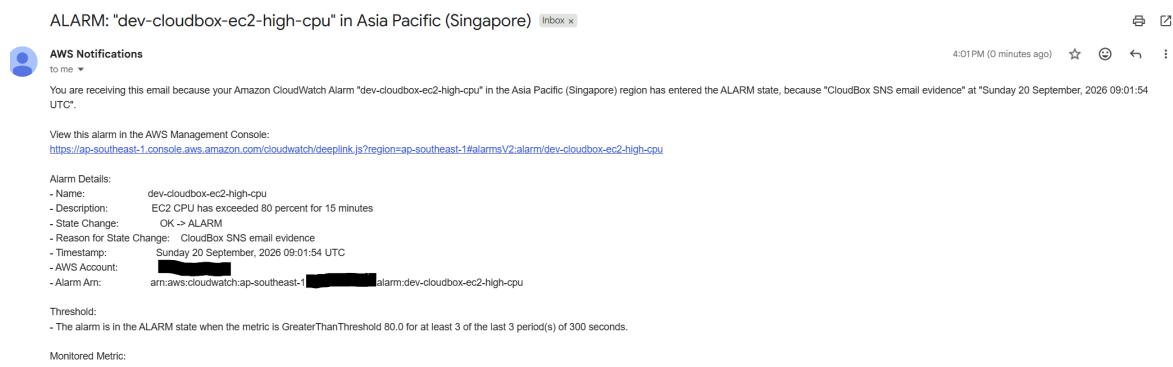


```
(.env) PS E:\BtapThucHanh\Antoanthongtin\cloud-security-project> aws cloudwatch describe-alarm-history \
>> --alarm-name "dev-cloudbox-ec2-high-cpu" \
>> --history-item-type StateUpdate \
>> --max-records 5 \
>> --region ap-southeast-1 \
>> --query "AlarmHistoryItems[].[Time:Timestamp,Summary:HistorySummary]" \
>> --output table
```

DescribeAlarmHistory	
Summary	Time
Alarm updated from OK to ALARM	2026-09-20T13:40:26.335000+07:00
Alarm updated from INSUFFICIENT_DATA to OK	2026-09-20T13:17:59.494000+07:00
Alarm updated from OK to INSUFFICIENT_DATA	2026-09-19T23:56:24.826000+07:00
Alarm updated from INSUFFICIENT_DATA to OK	2026-09-19T18:35:24.827000+07:00

Hình 5.9: Lịch sử CloudWatch ghi nhận alarm EC2 chuyển từ OK sang ALARM trong phép thử

Hình 5.10 ghi nhận email cảnh báo nhận được, với trạng thái OK -> ALARM, lý do CloudBox SNS email evidence và thời điểm 09:01:54 UTC ngày 20-09-2026 (16:01:54 UTC+7). Bằng chứng xác nhận luồng CloudWatch–SNS–hộp thư hoạt động trong phép thử kích hoạt thủ công. Mô tả ngưỡng CPU trong email là cấu hình của alarm; phép thử chưa chứng minh CPU thực sự vượt 80% trong 15 phút và không phải kiểm thử gửi OTP qua SES.



Hình 5.10: Email SNS nhận được khi kích hoạt thủ công alarm EC2 trên CloudWatch

Đối với S3, nhóm tải một object thử lên bucket đã bật versioning, xóa object

để tạo delete marker rồi xóa đúng phiên bản delete marker. Sau thao tác này, lệnh get-object truy xuất lại phiên bản trước, trả metadata mã hóa AES256 và nội dung đối chiếu “CloudBox S3 restore evidence – 2026-09-20” như Hình 5.11. Kết quả xác nhận phục hồi một object bị xóa logic; nó không chứng minh phục hồi hàng loạt hoặc tính nhất quán với bản ghi RDS.

```
{
  "Versions": [
    {
      "VersionId": "nn1CNITxCZ.jKSHuAoMA14_1.orMI_ba",
      "Latest": false
    }
  ],
  "DeleteMarkers": [
    {
      "VersionId": "oLW03cpGPC3KjYVP63QDWDhJfs.5o40S",
      "Latest": true
    }
  ]
}

(.venv) PS E:\BtapThucHanh\Antoanthongtin\cloud-security-project> aws s3api delete-object `
>> --bucket $bucket `
>> --key $key `
>> --version-id $deleted.VersionId `
>> --region ap-southeast-1
{
  "DeleteMarker": true,
  "VersionId": "oLW03cpGPC3KjYVP63QDWDhJfs.5o40S"
}

(.venv) PS E:\BtapThucHanh\Antoanthongtin\cloud-security-project> $restoredFile = Join-Path $env:TEMP "s3-restored.txt"
>>
>> aws s3api get-object `
>> --bucket $bucket `
>> --key $key `
>> --region ap-southeast-1 `
>> $restoredFile
>>
>> Get-Content -LiteralPath $restoredFile
{
  "AcceptRanges": "bytes",
  "LastModified": "2026-09-20T06:46:20+00:00",
  "ContentLength": 46,
  "ETag": "\"6befd61673abd84531c705f473d55e20\"",
  "ChecksumCRC64NME": "u1gvRS76iku=",
  "ChecksumType": "FULL_OBJECT",
  "VersionId": "nn1CNITxCZ.jKSHuAoMA14_1.orMI_ba",
  "ContentType": "binary/octet-stream",
  "ServerSideEncryption": "AES256",
  "Metadata": {}
}

CloudBox S3 restore evidence - 2026-09-20
```

Hình 5.11: Phục hồi object S3 bằng cách loại bỏ delete marker và đọc lại phiên bản trước

Đối với RDS, snapshot thủ công dev-cloudbox-mysql-report-20260920 của database chính đạt trạng thái available và có mã hóa. Snapshot được phục hồi thành instance độc lập dev-cloudbox-mysql-restore-test; kết quả truy vấn sau khôi phục cho thấy lớp db.t3.micro, trạng thái available, storage mã hóa và Public=False. Hình 5.12 chứng minh khả năng tạo instance từ snapshot mà không ghi đè database chính. Phép thử chưa chuyển kết nối ứng dụng sang instance phục hồi và chưa đối chiếu nội dung bảng, quyền chia sẻ hay tính nhất quán với S3; vì vậy không suy rộng thành diễn tập phục hồi toàn hệ thống.

DescribeDBSnapshots	
Created	2026-09-20T06:52:01.060000+00:00
Encrypted	True
Snapshot	dev-cloudbox-mysql-report-20260920
Source	dev-cloudbox-mysql
Status	available

DescribeDBInstances	
Class	db.t3.micro
Encrypted	True
Endpoint	dev-cloudbox-mysql-restore-test.cpg2sug6uekc.ap-southeast-1.rds.amazonaws.com
Identifier	dev-cloudbox-mysql-restore-test
Public	False
Status	available

Hình 5.12: Snapshot RDS mã hóa và instance phục hồi độc lập đạt trạng thái available

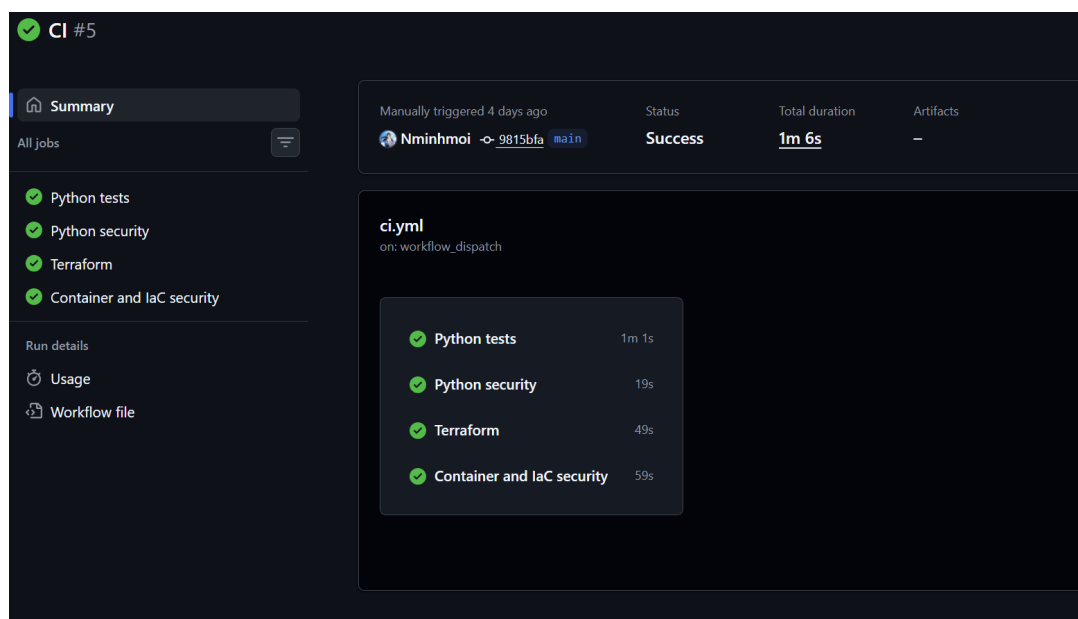
5.11. Kiểm thử CI/CD

Bây test cấu hình CI đều đạt; chúng đối chiếu workflow và các điều kiện mong đợi trong repository. Bổ sung cho kiểm thử cấu hình, Hình 5.13 ghi nhận lần chạy CI số 5 trên GitHub Actions với commit rút gọn 9815bfa, nhánh main, trạng thái Success và tổng thời gian 1 phút 6 giây. Cả bốn job Python tests, Python security, Terraform và Container and IaC security đều thành công. Đây là bằng chứng thực thi CI, không phải bằng chứng workflow triển khai AWS đã chạy thành công.

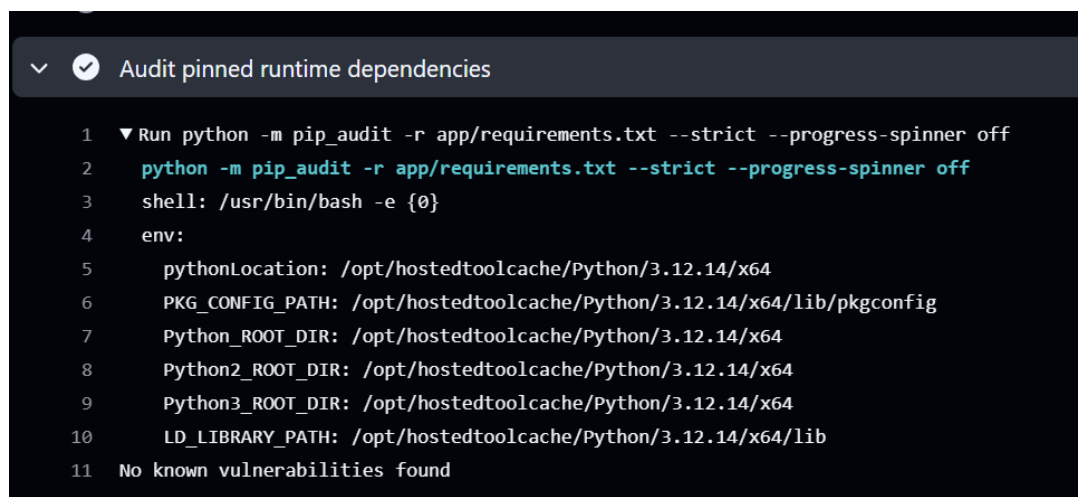
5.11.1. Kiểm tra thư viện phụ thuộc và mã nguồn Python

Hình 5.14 thể hiện bước kiểm tra thư viện phụ thuộc bằng pip-audit đối với app/requirements.txt, với kết quả “No known vulnerabilities found”. Như vậy, công cụ không phát hiện lỗ hổng đã biết trong các thư viện phụ thuộc được kiểm tra tại thời điểm chạy, theo nguồn dữ liệu lỗ hổng mà công cụ sử dụng. Kết quả này không khẳng định mọi thư viện đều an toàn tuyệt đối, không bao quát lỗi logic của ứng dụng và có thể thay đổi khi thông tin lỗ hổng mới được công bố. Ảnh cũng ghi nhận Python 3.12.14 trên runner GitHub Actions, khác với Python 3.14 trong máy ảo Ubuntu chạy bộ test local.

Bandit 1.9.4 quét app, scripts và security với hai tệp test được loại trừ theo lệnh CI. Tổng thống kê là 3.522 dòng mã, không có phát hiện High; thống kê vẫn ghi nhận ba cảnh báo Low và hai Medium. Bộ lọc High cho kết quả đạt nhưng không có nghĩa mọi mức cảnh báo đều bằng không.



Hình 5.13: Tổng quan lần chạy CI số 5 thành công trên GitHub Actions



Hình 5.14: Kết quả pip-audit trên GitHub Actions: không phát hiện lỗ hổng đã biết

```
Python security
succeeded 4 days ago in 19s

> ☒ Audit pinned runtime dependencies

▼ ☒ Scan Python code for high-severity issues

1 ▼ Run python -m bandit -r app scripts security -x security/iam/test_iam.py,security/monitoring/test_monitoring.py --severity-level high
2 python -m bandit -r app scripts security -x security/iam/test_iam.py,security/monitoring/test_monitoring.py --severity-level high
3 shell: /usr/bin/bash -e {}
4 env:
5   pythonLocation: /opt/hostedtoolcache/Python/3.12.14/x64
6   PKG_CONFIG_PATH: /opt/hostedtoolcache/Python/3.12.14/x64/lib/pkgconfig
7   Python_ROOT_DIR: /opt/hostedtoolcache/Python/3.12.14/x64
8   Python2_ROOT_DIR: /opt/hostedtoolcache/Python/3.12.14/x64
9   Python3_ROOT_DIR: /opt/hostedtoolcache/Python/3.12.14/x64
10  LD_LIBRARY_PATH: /opt/hostedtoolcache/Python/3.12.14/x64/lib
11 [main] INFO profile include tests: None
12 [main] INFO profile exclude tests: None
13 [main] INFO cli include tests: None
14 [main] INFO cli exclude tests: None
15 [main] INFO running on Python 3.12.14
16 Run started:2026-09-13 11:01:13.418222+00:00
17
18 Test results:
19   No issues identified.
20
21 Code scanned:
22   Total lines of code: 3522
23   Total lines skipped (#nosec): 0
24   Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0
25
26 Run metrics:
27   Total issues (by severity):
28     Undefined: 0
29     Low: 3
30     Medium: 2
31     High: 0
32   Total issues (by confidence):
33     Undefined: 0
34     Low: 1
35     Medium: 1
36     High: 3
37 Files skipped (0):
```

Hình 5.15: Kết quả Bandit: không có High, còn ba Low và hai Medium

5.11.2. Phân tích các cảnh báo Bandit

Kết quả ở Hình 5.15 cần được đọc theo hai tiêu chí khác nhau: mức độ nghiêm trọng (Severity) và độ tin cậy của phát hiện (Confidence). Severity cho biết mức ảnh hưởng tiềm tàng mà quy tắc của công cụ gán cho cảnh báo, gồm Low, Medium và High. Confidence phản ánh mức độ chắc chắn của công cụ đối với phát hiện đó. Vì vậy, một cảnh báo có Confidence High không đồng nghĩa với một lỗ hổng có Severity High. Các con số này giúp định hướng rà soát, nhưng không thay thế việc xem xét đầu vào, đường thực thi và môi trường triển khai.

Trong workflow của dự án, Bandit được chạy với tùy chọn `--severity-level high`. Do không có phát hiện đạt ngưỡng này, bước kiểm tra trả về thành công và phần kết quả hiển thị “No issues identified”. Tuy nhiên, thống kê vẫn ghi nhận ba cảnh báo Low và hai cảnh báo Medium. Hai thông tin này không mâu thuẫn: quy trình CI/CD đã đạt ngưỡng kiểm tra được đặt ra, chứ không khẳng định toàn bộ mã nguồn không còn vấn đề bảo mật.

Để làm rõ các cảnh báo còn lại, phần phân tích dưới đây đối chiếu kết quả quét các tệp Python đang được Git theo dõi trong bản mã nguồn hiện có, với hai tệp test được loại trừ như cấu hình CI. Lần rà soát này ghi nhận cùng số lượng ba Low và hai Medium. Đây là phần bổ sung từ mã nguồn hiện tại; ảnh tổng kết CI không tự cung cấp vị trí chi tiết của từng phát hiện và cũng không chứng minh hai bản mã nguồn hoàn toàn giống nhau.

Cảnh báo về địa chỉ lắng nghe của ứng dụng

Cảnh báo B104, mức Medium, xuất hiện tại lệnh `app.run(host="0.0.0.0", port=5000)` trong `app/app.py`. Địa chỉ này cho phép ứng dụng lắng nghe trên mọi giao diện IPv4 của môi trường chạy. Nếu cổng dịch vụ được mở ra mạng ngoài, phạm vi truy cập có thể rộng hơn mong muốn khi phát triển hoặc thử nghiệm.

Trong CloudBox, lệnh trên nằm trong nhánh khởi chạy trực tiếp tệp Python. Container sử dụng Gunicorn nên không thực thi nhánh này để khởi động máy chủ. Việc lắng nghe trên mọi giao diện trong container có thể là lựa chọn cần thiết để nhận lưu lượng qua cổng được ánh xạ; do đó không thể chỉ dựa vào địa chỉ `0.0.0.0` để kết luận hệ thống có lỗ hổng. Điều cần kiểm tra là cổng nào được công khai, nguồn nào được phép kết nối và firewall hoặc security group có giới hạn đúng phạm vi hay không. Cảnh báo này được xem là một điểm cần kiểm soát khi triển khai, không phải bằng chứng ứng dụng đã bị truy cập trái phép.

Cảnh báo về xây dựng truy vấn SQL

Cảnh báo B608, mức Medium và độ tin cậy Low, nằm trong `security/iam/user_evaluator.py`. Công cụ phát hiện câu truy vấn được tạo bằng f-string nên đánh dấu khả năng SQL Injection. Nguy cơ này sẽ đáng lo nếu dữ liệu không tin cậy được ghép trực tiếp vào câu SQL và làm thay đổi ý nghĩa của truy vấn.

Qua đối chiếu đoạn mã hiện tại, các phần được chèn vào truy vấn chỉ được lựa chọn từ những chuỗi cố định. Chẳng hạn, biểu thức `email` là `u.email` hoặc `NULL`; phần nói bằng vai trò là một mệnh đề `JOIN` định sẵn hoặc chuỗi rỗng. Không thấy dữ liệu nhập từ biểu mẫu người dùng được ghép trực tiếp vào các vị trí này. Vì vậy, chưa có căn cứ xác nhận đường khai thác SQL Injection tại đoạn mã được rà soát. Nếu chức năng sau này được mở rộng để nhận điều kiện lọc hoặc tên trường từ bên ngoài, cần đánh giá lại và không tiếp tục dựa vào nhận xét của phiên bản hiện tại.

Các cảnh báo khi gọi Terraform bằng subprocess

Ba cảnh báo Low gồm B404, B603 và B607 tập trung trong `scripts/aws_integration_test.py`. B404 lưu ý việc sử dụng mô-đun `subprocess`; B603 yêu cầu xem xét đầu vào khi gọi chương trình ngoài; B607 cảnh báo việc gọi executable bằng tên `terraform` thay vì đường dẫn tuyệt đối. Đây là ba góc kiểm tra quanh cùng một nhóm thao tác, không nhất thiết tương ứng với ba đường tấn công độc lập.

Script hiện truyền lệnh và tham số dưới dạng danh sách, không bật `shell=True`. Cách gọi này tránh để shell diễn giải chuỗi đầu vào thành nhiều lệnh, qua đó giảm rủi ro chèn lệnh shell. Tuy nhiên, việc tìm Terraform qua biến môi trường `PATH` vẫn phụ thuộc độ tin cậy của máy chạy. Nếu executable hoặc thư mục trong `PATH` bị thay thế, script có thể gọi nhầm chương trình. Bởi vậy, môi trường kiểm thử cần sử dụng bản Terraform được cài đặt có kiểm soát, bảo vệ đường dẫn thực thi và không nhận thư mục Terraform từ nguồn không tin cậy.

Từ các phân tích trên, kết quả Bandit được đánh giá là đạt ngưỡng High của CI, đồng thời còn năm phát hiện cần được quản lý theo ngữ cảnh. Rà soát chưa xác nhận khả năng khai thác của các phát hiện này trong những đoạn mã đã xem xét; điều đó không tương đương với kết luận chúng luôn vô hại trong mọi môi trường. Các giới hạn về mạng, nguồn đầu vào và chương trình thực thi cần được duy trì và kiểm tra lại khi hệ thống thay đổi. Việc ghi nhận rõ những điều kiện này phù hợp hơn với mục tiêu đánh giá an toàn thông tin của đề tài so với chỉ dựa vào trạng thái thành công của quy trình CI/CD.

5.11.3. Kiểm tra cấu hình hạ tầng và Docker image

Ảnh Trivy tại Hình 5.16 ghi nhận cột Misconfigurations bằng 0 ở các mục Dockerfile và Terraform được hiển thị. Dấu gạch ngang trong cột Secrets không được diễn giải thành số phát hiện bằng 0. Kết luận chỉ áp dụng cho phạm vi bộ quét, ngưỡng High/Critical và các ngoại lệ của lần chạy này.

Target	Type	Secrets	Misconfigurations
app/requirements.txt	pip	-	-
docker/Dockerfile	dockerfile	-	0
terraform	terraform	-	0
terraform/database.tf	terraform	-	0
terraform/load-balancer.tf	terraform	-	0
terraform/observability.tf	terraform	-	0
terraform/security-groups.tf	terraform	-	0
terraform/storage.tf	terraform	-	0

Hình 5.16: Bảng kết quả Trivy đối với Dockerfile và cấu hình Terraform

Ảnh quét image tại Hình 5.17 hiển thị image mang tag commit bắt đầu bằng 9815bfa, tương ứng mã commit rút gọn trên trang CI. Các hàng hệ điều hành và package hiển thị đều có giá trị Vulnerabilities bằng 0 theo chính sách quét đã cấu hình. Bước quét image sử dụng ngưỡng High/Critical và bỏ qua lỗ hổng chưa có bản sửa; kết quả này không khẳng định image không còn bất kỳ lỗ hổng nào. Bộ ảnh cũng chưa liên kết image này với một instance AWS đang chạy.

5.12. Kiểm tra nội dung tài liệu sau khi khởi động lại container

Phép thử trên Ubuntu thực hiện khởi động lại hai dịch vụ db và web, sau đó kiểm tra cả hai trở về trạng thái healthy. Hai bản requirements-dev.txt lưu trong thư mục tải về trước và sau phép thử có cùng SHA-256, như Hình 5.18. Kết quả xác nhận nội dung hai bản tệp đối chiếu không thay đổi trong phép thử. Ảnh terminal chưa thể hiện thao tác tải trên giao diện và chưa kiểm chứng lại quyền chia sẻ của các tài khoản; vì vậy không suy rộng thành kết luận toàn bộ dữ liệu và phân quyền đều được bảo toàn.

Target	Type	Vulnerabilities
cloudbox-ci:9815bfab598afc84cfc6919b56f4e4ce3485ca7 (debian 13.7)	debian	0
usr/local/lib/python3.12/site-packages/Flask_Migrate-4.1.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/alembic-1.20.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/blinker-1.9.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/boto3-1.43.89.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/botocore-1.43.93.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/click-8.5.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/deprecated-1.3.1.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/Flask-3.1.3.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/Flask_limiter-4.1.1.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/flask_sqlalchemy-3.1.1.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/flask_wtf-1.3.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/greenlet-3.5.5.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/gunicorn-26.2.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/itsdangerous-2.2.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/jinja2-3.1.6.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/jmespath-1.1.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/limits-5.8.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/mako-1.4.1.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/markupsafe-3.0.3.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/ordered_set-4.1.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/packaging-26.3.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/pymysql-1.2.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/python_dateutil-2.9.0.post0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/s3transfer-0.19.2.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/six-1.17.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/sqlalchemy-2.0.52.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/typing_extensions-4.16.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/urllib3-2.7.0.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/werkzeug-3.1.8.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/wrapt-2.4.1.dist-info/METADATA	python-pkg	0
usr/local/lib/python3.12/site-packages/wtforms-3.2.2.dist-info/METADATA	python-pkg	0

Hình 5.17: Kết quả Trivy quét lỗ hổng Docker image theo ngưỡng của CI

Đây là kiểm tra sau khởi động lại, không phải phục hồi từ bản sao lưu.

```

nminh@localhost:~/cloud-security-project$ dc restart db web
[+] restart 0/2
  i. Container docker-web-1 Restarting
  i. Container docker-db-1 Restarting
nminh@localhost:~/cloud-security-project$ dc ps
NAME          IMAGE          COMMAND                SERVICE  CREATED   STATUS    PORTS
docker-db-1   mysql:8.4      "docker-entrypoint.s..." db        3 hours ago Up 2 minutes (healthy) 127.0.0.1:3306->3306/tcp, 33060/tcp
docker-web-1  cloud-security-app:local "sh -c 'exec gunico..." web       3 hours ago Up 2 minutes (healthy) 0.0.0.0:5000->5000/tcp, [::]:5000->5000/tcp
nminh@localhost:~/cloud-security-project$ ^C
nminh@localhost:~/cloud-security-project$ sha256sum ~/Downloads/truoc/requirements-dev.txt ~/Downloads/sau/requirements-dev.txt
84ea9c08843bcd06ed6e17d4834b18cbc62cd72a595b3820a74509fde69f6fb6 /home/nminh/Downloads/truoc/requirements-dev.txt
84ea9c08843bcd06ed6e17d4834b18cbc62cd72a595b3820a74509fde69f6fb6 /home/nminh/Downloads/sau/requirements-dev.txt

```

Hình 5.18: Hai dịch vụ healthy sau khởi động lại và SHA-256 hai bản tài liệu trùng nhau

5.13. Mô phỏng các kịch bản tấn công

5.13.1. Phạm vi và quy trình thực hiện

Các kịch bản được thực hiện có kiểm soát trên tài khoản, dữ liệu và hạ tầng thử nghiệm của nhóm. Không sử dụng tải lớn, mã độc thật hoặc khai thác hệ thống bên thứ ba. Với mỗi kịch bản, nhóm xác định trạng thái ban đầu, gửi yêu cầu tấn công, ghi phản hồi HTTP hoặc trạng thái AWS, sau đó kiểm tra dữ liệu và nhật ký. Dữ liệu thử được xóa sau khi hoàn tất.

Những kịch bản có thể tái lập bằng test client được tự động hóa trong bộ test. Kịch bản phụ thuộc trình duyệt, Docker hoặc AWS được thực hiện ở môi trường tương ứng và lưu ảnh theo mã bằng chứng. Trạng thái “đạt một phần” được sử dụng khi kiểm soát liên quan hoạt động nhưng phép thử chưa đủ để loại trừ toàn bộ lớp tấn công.

5.13.2. Tấn công đăng nhập và OTP

Kịch bản ATK-01 gửi liên tiếp thông tin đăng nhập sai để kích hoạt giới hạn năm yêu cầu mỗi phút và khóa tài khoản sau năm lần xác thực thất bại. Kết quả mong đợi là yêu cầu tiếp theo bị từ chối, thời điểm khóa được lưu và sự kiện được ghi log. Cần phân biệt phản hồi do rate limit với phản hồi do trạng thái khóa trong cơ sở dữ liệu.

Kịch bản ATK-02 nhập OTP sai quá ba lần, sử dụng OTP hết hạn và thử lại mã đã bị thay thế. Kết quả mong đợi là hệ thống không cấp quyền đặt lại mật khẩu. Bộ test hiện có xác nhận giới hạn lần thử và hết hạn OTP; quyền đặt lại mật khẩu sau bước xác minh vẫn cần token giao dịch một lần phía máy chủ nên được ghi là rủi ro còn lại.

5.13.3. Vượt quyền và IDOR/BOLA

Kịch bản ATK-03 đăng nhập bằng người dùng B rồi thay mã tài liệu trong URL/API để yêu cầu tài liệu riêng của người dùng A. Phép thử được lặp lại ở ba trạng thái: chưa chia sẻ, đã chia sẻ và đã thu hồi. Hệ thống phải từ chối trước khi chia sẻ, cho phép đọc khi quan hệ chia sẻ hợp lệ và từ chối yêu cầu mới sau khi thu hồi.

Kịch bản ATK-04 dùng tài khoản thường gọi endpoint quản trị và endpoint thay đổi role/permission. Kết quả mong đợi là phản hồi 403 hoặc chuyển hướng phù hợp, không có thay đổi dữ liệu và không tạo nhật ký giả cho hành động không diễn ra. Các test RBAC và vòng đời chia sẻ cung cấp bằng chứng tự động cho hai kịch bản này.

Bảng chứng trình duyệt bổ sung cho ATK-03 gồm trạng thái chia sẻ ở Hình 5.4–5.5 và hai kết quả từ chối ở Hình 5.6–5.7. Cặp Hình 5.2–5.3 bổ sung cho ATK-04 ở thao tác mở trang quản trị người dùng; cặp ảnh này không kiểm chứng các yêu cầu thay đổi role/permission.

5.13.4. Tấn công vào ứng dụng web và tệp tải lên

Kịch bản ATK-05 gửi yêu cầu thay đổi dữ liệu khi thiếu hoặc sai CSRF token; yêu cầu phải bị từ chối trước khi cập nhật dữ liệu. Kịch bản ATK-06 đưa chuỗi HTML/JavaScript vô hại vào trường tên hiển thị và kiểm tra mã nguồn phản hồi trong trình duyệt. CSP và auto-escape là lớp giảm thiểu, nhưng kết quả header không đủ để kết luận toàn bộ giao diện không có XSS; vì vậy kịch bản này chỉ được đánh giá một phần nếu chưa rà soát mọi vị trí render.

Kịch bản ATK-07 đổi phần mở rộng của tệp, khai báo MIME không phù hợp, gửi tệp rỗng, tệp vượt giới hạn và tệp làm vượt hạn mức lưu trữ. Kịch bản ATK-08 dùng tệp nén nhỏ có thành phần vượt thư mục hoặc tỷ lệ nén khai báo vượt ngưỡng. Không tạo ZIP bomb thật; mẫu thử chỉ đủ kích hoạt nhánh kiểm tra. Kết quả mong đợi là tệp bị từ chối trước khi tạo siêu dữ liệu hợp lệ hoặc được dọn khi giao dịch cơ sở dữ liệu thất bại.

5.13.5. Tấn công vào phiên và tài nguyên AWS

Kịch bản ATK-09 giữ một phiên đăng nhập cũ, thay đổi mật khẩu ở phiên khác rồi thử truy cập lại. Giá trị `session_version` phải làm phiên cũ mất hiệu lực. Đăng xuất chưa thu hồi được một bản sao cookie ở phía máy chủ, do đó không được gộp hai thuộc tính này thành một kết luận.

Kịch bản ATK-10 kiểm tra truy cập S3 ẩn danh và kết nối trực tiếp đến các bề mặt không được công khai. Kết quả mong đợi gồm S3 trả Access Denied, RDS không mở công khai, EC2 không mở SSH và cổng ứng dụng chỉ nhận từ security group của ALB. Kiểm tra cấu hình và trạng thái tài nguyên chứng minh cấu hình; phép thử kết nối từ ngoài mạng cung cấp bằng chứng bổ sung cho đường truy cập thực tế.

Hình 5.19 ghi nhận nhóm kiểm soát bảo mật ứng dụng hoàn tất 8 test trong 2,463 giây và trả OK. Nhóm storage hiển thị bốn ca có trạng thái ok cùng dòng tổng kết 4 test trong 0,047 giây; kết quả toàn bộ suite được đối chiếu thêm ở Hình 5.21. Các ca này đã nằm trong tổng 78 bài kiểm thử ứng dụng, nên không cộng thêm vào tổng 88. Ảnh thể hiện kiểm thử tự động bằng dữ liệu thử, không phải ảnh kiểm tra tài nguyên

Bảng 5.2: Tổng hợp kịch bản mô phỏng tấn công

Mã	Kịch bản	Nguy cơ	Kết quả quan sát/điều kiện đạt	Trạng thái
ATK-01	Brute force đăng nhập	R01, R02	Rate limit và khóa tạm thời được kích hoạt; có test hồi quy	Đạt
ATK-02	OTP sai, hết hạn, thay thế	R02, R03	Không cấp quyền đặt lại mật khẩu với OTP không hợp lệ	Đạt trong phạm vi OTP
ATK-03	Đổi ID tài liệu	R04, R10	Quyền thay đổi đúng theo owner/share/revoke	Đạt
ATK-04	User gọi chức năng admin	R05	Bị từ chối và dữ liệu không thay đổi	Đạt
ATK-05	Thiếu/sai CSRF token	R06	Yêu cầu thay đổi trạng thái bị từ chối	Đạt
ATK-06	Payload XSS vô hại	R07	Có CSP/escape; cần rà soát mọi điểm render	Đạt một phần
ATK-07	Giả mạo tệp/MIME/quá dung lượng	R08, R09	Validator hoặc giới hạn request từ chối mẫu thử	Đạt
ATK-08	Path traversal/archive bất thường	R08, R09	Storage key và tệp nén member bị từ chối	Đạt
ATK-09	Dùng phiên cũ sau đổi mật khẩu	R03	Phiên version không còn khớp	Đạt
ATK-10	Truy cập trực tiếp tài nguyên AWS	R11–R14	S3/RDS/EC2 bị giới hạn; đối chiếu AWS-02–AWS-06	Theo bảng chứng AWS

```
(.venv-ubuntu) minh@localhost:~/cloud-security-project$ python -m unittest discover \
-s tests -p "test_security_controls.py" -v
[2026-09-17 12:23:13.044] WARNING in app: Using database: sqlite:///tmp/tmpc8arl3j9/bootstrap.db
[2026-09-17 12:23:13.097] WARNING in app: Using database: sqlite:///tmp/tmpirpti8ii/security.db
test_csrf_rejects_missing_token_and_accepts_header (test_security_controls.SecurityControlsTests.test_csrf_rejects_missing_token_and_accepts_header) ... ok
test_failed_otp_delivery_removes_code_and_hides_account_state (test_security_controls.SecurityControlsTests.test_failed_otp_delivery_removes_code_and_hides_account_state) ... [2026-09-17 12:23:14.454] ERROR in auth: Gđt
OTP thất bại
Traceback (most recent call last):
  File "/home/minh/cloud-security-project/app/routes/auth.py", line 178, in forgot_password
    send_otp_email(email, otp)
    ~~~~~^~~~~~
  File "/usr/lib/python3.14/unittest/mock.py", line 1176, in __call__
    return self._mock_call(*args, **kwargs)
    ~~~~~^~~~~~
  File "/usr/lib/python3.14/unittest/mock.py", line 1188, in _mock_call
    return self._execute_mock_call(*args, **kwargs)
    ~~~~~^~~~~~
  File "/usr/lib/python3.14/unittest/mock.py", line 1241, in _execute_mock_call
    raise effect
services.email_service.EmailDeliveryError: SES unavailable
test_login_endpoint_is_rate_limited (test_security_controls.SecurityControlsTests.test_login_endpoint_is_rate_limited) ... ok
test_login_lockout_records_audit_events (test_security_controls.SecurityControlsTests.test_login_lockout_records_audit_events) ... ok
test_password_policy_and_post_only_logout (test_security_controls.SecurityControlsTests.test_password_policy_and_post_only_logout) ... ok
test_password_reset_invalidates_existing_session (test_security_controls.SecurityControlsTests.test_password_reset_invalidates_existing_session) ... ok
test_security_headers_and_nonce_are_present (test_security_controls.SecurityControlsTests.test_security_headers_and_nonce_are_present) ... ok
test_upload_rejects_dangerous_and_oversized_files (test_security_controls.SecurityControlsTests.test_upload_rejects_dangerous_and_oversized_files) ... ok
.....
Ran 8 tests in 2.463s

(.venv-ubuntu) minh@localhost:~/cloud-security-project$ python -m unittest discover \
-s tests -p "test_storage_service.py" -v
test_s3_upload_download_and_delete (test_storage_service.StorageServiceTests.test_s3_upload_download_and_delete) ... ok
test_storage_operations_reject_path_traversal (test_storage_service.StorageServiceTests.test_storage_operations_reject_path_traversal) ... ok
test_validation_rejects_suspicious_archive_ratio (test_storage_service.StorageServiceTests.test_validation_rejects_suspicious_archive_ratio) ... ok
test_validation_returns_checksun_and_rejects_archive_traversal (test_storage_service.StorageServiceTests.test_validation_returns_checksun_and_rejects_archive_traversal) ... ok
.....
Ran 4 tests in 0.047s
```

Hình 5.19: Kiểm thử tự động các tình huống bảo mật ứng dụng và lưu trữ trên Ubuntu

AWS thật.

Kết quả “đạt” trong Bảng 5.2 chỉ áp dụng cho mẫu thử và phiên bản hệ thống được đánh giá. Nó không tương đương chứng nhận an toàn tuyệt đối. Mỗi ảnh hoặc log kèm báo cáo cần hiển thị mã kịch bản, thời gian, điều kiện ban đầu và phản hồi cuối, đồng thời che token, cookie và dữ liệu định danh không cần thiết.

5.14. Tổng hợp kết quả

Bảng 5.3: Kết quả bộ kiểm thử ứng dụng chạy lại trong tháng 09-2026

Nhóm test	Tổng	Đạt	Lỗi
API và vòng đời tài liệu	16	16	0
Quản trị và RBAC	22	22	0
Kiểm soát bảo mật ứng dụng	8	8	0
Storage service	4	4	0
Cấu hình ứng dụng	5	5	0
Gửi email	3	3	0
Sao lưu SQLite	3	3	0
Smoke test deployment bằng mô phỏng	3	3	0
Tích hợp AWS bằng mô phỏng	7	7	0
Cấu hình CI	7	7	0
Tổng bộ ứng dụng	78	78	0

Bộ ảnh ngày 17-09-2026 ghi nhận 78 bài kiểm thử ứng dụng hoàn tất trong 14,023 giây và 10 bài kiểm thử mô-đun bảo mật hoàn tất trong 0,042 giây; cả hai đều trả OK. Thời gian này mô tả lần chạy test trên máy ảo, không phải thời gian đáp ứng của ứng dụng. Trong log có traceback EmailDeliveryError: SES unavailable do test cố ý mô phỏng lỗi gửi OTP. Trạng thái ok ngay sau traceback xác nhận ứng dụng xử lý tình huống này theo điều kiện kiểm tra của test. Tổng cộng 88/88 bài kiểm thử tự động đạt, tương ứng 100% số bài kiểm thử đã chạy. Mẫu số là số phương thức kiểm thử được thực thi, không phải số nguy cơ có thể xảy ra. Kết quả Docker, AWS và mô phỏng tấn công được báo cáo riêng, không cộng vào mẫu số 88. Chưa đo độ bao phủ mã nguồn nên không ghi tỷ lệ bao phủ mã nguồn, và chưa kiểm thử tải nên không ghi thông lượng hay thời gian đáp ứng của hệ thống.

5.15. Đánh giá mô hình bảo vệ dữ liệu

5.15.1. Mức độ bảo vệ tính bí mật

Ứng dụng có cơ chế xác thực, RBAC và quyền sở hữu hoặc quyền được chia sẻ giúp hạn chế truy cập nội dung. Các tình huống phải bị từ chối kiểm tra người không có quyền bị từ chối. Môi trường AWS bổ sung S3 riêng tư, RDS không mở công khai

```
(.venv-ubuntu) minikubectl -n cloud-security-project python -m unittest discover -s tests -v 2>&1 |
[ 2026-09-17 12:03:34.103] WARNING in app: Using database: sqlite://:/tmp/tmpicavef3t/test.db
test_admin_can_change_user_role (test_admin.rbac.AdminRbacTests.test_admin_can_change_user_role) ... ok
test_admin_can_revoke_and_assign_role_permission (test_admin.rbac.AdminRbacTests.test_admin_can_revoke_and_assign_role_permission) ... ok
test_admin_cannot_land_in_the_user_document_workspace (test_admin.rbac.AdminRbacTests.test_admin_cannot_land_in_the_user_document_workspace) ... ok
test_admin_document_deletion_is_audited (test_admin.rbac.AdminRbacTests.test_admin_document_deletion_is_audited) ... ok
test_admin_document_page_exposes_metadata_but_no_download_link (test_admin.rbac.AdminRbacTests.test_admin_document_page_exposes_metadata_but_no_download_link) ... ok
test_admin_manager_returns_inserted_id (test_admin.rbac.AdminRbacTests.test_admin_manager_returns_inserted_id) ... ok
test_async_login_returns_inline_error_or_role_redirect (test_admin.rbac.AdminRbacTests.test_async_login_returns_inline_error_or_role_redirect) ... ok
test_browser_login_failure_stays_on_login_page_and_clears_fields (test_admin.rbac.AdminRbacTests.test_browser_login_failure_stays_on_login_page_and_clears_fields) ... ok
test_delete_user_is_audited_and_keeps_target_identity (test_admin.rbac.AdminRbacTests.test_delete_user_is_audited_and_keeps_target_identity) ... ok
test_delete_user_removes_incoming_and_outgoing_shares (test_admin.rbac.AdminRbacTests.test_delete_user_removes_incoming_and_outgoing_shares) ... ok
test_delete_user_removes_private_storage_objects (test_admin.rbac.AdminRbacTests.test_delete_user_removes_private_storage_objects) ... ok
test_disabled_user_cannot_login_or_keep_a_session (test_admin.rbac.AdminRbacTests.test_disabled_user_cannot_login_or_keep_a_session) ... ok
test_login_accepts_trimmed_case_insensitive_username_or_email (test_admin.rbac.AdminRbacTests.test_login_accepts_trimmed_case_insensitive_username_or_email) ... ok
test_login_redirects_each_role_to_its_home_page (test_admin.rbac.AdminRbacTests.test_login_redirects_each_role_to_its_home_page) ... ok
test_normal_user_cannot_access_admin (test_admin.rbac.AdminRbacTests.test_normal_user_cannot_access_admin) ... ok
test_public_home_and_authenticated_home_redirects (test_admin.rbac.AdminRbacTests.test_public_home_and_authenticated_home_redirects) ... ok
test_rejected_self_management_does_not_create_audit_log (test_admin.rbac.AdminRbacTests.test_rejected_self_management_does_not_create_audit_log) ... ok
test_remember_me_controls_permanent_session (test_admin.rbac.AdminRbacTests.test_remember_me_controls_permanent_session) ... ok
test_role_endpoint_validates_json_and_references (test_admin.rbac.AdminRbacTests.test_role_endpoint_validates_json_and_references) ... ok
test_toggle_user_active_is_audited (test_admin.rbac.AdminRbacTests.test_toggle_user_active_is_audited) ... ok
test_user_management_api_requires_admin (test_admin.rbac.AdminRbacTests.test_user_management_api_requires_admin) ... ok
test_users_page_marks_the_real_role (test_admin.rbac.AdminRbacTests.test_users_page_marks_the_real_role) ... ok
test_auth_requires_login_and_returns_current_user (test_api.ApiTests.test_auth_requires_login_and_returns_current_user) ... ok
test_database_failure_removes_orphaned_upload (test_api.ApiTests.test_database_failure_removes_orphaned_upload) ... ok
test_document_lifecycle_and_sharing (test_api.ApiTests.test_document_lifecycle_and_sharing) ... ok
test_document_views_favorite_and_owner_boundaries (test_api.ApiTests.test_document_views_favorite_and_owner_boundaries) ... ok
test_download_blocks_pending_and_infected_scan_status (test_api.ApiTests.test_download_blocks_pending_and_infected_scan_status) ... ok
test_favorite_requires_boolean (test_api.ApiTests.test_favorite_requires_boolean) ... ok
test_login_logout_and_inactive_account (test_api.ApiTests.test_login_logout_and_inactive_account) ... ok
test_purge_command_removes_expired_trash_and_file (test_api.ApiTests.test_purge_command_removes_expired_trash_and_file) ... ok
test_registration_validates_input_and_rejects_duplicates (test_api.ApiTests.test_registration_validates_input_and_rejects_duplicates) ... ok
test_revoked_create_permission_blocks_api_upload (test_api.ApiTests.test_revoked_create_permission_blocks_api_upload) ... ok
test_share_lifecycle_validation_and_authorization (test_api.ApiTests.test_share_lifecycle_validation_and_authorization) ... ok
test_soft_delete_records_timestamp_and_restore_clears_it (test_api.ApiTests.test_soft_delete_records_timestamp_and_restore_clears_it) ... ok
test_upload_enforces_user_quota (test_api.ApiTests.test_upload_enforces_user_quota) ... ok
test_upload_persists_safe_metadata_and_unique_storage_keys (test_api.ApiTests.test_upload_persists_safe_metadata_and_unique_storage_keys) ... ok
test_upload_requires_authentication_and_file (test_api.ApiTests.test_upload_requires_authentication_and_file) ... ok
test_user_search_validation_and_visibility (test_api.ApiTests.test_user_search_validation_and_visibility) ... ok
test_all_read_only_integration_checks_pass (test_aws_integration.AwsIntegrationTests.test_all_read_only_integration_checks_pass) ... ok
test_detects_public_s3_bucket (test_aws_integration.AwsIntegrationTests.test_detects_public_s3_bucket) ... ok
test_https_requires_listener_and_redirect (test_aws_integration.AwsIntegrationTests.test_https_requires_listener_and_redirect) ... ok
test_normalizes_real_terraform_output_shape (test_aws_integration.AwsIntegrationTests.test_normalizes_real_terraform_output_shape) ... ok
test_rejects_unrestricted_iam_statement_in_list_form (test_aws_integration.AwsIntegrationTests.test_rejects_unrestricted_iam_statement_in_list_form) ... ok
test_rejects_wrong_account_and_url_scheme (test_aws_integration.AwsIntegrationTests.test_rejects_wrong_account_and_url_scheme) ... ok
```

Hình 5.20: Chi tiết các kiểm thử quản trị, RBAC và API trong bộ ứng dụng trên Ubuntu

```
test_reports_failed_invariant_without_stopping_other_checks (test_aws_integration.AwsIntegrationTests.test_reports_failed_invariant_without_stopping_other_checks) ... ok
test_all_actions_are_pinned_to_full_commit_sha (test_ci.configuration.CiConfigurationTests.test_all_actions_are_pinned_to_full_commit_sha) ... ok
test_ci_has_read_only_permissions_and_security_gates (test_ci.configuration.CiConfigurationTests.test_ci_has_read_only_permissions_and_security_gates) ... ok
test_dependabot_covers_every_pipeline_ecosystem (test_ci.configuration.CiConfigurationTests.test_dependabot_covers_every_pipeline_ecosystem) ... ok
test_deploy_is_manual_only_and_apply_is_guarded (test_ci.configuration.CiConfigurationTests.test_deploy_is_manual_only_and_apply_is_guarded) ... ok
test_runtime_image_applies_security_updates_and_removes_build_tools (test_ci.configuration.CiConfigurationTests.test_runtime_image_applies_security_updates_and_removes_build_tools) ... ok
test_security_tool_versions_are_pinned (test_ci.configuration.CiConfigurationTests.test_security_tool_versions_are_pinned) ... ok
test_driver_exceptions_are_scoped_and_documented (test_ci.configuration.CiConfigurationTests.test_driver_exceptions_are_scoped_and_documented) ... ok
test_database_url_takes_precedence_and_selects_pymysql (test_config.DatabaseConfigs.test_database_url_takes_precedence_and_selects_pymysql) ... ok
test_discrete_mysql_settings_escape_password (test_config.DatabaseConfigs.test_discrete_mysql_settings_escape_password) ... ok
test_incomplete_mysql_settings_fails_fast (test_config.DatabaseConfigs.test_incomplete_mysql_settings_fails_fast) ... ok
test_invalid_mysql_port_fails_fast (test_config.DatabaseConfigs.test_invalid_mysql_port_fails_fast) ... ok
test_mysql_tls_ca_is_passed_to_driver (test_config.DatabaseConfigs.test_mysql_tls_ca_is_passed_to_driver) ... ok
test_backup_and_restore_refuse_to_overwrite (test_database_backup.DatabaseBackupsTests.test_backup_and_restore_refuse_to_overwrite) ... ok
test_backup_is_consistent_and_restore_creates_new_database (test_database_backup.DatabaseBackupsTests.test_backup_is_consistent_and_restore_creates_new_database) ... ok
test_verify_rejects_non_database_file (test_database_backup.DatabaseBackupsTests.test_verify_rejects_non_database_file) ... ok
test_rejects_missing_session_cookie (test_deployment.smoke.DeploymentSmokeTests.test_rejects_missing_session_cookie) ... ok
test_security_headers_require_hsts_for_https (test_deployment.smoke.DeploymentSmokeTests.test_security_headers_require_hsts_for_https) ... ok
test_session_cookie_requires_secure_and_httpsonly (test_deployment.smoke.DeploymentSmokeTests.test_session_cookie_requires_secure_and_httpsonly) ... ok
test_disabled_mode_fails_closed (test_email_service.EmailServiceTests.test_disabled_mode_fails_closed) ... ok
test_ses_error_is_wrapped_without_exposing_provider_details (test_email_service.EmailServiceTests.test_ses_error_is_wrapped_without_exposing_provider_details) ... ok
test_ses_send_html_opt_email (test_email_service.EmailServiceTests.test_ses_send_html_opt_email) ... ok
[2026-09-17 12:03:44.954] WARNING in app: Using database: sqlite://:/tmp/tmp1uhvif/security.db
test_csrf_rejects_missing_token_and_accepts_header (test_security_controls.SecurityControlTests.test_csrf_rejects_missing_token_and_accepts_header) ... ok
test_failed_otp_delivery_removes_code_and_hides_account_state (test_security_controls.SecurityControlTests.test_failed_otp_delivery_removes_code_and_hides_account_state) ... [2026-09-17 12:03:45.660] ERROR in auth: G&A OTP thất bại
Traceback (most recent call last):
  File "/home/minik/cloud-security-project/app/routes/auth.py", line 176, in forgot_password
    and otp_email(email, otp)
    ~~~~~
  File "/usr/lib/python3.14/unittest/mock.py", line 1176, in __call__
    return self._mock_call(*args, **kwargs)
    ~~~~~
  File "/usr/lib/python3.14/unittest/mock.py", line 1180, in _mock_call
    return self._execute_mock_call(*args, **kwargs)
    ~~~~~
  File "/usr/lib/python3.14/unittest/mock.py", line 1241, in _execute_mock_call
    raise effect
services_email_service.EmailDeliveryError: SES unavailable
ok
test_login_endpoint_is_rate_limited (test_security_controls.SecurityControlTests.test_login_endpoint_is_rate_limited) ... ok
test_login_lockout_records_audit_events (test_security_controls.SecurityControlTests.test_login_lockout_records_audit_events) ... ok
test_password_policy_and_post_only_login (test_security_controls.SecurityControlTests.test_password_policy_and_post_only_login) ... ok
test_password_reset_invalidates_existing_session (test_security_controls.SecurityControlTests.test_password_reset_invalidates_existing_session) ... ok
test_security_headers_and_nonce_are_present (test_security_controls.SecurityControlTests.test_security_headers_and_nonce_are_present) ... ok
test_upload_rejects_dangerous_and_oversized_file (test_security_controls.SecurityControlTests.test_upload_rejects_dangerous_and_oversized_files) ... ok
test_s3_upload_download_and_delete (test_storage_service.StorageServiceTests.test_s3_upload_download_and_delete) ... ok
test_storage_operations_reject_path_traversal (test_storage_service.StorageServiceTests.test_storage_operations_reject_path_traversal) ... ok
test_validation_rejects_suspicious_archive_ratio (test_storage_service.StorageServiceTests.test_validation_rejects_suspicious_archive_ratio) ... ok
test_validation_returns_checksum_and_rejects_archive_traversal (test_storage_service.StorageServiceTests.test_validation_returns_checksum_and_rejects_archive_traversal) ... ok
.....
Ran 78 tests in 14.023s

ok
(.venv-ubuntu) minikubectl -n cloud-security-project python -m unittest discover -s security -p 'test_*.py' -v 2>&1 |
[ 2026-09-17 12:03:45.660] ERROR in auth: G&A OTP thất bại
test_project_iam_policies_pass (lan.test_iam.IAMSecurityTests.test_project_iam_policies_pass) ... ok
test_rejects_allow_all (lan.test_iam.IAMSecurityTests.test_rejects_allow_all) ... ok
test_rejects_missing_action_and_resource (lan.test_iam.IAMSecurityTests.test_rejects_missing_action_and_resource) ... ok
test_rejects_s3_policy_without_transport_deny (lan.test_iam.IAMSecurityTests.test_rejects_s3_policy_without_transport_deny) ... ok
test_scan_policy_directory (lan.test_iam.IAMSecurityTests.test_scan_policy_directory) ... ok
test_account_audit_is_read_only_and_does_not_expose_hashes (lan.test_iam.IAMSecurityTests.test_account_audit_is_read_only_and_does_not_expose_hashes) ... ok
test_cloudwatch_alarm_has_expected_schema (monitoring.test_monitoring.SecurityMonitoringTests.test_cloudwatch_alarm_has_expected_schema) ... ok
test_failed_login_threshold_reports_alert (monitoring.test_monitoring.SecurityMonitoringTests.test_failed_login_threshold_reports_alert) ... ok
test_missing_database_fails_without_creating_s3 (monitoring.test_monitoring.SecurityMonitoringTests.test_missing_database_fails_without_creating_s3) ... ok
test_missing_login_telemetry_reports_incomplete (monitoring.test_monitoring.SecurityMonitoringTests.test_missing_login_telemetry_reports_incomplete) ... ok
.....
Ran 10 tests in 0.042s

ok
```

Hình 5.21: Kết quả 78 bài kiểm thử ứng dụng và 10 bài kiểm thử mô-đun bảo mật đều đạt trên Ubuntu

Bảng 5.4: Tổng hợp kiểm chứng và giới hạn kết luận

Phép kiểm tra	Kết quả	Phạm vi kết luận
Unittest ứng dụng	78/78 đạt	Các điều kiện kiểm tra của bộ test trên môi trường local/mock
Unittest security	10/10 đạt	Các mô-đun trong bộ test, không phải AWS thật
Compileall	Thành công	Mã Python được biên dịch cú pháp
Pip check	Không lỗi thư viện phụ thuộc	Tương thích yêu cầu package đã cài, không đánh giá CVE
Bandit High	Không có High	Còn thống kê Low/Medium; không thay pentest
Docker/MySQL	Healthy sau khởi động lại	Hai bản tệp có SHA-256 trùng nhau; chưa kiểm chứng lại quyền chia sẻ
Smoke test local	HTTP 200; headers đạt	Endpoint đăng nhập, CSRF và chính sách phản hồi trong chế độ HTTP
Terraform/AWS	Đã apply và thử phục hồi riêng lẻ	Đã nhận email SNS từ CloudWatch; S3 Versioning và RDS snapshot phục hồi đạt; chưa kiểm thử đồng bộ
Mô phỏng tấn công	ATK-01–ATK-10	Kết quả theo Bảng 5.2 và hồ sơ ảnh
Pip-audit/Trivy	CI số 5 thành công	Đạt theo ngưỡng và ngoại lệ cấu hình; không chứng minh sạch mọi lỗ hổng

và security group theo quan hệ nguồn; kết quả ghi nhận khi hệ thống chạy được đối chiếu theo Bảng 4.4.

Bí mật vẫn phụ thuộc vào khóa ký phiên, tài khoản quản trị và thông tin xác thực dịch vụ. Cookie cũ sau đăng xuất, quyền đặt lại mật khẩu sau OTP và tài khoản master RDS là các điểm cần tiếp tục xử lý. Chưa thể kết luận bảo vệ bí mật đầy đủ chỉ từ số bài kiểm thử đạt.

5.15.2. Mức độ bảo vệ tính toàn vẹn

Ràng buộc dữ liệu, kiểm tra chủ sở hữu và giá trị băm hỗ trợ tính toàn vẹn. Cơ chế bù trừ giảm khả năng tệp tồn tại khi siêu dữ liệu không ghi được. Tuy nhiên, giá trị băm hiện được lưu khi tải lên, chưa được kiểm lại tự động ở mọi lần tải xuống.

Nhật ký hiện được lưu trong cơ sở dữ liệu, còn các thao tác dọn dẹp chỉ cố gắng thực hiện và vẫn có thể thất bại. Để phát hiện sai lệch, cần định kỳ đối chiếu nội dung tệp với thông tin đã lưu và kiểm tra lại giá trị băm. Quyền sửa hoặc xóa nhật ký cũng cần được quản lý tách biệt.

5.15.3. Mức độ bảo vệ tính sẵn sàng

Giới hạn tải lên, hạn mức lưu trữ và kiểm tra tệp nén giảm một số tình huống dùng tài nguyên quá mức. Script backup SQLite có kiểm tra tính hợp lệ và phục hồi vào tệp mới. Những kết quả này là nền tảng hữu ích cho vận hành cục bộ.

Kiến trúc một EC2, bộ đếm yêu cầu trong bộ nhớ và chưa kiểm thử phục hồi toàn hệ thống giới hạn mức sẵn sàng có thể khẳng định. ALB có health check không tạo ra máy thay thế khi chỉ có một target. Chưa có số đo để chứng minh đạt RTO/RPO hoặc phục vụ ổn định dưới tải lớn.

5.15.4. Khả năng phát hiện và truy vết

Nhật ký hoạt động phản ánh một số sự kiện xác thực và quản trị, hỗ trợ phân tích thay đổi quyền. CloudWatch và VPC Flow Logs cung cấp điểm tập trung log trong môi trường AWS đã triển khai. Tuy nhiên, log nghiệp vụ chưa bao phủ đầy đủ mọi lần tải lên, tải xuống và chia sẻ.

Cảnh báo tài nguyên chưa thay thế giám sát hành vi bảo mật. Phép thử đã xác nhận người nhận nhận được email SNS khi kích hoạt thủ công alarm EC2; cần bổ sung kiểm thử vượt ngưỡng thật và diễn tập phản ứng. Nhật ký hiện tại hỗ trợ truy vết một số hoạt động, nhưng chưa đáp ứng đầy đủ chức năng của SIEM hoặc bảo đảm bản ghi không bị sửa đổi.

5.16. Ưu điểm của mô hình

Mô hình kết hợp kiểm tra đăng nhập với quyền truy cập và trạng thái của từng tài liệu. Phân lưu trữ được tách khỏi xử lý nghiệp vụ nên có thể dùng ổ đĩa cục bộ hoặc S3, đồng thời thuận tiện cho việc mô phỏng lỗi. Bộ kiểm thử bao gồm cả yêu cầu hợp lệ và yêu cầu phải bị từ chối, giúp phát hiện chức năng bị ảnh hưởng sau khi sửa mã nguồn.

Docker và IaC làm rõ kiến trúc đồng thời tăng khả năng tái lập giữa máy ảo Ubuntu và AWS. Workflow định nghĩa các bước kiểm tra chất lượng, bảo mật và nghiệm thu sau apply. Các mã tham chiếu giúp tra cứu riêng kết quả kiểm thử đơn vị, kết quả chạy container và trạng thái tài nguyên đám mây.

5.17. Hạn chế của mô hình

Các hạn chế quan trọng được xác định trực tiếp từ mã nguồn và phạm vi thực nghiệm. Không có bộ quét mã độc hoàn chỉnh; not_scanned vẫn tải được. Bộ đếm giới hạn yêu cầu trong bộ nhớ không tổng hợp qua các worker. Việc kiểm tra dung lượng và ghi dữ liệu diễn ra ở hai bước riêng, nên chưa thể khẳng định hệ thống ngăn được vượt hạn mức khi nhiều yêu cầu đến cùng lúc.

Luồng đặt lại mật khẩu chưa có token giao dịch một lần phía máy chủ sau OTP; đăng xuất chưa thu hồi mọi bản sao cookie. Ứng dụng chạy trên AWS sử dụng thông tin xác thực của tài khoản quản trị RDS và có quyền sửa secret ứng dụng. Log chưa toàn diện và chưa chống sửa đổi độc lập. CI số 5 bổ sung bằng chứng quét image theo ngưỡng cấu hình; CloudWatch đã được thử chuyển trạng thái và nhận email SNS

nhưng chưa kiểm thử tạo tải thật, còn phục hồi RDS và S3 mới được kiểm tra riêng lẻ chứ chưa đồng bộ. Kết quả đối chiếu tệp sau khởi động lại chưa thay thế việc xác minh lại dữ liệu và quyền tài liệu sau phục hồi.

Kết quả 88 bài kiểm thử đạt cho thấy các tình huống đã kiểm tra hoạt động như mong đợi. Những hạn chế nêu trên thuộc các tình huống hoặc yêu cầu chưa được kiểm chứng đầy đủ. Ở giai đoạn tiếp theo, nhóm cần bổ sung biện pháp xử lý và bài kiểm thử cho từng hạn chế này.

5.18. Rủi ro còn lại và thứ tự cải tiến

Bảng 5.5: Ưu tiên xử lý sau đánh giá

Ưu tiên	Vấn đề	Điều kiện xác nhận hoàn thành
P1	Đặt lại mật khẩu sau OTP và thu hồi phiên	Token một lần có hạn; test dừng lại, hết hạn và đồng thời
P1	Nội dung chưa quét vẫn tải	Tích hợp quét/cách ly; lỗi quét bị chặn; kết quả gắn giá trị băm
P1	Thông tin xác thực có quyền cao khi chạy ứng dụng	Tài khoản cơ sở dữ liệu chỉ có quyền cần thiết; tách migration và bootstrap secret
P2	Rate limit và hạn mức lưu trữ đồng thời	Kho limiter chung; cơ chế kiểm tra và cập nhật dung lượng trong cùng một thao tác; test nhiều worker
P2	Phục hồi và đối soát	Khôi phục đồng bộ siêu dữ liệu và tệp; đo RPO/RTO
P2	Nhật ký kiểm toán và cảnh báo	Bao phủ vòng đời tài liệu; quyền log tách biệt; thử cảnh báo
P3	Mở rộng và chịu lỗi	Kiểm thử tải, nhiều target và quy trình thay instance

Thứ tự ưu tiên dựa trên ảnh hưởng đến danh tính và dữ liệu trước khi tối ưu mở rộng. Các cải tiến cần được kiểm tra trong môi trường có thể tái lập và có dữ liệu thử phù hợp. Không gán điểm rủi ro còn lại thấp hơn nếu chưa có bằng chứng kiểm soát mới hoạt động.

5.19. Kết luận chương

Thực nghiệm xác nhận 88 bài kiểm thử tự động thành công, môi trường Docker/MySQL hoạt động trên máy ảo Ubuntu và hạ tầng thử nghiệm được triển khai trên AWS bằng Terraform. Các kịch bản ATK-01–ATK-10 liên kết nguy cơ với phản hồi của kiểm soát. Kết quả hỗ trợ đánh giá nền tảng chức năng, triển khai và một số lớp bảo vệ; đợt nghiệm thu bổ sung xác nhận chuyển trạng thái CloudWatch cùng phục hồi riêng lẻ S3/RDS, nhưng các khoảng trống về quét mã độc, đặt lại mật khẩu, giới hạn quyền tài khoản dịch vụ và phục hồi đồng bộ vẫn cần xử lý trước khi mở rộng phạm vi sử dụng.

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

1. Kết luận

Đề tài đã hệ thống hóa cơ sở lý thuyết điện toán đám mây và an toàn thông tin, nhận diện tài sản của ứng dụng lưu trữ tài liệu, phân tích nguy cơ theo các lớp và xây dựng ma trận ưu tiên. Từ đó, mô hình bảo vệ dữ liệu được đề xuất với sự phối hợp của xác thực, quyền cấp tài liệu, kiểm tra tải lên, bảo vệ dữ liệu và vận hành.

CloudBox hiện thực được các chức năng cốt lõi và nhiều kiểm soát tương ứng. Kết quả chạy lại 78 bài kiểm thử ứng dụng và 10 bài kiểm thử mô-đun bảo mật đều đạt trong môi trường đã mô tả. Ứng dụng được chạy bằng Docker/MySQL trên máy ảo Ubuntu; hạ tầng AWS được tạo bằng Terraform và kiểm tra theo trạng thái tài nguyên cùng endpoint ALB. Việc đối chiếu mã nguồn, mô phỏng tấn công và bằng chứng triển khai cho phép chỉ ra cụ thể phần đã hiện thực, phần đã kiểm chứng và phần còn giới hạn.

Qua đề tài, nhóm đã đối chiếu từng nguy cơ với yêu cầu bảo vệ, phần mã nguồn thực hiện và kết quả kiểm thử. Quá trình này cho thấy việc bảo vệ dữ liệu cần kết hợp mã hóa, kiểm tra quyền trên từng yêu cầu, kiểm tra tệp và khả năng khôi phục khi có sự cố. Kết quả hiện tại có giá trị trong phạm vi thử nghiệm; để sử dụng ở quy mô doanh nghiệp, hệ thống cần được đánh giá thêm.

2. Hạn chế

Thử nghiệm đã triển khai môi trường AWS thử nghiệm và chạy Docker/MySQL nhưng chưa có pentest độc lập, kiểm thử tải lớn hoặc kiến trúc nhiều instance. Một số tính năng có khung hỗ trợ nhưng chưa hoàn chỉnh, tiêu biểu là quét mã độc và giám sát đầy đủ vòng đời tài liệu. Kết quả AWS chỉ xác nhận các điều kiện vận hành đã kiểm tra ở thời điểm nghiệm thu, không phải chứng nhận an toàn hay sẵn sàng vận hành ở quy mô doanh nghiệp.

Rà soát còn chỉ ra nhu cầu hoàn thiện token đặt lại mật khẩu một lần, thu hồi phiên, tài khoản cơ sở dữ liệu dùng khi chạy ứng dụng, giới hạn tốc độ dùng chung và cơ chế kiểm tra và cập nhật dung lượng trong cùng một thao tác. Bản sao lưu SQLite đã được kiểm tra trong phạm vi script; S3 Versioning và RDS snapshot cũng đã được phục hồi riêng lẻ, nhưng chưa chứng minh phục hồi đồng bộ siêu dữ liệu và nội dung trên AWS. Do đó, chưa có căn cứ đặt ra số đo RPO/RTO đạt được cho toàn hệ thống.

3. Hướng phát triển

Giai đoạn tiếp theo ưu tiên hoàn thiện những điểm tác động trực tiếp đến quyền và nội dung: token đặt lại mật khẩu ngắn hạn một lần, chính sách thu hồi phiên, quét mã độc có cách ly và tách quyền tài khoản cơ sở dữ liệu. Mỗi thay đổi cần đi cùng bài kiểm thử các trường hợp phải bị từ chối, kể cả tình huống lỗi dịch vụ hoặc yêu cầu đồng thời.

Sau đó, chuyển limiter sang kho dùng chung, bổ sung cơ chế kiểm tra và cập nhật dung lượng trong cùng một thao tác, đối soát tệp mờ côi và mở rộng nhật ký kiểm toán. Trên AWS, cần hoàn thiện HTTPS nếu lần triển khai hiện tại còn dùng HTTP, tách tài khoản cơ sở dữ liệu dùng khi chạy ứng dụng, kiểm thử cảnh báo dưới tải thật và quy trình phản ứng sau email SNS, rồi diễn tập chuyển kết nối cùng kiểm tra nội dung, quyền và tính nhất quán giữa RDS với S3.

Khi có nhu cầu tải và mức sẵn sàng rõ ràng, có thể đánh giá nhiều instance, Auto Scaling, RDS Multi-AZ, WAF, quản lý khóa chi tiết và lưu log độc lập. Những lựa chọn này phải dựa vào rủi ro, yêu cầu vận hành và chi phí; không bổ sung chỉ để tăng số lượng dịch vụ trong kiến trúc.

TÀI LIỆU THAM KHẢO

- [1] NIST, *The NIST Definition of Cloud Computing*, SP 800-145, 2011. [Trực tuyến]. <https://csrc.nist.gov/pubs/sp/800/145/final>.
- [2] A. Kraus, *The Official (ISC)² CCSP CBK Reference*, ấn bản thứ 4. John Wiley & Sons, 2023. ISBN: 978-1-119-90901-9. [PDF].
- [3] AWS, *Shared Responsibility Model*. [Trực tuyến]. <https://aws.amazon.com/compliance/shared-responsibility-model/>.
- [4] AWS, *Security best practices for Amazon S3*. [Trực tuyến]. <https://docs.aws.amazon.com/AmazonS3/latest/userguide/security-best-practices.html>.
- [5] AWS, *Security in Amazon RDS*. [Trực tuyến]. <https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/UsingWithRDS.html>.
- [6] NIST, *Zero Trust Architecture*, SP 800-207, 2020. [Trực tuyến]. <https://csrc.nist.gov/pubs/sp/800/207/final>.
- [7] OWASP, *Authentication Cheat Sheet*. [Trực tuyến]. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html.
- [8] OWASP, *Authorization Cheat Sheet*. [Trực tuyến]. https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html.
- [9] OWASP, *Password Storage Cheat Sheet*. [Trực tuyến]. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html.
- [10] OWASP, *OWASP Top 10:2025*. [Trực tuyến]. <https://top10.owasp.org/2025/>.
- [11] OWASP, *Application Security Verification Standard*, kho dự án chính thức. [Trực tuyến]. <https://github.com/OWASP/ASVS>.
- [12] NIST, *Cybersecurity Framework*, CSF 2.0. [Trực tuyến]. <https://www.nist.gov/cyberframework>.
- [13] CIS, *CIS Amazon Web Services Benchmarks*. [Trực tuyến]. https://www.cisecurity.org/benchmark/amazon_web_services.
- [14] AWS, *Security Pillar – AWS Well-Architected Framework*. [Trực tuyến]. <https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html>.
- [15] ISO, *ISO/IEC 27001:2022 – Information security management systems*. [Trực tuyến]. <https://www.iso.org/standard/27001>.
- [16] E. Estrin, *Cloud Security Handbook: Find out how to effectively secure cloud environments using AWS, Azure, and GCP*. Packt, 2022.

- [17] OWASP, “File Upload Cheat Sheet.” [Trực tuyến]. https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html.
- [18] AWS, “Using server-side encryption with Amazon S3 managed keys (SSE-S3).” [Trực tuyến]. <https://docs.aws.amazon.com/AmazonS3/latest/userguide/UsingServerSideEncryption.html>.
- [19] A. Mishra, *Cloud Security Handbook for Architects: Practical Strategies and Solutions for Architecting Enterprise Cloud Security using SECaaS and DevSecOps*. Orange Education, 2023.
- [20] S. Majumdar et al., *Cloud Security Auditing*, Advances in Information Security, vol. 76. Springer, 2019. doi: 10.1007/978-3-030-23128-6.
- [21] Pallets Projects, “Security Considerations,” *Flask Documentation 3.1.x*. [Trực tuyến]. <https://flask.palletsprojects.com/en/stable/web-security/>.
- [22] M. J. Haber, B. Chappell và C. Hills, *Cloud Attack Vectors: Building Effective Cyber-Defense Strategies to Protect Cloud Resources*. Apress, 2022. doi: 10.1007/978-1-4842-8236-6. [PDF].

PHỤ LỤC A. Hướng dẫn cài đặt và kiểm chứng hệ thống

A.1. Cài đặt và chạy kiểm thử cục bộ

Các lệnh dưới đây thực hiện tại thư mục gốc dự án và dùng dữ liệu thử. Python 3.12 là nhánh được khai báo trong môi trường CI/container. Trên Windows, lệnh kích hoạt môi trường ảo khác với Linux nhưng các lệnh Python sau kích hoạt giữ cùng mục đích.

```
python -m venv .venv
# Windows PowerShell:
.venv\Scripts\Activate.ps1
# Linux:
source .venv/bin/activate
python -m pip install -r app/requirements.txt
```

Trước khi chạy ứng dụng, cấu hình SECRET_KEY riêng cho môi trường; DATABASE_PATH và UPLOAD_FOLDER chỉ tới dữ liệu thử. Không sử dụng khóa phát triển mặc định ngoài local. OTP_DELIVERY_MODE cần phù hợp với kênh gửi đã chuẩn bị; khi chưa có email, chỉ kiểm thử luồng bằng dữ liệu mô phỏng.

```
python -m flask --app app/app.py run
python -m unittest discover -s tests -v
python -m unittest discover -s security -t . -v
python -m compileall -q app scripts security tests
python -m pip check
```

Kết quả tóm tắt đã ghi nhận trong lần đánh giá:

```
Application suite: Ran 78 tests in 8.712s -- OK
Security suite:    Ran 10 tests in 0.016s -- OK
pip check:        No broken requirements found.
```

Thời gian phụ thuộc máy chạy. Bộ test có thể in lỗi do các tình huống được mô phỏng có chủ ý; cần đọc kết quả cuối và mã thoát. Không chạy test trên cơ sở dữ liệu sử dụng thật vì setup của test có thao tác xóa dữ liệu thử.

A.2. Kiểm chứng Docker và Terraform

A.2.1. Docker

Chuẩn bị các biến theo cấu hình Compose, tạo secret riêng và xác định volume dành cho thử nghiệm. Tập Compose nằm trong thư mục docker; chạy từ gốc dự án để

đường dẫn build đúng. Đây là các lệnh tái lập môi trường Docker/MySQL đã dùng trên máy ảo Ubuntu:

```
docker compose -f docker/docker-compose.yml config
docker compose -f docker/docker-compose.yml build
docker compose -f docker/docker-compose.yml up -d
docker compose -f docker/docker-compose.yml ps
docker compose -f docker/docker-compose.yml logs web
```

Kiểm tra migration hoàn tất, MySQL khỏe, web phản hồi và dữ liệu vẫn còn sau khi khởi động lại container. Ghi lại phiên bản Ubuntu, Docker, Compose và mã commit trước khi chụp bằng chứng. Không đưa đầu ra cấu hình có secret vào báo cáo hoặc Git. Phần kiểm tra nhiều instance cần dùng profile tích hợp theo Compose và thay limiter memory nếu đánh giá giới hạn chung.

A.2.2. Terraform

Trước khi tạo tài nguyên cần chọn region, tên môi trường, nguồn mã và các biến tùy chọn như chứng chỉ, email, Multi-AZ và backup. Kiểm tra tỉnh có thể thực hiện mà chưa áp dụng hạ tầng:

```
terraform -chdir=terraform fmt -check -recursive
terraform -chdir=terraform init -backend=false -input=false
terraform -chdir=terraform validate
```

Khi triển khai, cấu hình backend phù hợp, rà soát plan rồi áp dụng đúng plan đã duyệt:

```
terraform -chdir=terraform plan -out=tfplan
terraform -chdir=terraform apply tfplan
python scripts/aws_integration_test.py --region ap-southeast-1
```

PHỤ LỤC B. Tổng hợp kiểm thử đã thực hiện

Bảng sau tổng hợp các phương thức kiểm thử theo tệp và nhóm chức năng. Một phương thức có thể chứa nhiều điều kiện kiểm tra. Toàn bộ 78 kiểm thử ứng dụng và 10 kiểm thử mô-đun bảo mật đã chạy thành công trong lần thực nghiệm; số lượng này không được xem như tuyên bố bao phủ mọi trường hợp của một nguy cơ.

Bảng B.1: Tổng hợp các nhóm kiểm thử đã thực hiện

Tệp/nhóm kiểm thử	Phạm vi chính	Số lượng
test_admin_rbac.py	Đăng nhập, vai trò, quản trị và nhật ký kiểm toán	22
test_api.py	API tài liệu, chia sẻ, tải lên và quyền truy cập	16
test_aws_integration.py	Kiểm tra bất biến cấu hình AWS	7
test_ci_configuration.py	Cấu hình CI/CD và các cổng kiểm tra bảo mật	7
test_config.py	Cấu hình kết nối MySQL và TLS	5
test_database_backup.py	Sao lưu, xác minh và phục hồi cơ sở dữ liệu	3
test_deployment_smoke.py	Header bảo mật, cookie và phiên triển khai	3
test_email_service.py	Gửi OTP và xử lý lỗi dịch vụ email	3
test_security_controls.py	CSRF, rate limit, khóa tài khoản và tải tệp	8
test_storage_service.py	S3, checksum, đường dẫn và tệp nén	4
<i>Tổng bộ kiểm thử ứng dụng</i>		78
Mô-đun IAM	Chính sách IAM và kiểm tra quyền quá rộng	6
Mô-đun giám sát	Schema cảnh báo và dữ liệu đăng nhập thất bại	4
<i>Tổng bộ kiểm thử bảo mật</i>		10

Danh sách chi tiết tên từng phương thức được lưu cùng mã nguồn trong các thư mục tests/ và security/; báo cáo chỉ giữ số liệu tổng hợp cần thiết để đối chiếu kết quả.

PHỤ LỤC C. Ma trận hiện thực và bằng chứng

Bảng C.1: Trạng thái kiểm soát theo bằng chứng hiện có

Kiểm soát	Thành phần	Trạng thái / giới hạn
Bấm mật khẩu	auth service, Werkzeug	Có mã và kiểm thử cục bộ
Khóa tài khoản	failed attempts, locked until	Có kiểm thử; cần xem xét gây khóa có chủ ý
Rate limit	Flask-Limiter	Có kiểm thử một môi trường; memory riêng worker
Quyền tài liệu	Query owner/share	Có kiểm thử người được phép và bị từ chối
CSRF và header	Extensions, app hooks	Có kiểm thử; không thay đánh giá XSS đầy đủ
Tải lên	dịch vụ lưu trữ	Có kiểm thử định dạng, đường dẫn, tệp nén
Quét malware	scan status trong document	Chưa có scanner; not_scanned còn tải được
Giá trị bấm tài liệu	siêu dữ liệu SHA-256	Tính khi tải lên; chưa kiểm lại mọi tải xuống
Bù trừ tải lên	document service	Có ca lỗi cơ sở dữ liệu; dọn dẹp nhưng chưa bảo đảm luôn thành công
Backup SQLite	cơ sở dữ liệu backup script	Ba test đạt; không bao gồm toàn bộ kho tệp
S3, RDS, EC2	Terraform, AWS adapters và kiểm tra chỉ đọc	Đã triển khai thử nghiệm; đối chiếu AWS-01–AWS-08
TLS	ALB có điều kiện; RDS config	Ghi theo output thực tế; ALB–EC2 vẫn là HTTP
Nhật ký kiểm toán	activity logs	Một phần hành động; chưa bất biến
CI/CD	CI số 5, commit 9815bfa thành công	Có ảnh pip-audit, Bandit và Trivy; chưa chứng minh triển khai AWS cùng commit
Reset một lần	OTP và phiên reset	Cần token giao dịch có hạn phía máy chủ

Kiểm soát	Thành phần	Trạng thái / giới hạn
Đặc quyền DB	RDS secret trong bootstrap	Runtime còn dùng master; cần tách user

PHỤ LỤC D. Quy trình phục hồi dữ liệu

D.1. Phục hồi SQLite vào tệp mới

Script backup sử dụng SQLite backup API và kiểm tra integrity. Các lệnh mẫu dưới đây dùng tệp thử và đầu ra mới; không ghi đè cơ sở dữ liệu đang phục vụ ứng dụng.

```
python scripts/database_backup.py backup \  
    --source database.db --output backups/cloudbox-test.db  
python scripts/database_backup.py verify backups/cloudbox-test.db  
python scripts/database_backup.py restore backups/cloudbox-test.db \  
    --output restored/cloudbox-test.db
```

Sau bước này cần kiểm tra tài liệu và quan hệ chia sẻ, đồng thời đối chiếu nội dung trong thư mục lưu trữ tương ứng. Kết quả integrity thành công chỉ xác nhận cấu trúc SQLite theo phép kiểm tra, không xác nhận mọi object ngoài cơ sở dữ liệu tồn tại. Đối với phục hồi, ghi thời điểm bắt đầu, điểm dữ liệu được chọn, bước chuyển kết nối, thời điểm phục vụ lại và kết quả xác minh nội dung. Kiểm tra cả tài liệu riêng tư, tài liệu chia sẻ, tài liệu thùng rác và tài khoản vô hiệu hóa sau restore. Từ dữ liệu này mới có thể so sánh với RPO/RTO đã lựa chọn.